

LLM-Based Agents for Software and Systems Security: Approaches, Applications, and Assessment

JINGJING NIE, University at Buffalo, SUNY, USA

JIawei GUO*, University at Buffalo, SUNY, USA

KRISHNA MEDA, University at Buffalo, SUNY, USA

HAIPENG CAI, University at Buffalo, SUNY, USA

Software and systems security workflows are typically procedural: analysts inspect heterogeneous artifacts, form hypotheses, invoke tools, interpret outputs, and revise plans. Large language model (LLM)-based agents, which can plan, use tools, retain state, and revise actions across multi-step workflows, are being rapidly adopted to automate this work. Given the consequences of delegating security decisions to autonomous systems, understanding how such agents are built, used, and assessed is crucial. Yet to this date, there remains a lack of systematic understanding of what has been done and how far we are in this field: the term “agent” is applied inconsistently, applications differ sharply in risk, and assessment protocols are often incomparable. To gain a comprehensive and coherent view of this area hence inform relevant future research, this paper provides a systematic literature review of the (1) technical approaches, including agent architecture, perception, memory, reasoning and planning, action space, orchestration, and self-improvement, (2) applications, with respect to the security tasks served, and (3) assessment, including the datasets, outcome and trajectory metrics, safety measures, and baselines considered, over the peer-reviewed literature spanning the emergence of this area (2023–2026). Our synthesis reveals a field that has built agents able to act but not yet agents whose authority is bounded or whose behavior is auditable. In addition to knowledge systematization, we also extend our insights into the limitations of and challenges faced by current approach, application, and assessment designs, which shed light on potentially promising future research directions.

CCS Concepts: • **Security and privacy** → **Software security engineering**.

Additional Key Words and Phrases: LLM-based agents, agentic AI, software security, systems security, cybersecurity, systematic literature review, benchmarks, assessment

ACM Reference Format:

Jingjing Nie, Jiawei Guo, Krishna Meda, and Haipeng Cai. 2026. LLM-Based Agents for Software and Systems Security: Approaches, Applications, and Assessment. 1, 1 (August 2026), 72 pages. <https://doi.org/10.1145/nnnnnnn.nnnnnnn>

1 Introduction

Software and systems security increasingly depends on reasoning across heterogeneous artifacts: source code, binaries, configurations, logs, vulnerability reports, execution traces, network services, tickets, and human-written policies. Security work is also intrinsically procedural. Analysts rarely solve a task by producing one answer in isolation;

*Equal contribution to the first author.

Authors' Contact Information: [Jingjing Nie](mailto:jnie5@buffalo.edu), jnie5@buffalo.edu, University at Buffalo, SUNY, Buffalo, New York, USA; [Jiawei Guo](mailto:jiaweigu@buffalo.edu), jiaweigu@buffalo.edu, University at Buffalo, SUNY, Buffalo, New York, USA; [Krishna Meda](mailto:krishnamohanmeda@gmail.com), krishnamohanmeda@gmail.com, University at Buffalo, SUNY, Buffalo, New York, USA; [Haipeng Cai](mailto:haipengc@buffalo.edu), haipengc@buffalo.edu, University at Buffalo, SUNY, Buffalo, New York, USA.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than ACM must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

© 2026 ACM.

Manuscript submitted to ACM

Manuscript submitted to ACM

1

they inspect evidence, form hypotheses, call tools, interpret outputs, revise plans, and communicate findings. This makes security a natural but demanding setting for large language models (LLMs). Modern LLMs can interpret code and natural language, but many security tasks require more than text generation. They require systems that can plan, use tools, maintain task state, and act over multi-step workflows.

LLM-based agents provide one response to this need. In the broader AI literature, agentic LLM systems have been developed to interleave reasoning and action, invoke external tools, and operate over interactive environments [78, 107]. In software engineering, benchmarks such as SWE-bench show that realistic tasks often require repository-level context, environment interaction, and iterative repair rather than isolated code completion [43]. These characteristics are even more notable in security. A vulnerability-analysis agent may need to inspect a repository, trace a data flow, query a vulnerability database, run a proof of concept, and explain exploitability. A penetration-testing agent may need to perform reconnaissance, choose tools, interpret command output, and adapt to failed attempts. A repair agent may need to localize a defect, synthesize a patch, run tests, and preserve functionality. A Security Operations Center (SOC) agent may need to correlate alerts, enrich evidence, reduce hallucination, and produce analyst-facing narratives.

Recent research reflects this shift from LLMs as answer generators to LLMs as operational security agents. Systems such as PENTESTGPT [22] and BountyBench [112] explore agentic workflows for penetration testing and offensive security. CVE-Bench [117] assesses agents in executable vulnerability environments. REPOAUDIT [31] studies repository-level vulnerability auditing, while PATCHAGENT [109] targets vulnerability repair. COGNITIVE SOC [84] illustrates how multi-agent designs can support evidence-grounded security operations. These examples show the breadth of current work: LLM-based agents are being applied to vulnerability detection, exploit development, red teaming, fuzzing, malware analysis, reverse engineering, incident response, and access-control assessment, among many others.

At the same time, the rise of LLM-based security agents introduces new scientific and practical challenges. First, the term “agent” is used inconsistently. Some papers describe a single tool-using LLM as an agent; others build multi-agent systems with planners, executors, critics, memory, retrieval, and policy layers. Second, security applications differ sharply in risk. An agent that summarizes alerts has a different safety profile from one that executes exploits, scans internet-facing assets, patches production code, or changes access-control policies. Third, assessment is difficult. Final task success is important, but it does not show whether an agent used evidence faithfully, stayed within scope, avoided hallucinations, respected tool permissions, or consumed a practical amount of time and money.

These issues make the literature hard to interpret without systematic organization. Existing papers vary in their architectures, autonomy levels, memory designs, tool interfaces, security targets, datasets, baselines, and reported metrics. Some focus on end-to-end offensive workflows; others on repository auditing, patching, SOC support, cyber-defense simulation, or benchmark construction. Some assess agents against real-world systems or executable environments, while others use synthetic tasks, curated datasets, or restricted artifacts. Yet to this date, there remains a lack of systematic understanding of what has been done and how far we are in this field. Without a shared taxonomy, it is difficult to compare how agents are built, determine which security tasks they serve and which remain underexplored, or judge whether reported results are reproducible, safe, and comparable across studies.

To address this gap, we systematically review 100 peer-reviewed papers on LLM-based agents for software and systems security, published from January 2023 through March 2026—a window that spans the entire history of this emerging area, since the capable LLMs that serve as these agents’ underlying models only emerged at the end of 2022. We organize the literature along three dimensions: *Approach* captures agent architecture, perception, memory, reasoning and planning, action space, orchestration, and self-improvement; *Application* captures the security tasks served; and *Assessment* captures datasets, outcome and trajectory metrics, safety measures, baselines, and experimental protocols.

This survey makes three main contributions:

- We provide an extensive literature search and selection protocol that yields a corpus of 100 peer-reviewed papers spanning the emergence of this area.
- We derive and apply a taxonomy characterizing the surveyed literature across Approach, Application, and Assessment, enabling structured comparison of agent designs, security tasks, datasets, metrics, and baselines.
- We synthesize the findings into a central observation—that the field has built agents able to act, but not yet agents whose authority is bounded or whose behavior is auditable—and extend it into the limitations of and challenges facing current designs, pointing to future directions in evidence-centered architecture, risk-aware autonomy, realistic and reproducible benchmarks, trajectory-level assessment, and accountable human-agent collaboration.

Paper organization. The rest of the paper is organized as follows. Section 2 provides background concepts used in the survey. Section 3 summarizes the survey methodology, and Section 4 describes the literature search and selection process. Section 5 presents the taxonomy derivation. Section 6 maps the surveyed papers to the taxonomy and analyzes the results for Approach, Application, and Assessment. Section 7 discusses limitations, challenges, and future research directions. Section 8 discusses threats to validity, and Section 9 concludes the paper.

2 Background and Related Work

This section provides essential background on LLM-based agents and software/systems security, followed by a discussion of related surveys.

2.1 LLM-Based Agents

A large language model (LLM) is a neural network trained on large-scale text corpora that can generate, interpret, and reason over natural language and code [114]. Foundation-scale LLMs—including GPT [67], Claude [7], Gemini [27], and open-weight models such as LLaMA [90] and DeepSeek [21]—have demonstrated broad capabilities in code understanding, program repair, and security reasoning when used with appropriate prompting strategies.

An LLM-based agent extends a standalone LLM into a task-oriented system that can perceive its environment, reason about observations, plan multi-step actions, invoke external tools, and learn from feedback [93]. Whereas a bare LLM processes a single prompt and returns a single response, an agent operates in a loop: it observes the current state (e.g., tool output, code context, alert data), selects an action (e.g., run a scanner, query a knowledge base, generate a patch), executes that action, and then reasons over the result to decide its next step. This observe-reason-act cycle may repeat over many iterations before the agent produces a final output.

Several components distinguish agents from standalone LLM usage:

Agent architecture. An agent may be a single autonomous entity or a coordinated team of multiple agents. Single-agent designs handle the entire task loop in one model, while multi-agent designs decompose the task across specialised agents that communicate through message passing, shared memory, or hierarchical delegation.

Memory. Agents maintain state across steps through in-context working memory (the current prompt window), external short-term memory (e.g., an exploration trace stored outside the context), and long-term or persistent memory (e.g., a vector database of prior findings, a knowledge graph of discovered assets). Memory enables continuity: an agent can remember what it has already scanned, which hypotheses failed, and what evidence supports a current finding.

Perception. Perception concerns how raw artifacts—source code, binary disassembly, execution traces, log entries, network packets, alert records—are transformed into reasoning-ready context for the LLM. Common mechanisms

include direct ingestion into the prompt, retrieval-augmented generation (RAG) from external corpora, summarisation of verbose tool output, and embedding-based semantic matching.

Reasoning and planning. Agents employ various reasoning paradigms to decide what to do next. ReAct [107] interleaves reasoning, tool action, and observation. Chain-of-thought (CoT) [96] makes intermediate reasoning explicit. Reflection and self-critique allow the agent to evaluate its own intermediate products before continuing. Planning strategies include dynamic/reactive planning (revising steps based on new observations), hierarchical task decomposition (separating high-level goals from low-level execution), and backtracking on failure.

Action space and tools. The action space defines what operations the agent can invoke: static analysis tools (linters, taint analysers, formal verifiers), dynamic analysis tools (fuzzers, debuggers, execution sandboxes), code execution environments (shells, compilers, containers), information retrieval tools (code search, documentation retrieval, RAG), and security-specific platforms (CTF environments, penetration-testing frameworks, SIEM/SOAR systems, MITRE ATT&CK integration). The breadth of the action space largely determines what security tasks the agent can address.

Self-improvement and learning. Some agents adapt their behaviour over time through in-context learning from session feedback, cross-session trajectory storage, fine-tuning on solved tasks, or reinforcement learning with environment-based reward signals. These mechanisms allow agents to improve on repeated tasks without manual prompt engineering.

2.2 Software and Systems Security

Software and systems security encompasses the protection of software artifacts, computing infrastructure, and networked environments against threats that compromise their confidentiality, integrity, or availability [6]. The security lifecycle spans a broad set of tasks that range from proactive analysis through reactive response:

Vulnerability discovery and management. This includes the detection, localization, classification, prioritization, and tracking of software weaknesses in source code, compiled binaries, smart contracts, APIs, and infrastructure configurations. Traditional approaches rely on static analysis, dynamic testing, and manual code review; LLM-based agents augment these approaches with natural-language reasoning over code context, automated hypothesis generation, and iterative refinement.

Offensive security. Penetration testing, red-teaming, exploit development, and adversarial simulation assess the resilience of deployed systems by actively attempting to compromise them. These tasks are inherently interactive and multi-step, making them a natural fit for agentic workflows that can plan, execute, and adapt offensive strategies.

Defensive monitoring and response. Intrusion detection, incident response, log analysis, anomaly detection, threat intelligence, and SOC workflows monitor deployed systems for active or recent compromises. Agents in this space reason over heterogeneous runtime telemetry—logs, alerts, network flows—and must correlate signals into actionable defensive decisions.

Low-level artifact analysis. Binary analysis, reverse engineering, protocol inference, and malware analysis reason over artifacts below the level of source code. These tasks require agents to compensate for missing structure—no source, no specification, or only externally-observable behavior—by combining LLM reasoning with established analysis tools.

Repair and hardening. Automated program repair (APR), patch generation, code hardening, and security policy enforcement produce defensive modifications that close known weaknesses or prevent classes of future vulnerabilities. Agentic approaches extend traditional APR by integrating fault localization, patch synthesis, and validation into a single iterative loop.

Table 1. Comparison with closely related surveys. *Agents*: requires an agentic architecture rather than LLM usage alone. *Instrument*: agents as security practitioners (vs. agents as the object of attack). *Approach/Application* (to security)/*Assessment*: aspects covered (● full, ● partial, ○ absent). *Year*: year of surveyed studies covered up to

Survey	Scope	Agents	Instrument	Approach	Application	Assessment	Year
Xu et al. [103]	LLMs for cybersecurity	○	●	●	●	●	2024
Zhou et al. [115]	LLMs for vuln. detect./repair	○	●	●	●	●	2024
Fan et al. [25]	LLMs for SE	○	○	●	○	○	2023
Liu et al. [50]	LLM agents for SE	●	○	●	○	●	2024
Xu et al. [105]	Agents for cyberattacks	●	●	●	●	○	2025
Hassanin et al. [33]	LLMs for cyber defence	○	●	○	●	○	2024
Tang et al. [87]	Attacks/defenses on agents	●	○	●	●	●	2025
Shahriar et al. [82]	Agentic security landscape	●	●	○	●	○	2025
Wang et al. [93]	LLM agents (domain-agnostic)	●	○	●	○	○	2024
This survey	LLM agents for SW/sys. security	●	●	●	●	●	2026

2.3 Related Work

Table 1 contrasts our survey with the most closely related prior work. No existing survey combines our focus (LLM-based *agents*), domain (software and systems security), and three-aspect taxonomy (approach, application, and assessment). We group and contrast these surveys below.

LLMs for cybersecurity. Xu et al. [103] conduct a systematic literature review of LLMs for cybersecurity, analyzing 185 papers across vulnerability detection, malware analysis, and intrusion detection, and characterizing how LLM architectures and adaptation techniques map onto security tasks. Zhou et al. [115] narrow the scope to vulnerability detection and repair, comparing prompting, fine-tuning, and retrieval-augmented strategies. Both are closest to our application categories, but both treat the LLM as a model applied to a task rather than as an operational system: neither characterizes the agentic execution model—planning, tool invocation, memory, orchestration, and iterative refinement—that determines what an agent can attempt and how its behavior must be assessed. Our corpus is disjoint from theirs by construction, since we require an agentic architecture rather than LLM usage alone.

LLM-based agents for software engineering. Fan et al. [25] survey LLMs for software engineering and identify open problems across code generation, program repair, testing, and maintenance, treating the LLM largely as a single-shot predictor. Liu et al. [50] narrow this to LLM-based *agents* for software engineering, organizing the literature by agent roles, planning, memory, and multi-agent collaboration. Both establish that agentic designs improve robustness on complex SE tasks, but neither focuses on security: they do not treat the offensive/defensive duality, adversarial robustness, dual-use risk, or the security-specific benchmarks and safety constraints that define our targeted domain.

LLM-based agents for offense or defense. Xu et al. [105] survey LLM-based agents in autonomous cyberattacks, organizing offensive capabilities along the cyber kill chain, while Hassanin et al. [33] provide a complementary overview of LLMs for cyber defense. Domain-specific surveys narrow further: [86] reviews LLMs and agents across SOC functions. Each addresses one side of the offensive/defensive divide or one application area; our work unifies both orientations and eleven task categories under a single application taxonomy, and additionally characterizes how these agents are constructed and assessed.

Security of LLM-based agents. A distinct line of surveys treats the agent as the object, not the instrument of security. Tang et al. [87] systematize attacks and defenses against LLM-based agents and propose evaluation criteria for each, and Shahriar et al. [82] survey around applications, threats, and defenses. These surveys are complementary rather than competing: they focus on the agent’s own attack surface, whereas we address the agent as a security *practitioner* and treat

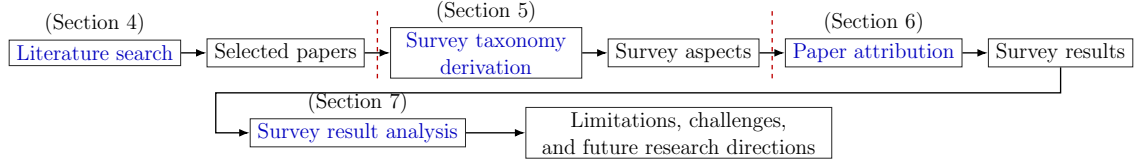


Fig. 1. Overview of our survey methodology and workflow.

attacks on agents as one application category among eleven. Critically, none of them characterizes agent construction at the granularity we require—perception, memory operations, action space, orchestration, and self-improvement—or systematizes assessment practice across datasets, outcome and trajectory metrics, safety measures, and baselines.

General surveys of LLM-based autonomous agents. Wang et al. [93] survey LLM-based autonomous agents across domains, providing a widely-adopted taxonomy of agent construction (profiling, memory, planning, and action). We adopt a compatible view of agent architecture (Section 6.2) but specialize it to security: our categories capture sandboxed execution, integration with scanners and CTF environments, scope containment, and robustness against prompt injection—adaptations that domain-agnostic agent surveys do not address.

In contrast to all of the above, our work is, to our knowledge, the first systematic survey to focus specifically on LLM-based *agents*—rather than standalone LLMs—as instruments of software and systems security, with a unified taxonomy spanning how such agents are built (*approach*), what security problems/tasks they address (*application*), and how they are assessed (*assessment*). This three-aspect coupling allows us to observe that autonomy has outpaced governance and that assessment practice has not kept pace with either—a finding no single-aspect survey would make.

3 Overview of Survey Methodology

To gain a systematic understanding of LLM-based agents for software and system security, our survey is organized around three research questions (RQs), to answer which we follow a structured methodology shown in Figure 1.

- **RQ1 (Approach).** How are LLM-based agents for software and systems security constructed and operated, in terms of architecture, perception, memory, reasoning and planning, action space, orchestration, and self-improvement?
- **RQ2 (Application).** Which software and systems security tasks do these agents address, and how is effort distributed across the security lifecycle?
- **RQ3 (Assessment).** How is agent behavior assessed, in terms of datasets, outcome and trajectory metrics, safety measures, and baselines?

We first performed a systematic *literature search* (§4) to collect peer-reviewed studies published between January 2023 and March 2026. This time window captures the period in which LLM-based agent systems became a visible research direction while keeping the scope focused on recent work. The search process combined keyword-based searching and forward/backward snowballing, followed by manual eligibility filtering based on explicit inclusion and exclusion criteria. This process produced the final set of 100 papers used in the survey.

Based on the selected papers, we then derived the *survey taxonomy* (§5). The taxonomy characterizes the literature from three complementary aspects: *approach*, which captures how LLM-based security agents are designed and operated; *application*, which captures the security tasks addressed by the agents; and *assessment*, which captures the datasets, metrics, and experimental protocols used to assess agentic security systems.

After deriving the taxonomy, we conducted *paper attribution* (§6) by mapping each selected paper to the taxonomy items. This attribution process allowed us to summarize cross-paper patterns, compare agent designs and applications,

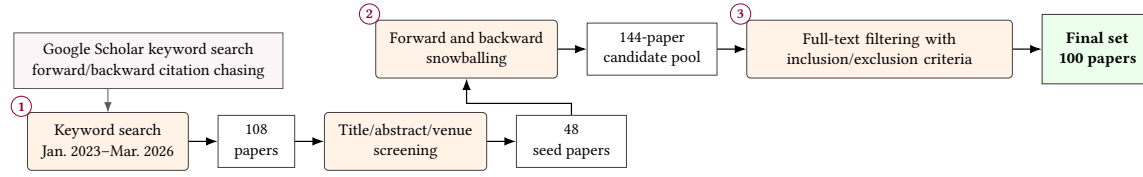


Fig. 2. Overview of our literature search process.

and identify how the surveyed works assess agent behavior. Finally, we analyzed the attributed results (§7) to identify limitations, open challenges, and future research directions for LLM-based agents in software and systems security.

4 Literature Search

We searched, identified, and filtered studies on LLM agents for software and system security in three phases, as summarized in Figure 2. The goal of the search was to collect papers that explicitly use or develop LLM-based agents for security-related software or system tasks, while excluding work that primarily studies the security of agents or LLMs themselves in general.

4.1 Phase 1

We search broadly for all potentially relevant research papers on Google Scholar and main academic publication portals/digital libraries such as ACM DL, IEEE Xplore, Scopus, and DBLP. We used the following two groups of topic-relevant keywords and their (pair-wise) combinations as queries: Group-1: "AI agent", "LLM agent", "LLM-based agent", "agentic", "multi-agent", "autonomous agent"; and Group-2: "vulnerability detection", "penetration testing", "exploit", "fuzzing", "security testing", "vulnerability assessment", "intrusion detection", "malware detection", "cyber attack". We use these queries as it combines agent-related terms with common software/system security tasks, including vulnerability detection, penetration testing, exploit analysis, fuzzing, security testing, vulnerability assessment, intrusion detection, malware detection, and cyber attacks. This initial search returned 108 candidate papers. We then manually inspected each paper and its metadata in detail. Papers that were clearly outside the target scope were removed at this stage. After this screening, we retained 48 seed papers for the next phase.

4.2 Phase 2

To improve coverage beyond keyword matching, we performed manual forward and backward snowballing from the 48 seed papers. Backward snowballing identified relevant papers cited by the seed papers, while forward snowballing identified later papers that cited them. During this process, we considered whether each candidate paper addressed an LLM-based agent and whether its task concerned software or system security.

The snowballing phase expanded the candidate pool to 144 papers. This pool was then passed to the next phase.

4.3 Phase 3

In the third phase, we manually inspected each candidate paper in the expanded pool and applied the following inclusion and exclusion criteria.

We used three inclusion criteria:

- The paper must use or develop an AI agent whose core intelligence is LLM-based.
- The paper must use the agent for software/system security-related studies.

- The paper must have been published between January 2023 (early enough date of published work on LLM-based agent) and March 2026 (our survey start date).

We also used the following exclusion criteria:

- Papers that do not address both an LLM-based agent and a software/system security task.
- Short articles, abstracts, posters (i.e., shorter than four pages) or non-English publications.
- Studies exclusively available as preprints (e.g., on arXiv) only, which were omitted to keep the survey focused on peer-reviewed work.

For each candidate paper, we examined the title, abstract, keywords, and main text. A paper was included only if it satisfied all inclusion criteria and none of the exclusion criteria. At the end of this phase, we were left with **100** papers as the final corpus for our survey. For each included paper, we recorded its research problem, agent design, security application, datasets or experimental subjects, assessment metrics, main findings, limitations, and future-work discussions when available.

5 Survey Taxonomy Derivation

In this section, we describe how we derived the taxonomy used to characterize the surveyed literature on LLM-based agents for software and systems security, to answer the three RQs (§3. Accordingly, we organize the taxonomy around three high-level aspects: *Approach*, *Application*, and *Assessment*.

We derived the taxonomy in two steps. First, we identified candidate attributes and items by reading and coding the selected papers (§5.1). Second, we generalized and consolidated these candidates into a taxonomy (§5.2). The resulting taxonomy is summarized in Table 2 and then elaborated for each aspect in Section 5.3.1, Section 5.3.2, and Section 5.3.3.

5.1 Attribute/Item Identification

Our attribute/item identification step aims to refine the three survey aspects (*Approach*, *Application*, and *Assessment*) into concrete taxonomy dimensions. We first reviewed the selected papers and recorded recurring terms, concepts, and design choices that describe LLM-based agents for software and system security. For the *Approach* aspect, we identified attributes such as agent architecture, memory, perception, reasoning and planning, action space, workflow and orchestration, and self-improvement. For the *Application* aspect, we recorded the security tasks addressed by the agents, such as vulnerability detection, penetration testing, exploit analysis, repair, fuzzing, intrusion detection, and security operations. For the *Assessment* aspect, we collected dataset characteristics, assessment metrics, baselines, safety measurements, and process-level indicators used to assess agent behavior and performance for the application.

5.2 Attribute/Item Generalization

After the initial attributes and items were identified, we generalized them through several iterations to keep the taxonomy manageable and reusable across papers. We merged semantically similar terms, resolved overlapping categories, and normalized paper-specific wording into broader taxonomy items. For example, under the *Approach* aspect, terms such as tool invocation, shell execution, sandbox execution, and browser automation were organized under the broader attribute of agent action space. Under the *Application* aspect, related tasks such as bug finding, vulnerability localization, and vulnerability triage were generalized into vulnerability detection and analysis. Similarly, under the *Assessment* aspect, metrics such as task completion, exploit success, patch validity, precision, recall, hallucination rate, and tool-call correctness were grouped into broader metric families. After this generalization step, the resulting attributes and items were documented as the survey taxonomy used for paper attribution.

Table 2. Overview of the derived survey taxonomy

Aspect	Attribute	Item	Description
Approach	Agent architecture	Agent multiplicity	Single vs. multi-agent organization.
		Internal structure	Module, pipeline, guardrail, fine-tuning, or hybrid layout.
		Backbone LLM role	LLM as actor, planner, verifier, critic, or controller.
	Agent perception	Input sources	Code, binaries, traces, logs, environments, images, or standards.
		Perception mechanisms	Ingest, retrieve, summarize, embed, or observe via tools.
	Agent memory	Memory types	In-context, external, long-term, graph, or parametric memory.
		Memory operations	Read, write, update, and revise memory.
	Agent reasoning & planning	Security-specific memory	Vulnerability knowledge, repos, traces, CTI, and tool docs.
		Reasoning paradigms	Patterns for analysis, decomposition, critique, and hypotheses.
		Planning strategies	Sequencing, decomposition, revision, and recovery.
		Decision-making under uncertainty	Branching, voting, checkpoints, and uncertainty handling.
	Agent action space	Static analysis tools	Linters, taint analysis, symbolic execution, and verification.
		Dynamic analysis tools	Fuzzers, debuggers, sandboxes, and traffic analysis.
		Code execution & environment	Shells, interpreters, containers, browsers, and automation.
		Information retrieval tools	Search, documentation lookup, vector stores, and RAG.
		Security-specific platforms	CTFs, pentest tools, scanners, SIEM/SOAR, ATT&CK, cloud, OSINT.
	Agent workflow & orchestration	Inter-agent communication	Messaging, aggregation, consensus, and audit trails.
		Human interaction	Human queries, approvals, reviews, and feedback.
		Workflow topology	Seq., parallel, iterative, hierarchical, debate, adversarial.
	Agent learning & self-improvement	Agent roles	Planner, analyst, executor, verifier, reporter, critic, coord.
		Human-in-the-loop integration	Autonomous, human-on-loop, human-in-loop, or collaborative modes.
		In-context adaptation	Within-session feedback, examples, and corrections.
Application		Cross-session learning	Persistent trajectories, experience, or fine-tuning data.
		RL-based improvement	Reward- and environment-driven improvement.
		Vulnerability detection & analysis	Detect, localize, classify, analyze, triage, and correlate vulnerabilities.
		Exploit development & analysis	Generate, chain, craft, detect, and analyze exploits or attack paths.
		Penetration testing & red-teaming	Support reconnaissance, access, escalation, movement, CTFs, and red-team automation.
		Vulnerability repair & hardening	Generate, validate, prioritize, review, and harden vulnerable code or dependencies.
		Fuzzing & test generation	Generate harnesses, seeds, mutations, security tests, and crash triage workflows.
		Malware analysis & detection	Detect, classify, attribute, deobfuscate, and analyze malware behavior.
		Reverse engineering	Analyze disassembly, decompiled binaries, functions, types, symbols, similarity, and protocols.
		Intrusion & threat detection, incident response	Analyze logs or traffic, triage alerts, hunt threats, investigate incidents, and automate response.
Assessment	Dataset origin	Access control & authentication assessment	Test authentication, authorization, firewall, ACL, and access-control policies.
		Threat intelligence & security operations (SecOps)	Synthesize threat intelligence, reports, advisories, policies, Q&A, and CTI analysis.
		Model attack generation & robustness assessment	Assess jailbreaks, prompt injection, agent guardrails, and adversarial ML/LLM robustness.
		Real-world	Production, competition, threat-feed, or curated public artifacts.
		Synthetic / controlled	Generated, mutated, or purpose-built controlled datasets.
		Realism	Synthetic, semi-synthetic, or real-world fidelity.
	Dataset characterisation axes	Label quality	Automatic, competition-verified, expert/reference-verified, weak, or noisy labels; unspecified.
		Scale	Small, medium, or large dataset size.
		Language / artifact	Source, binary, network, log, or other artifact modality.
		Vulnerability type coverage	Breadth of vulnerability classes or task types.
		Accessibility	Public, registered, restricted, proprietary, or internal access.
	Dataset by security task	Vuln. detection & classification	Named corpora, vulnerability databases, and other audit datasets.
		Pentest & CTF	Penetration-testing, CTF, and attack-simulation tasks.
		Smart contracts	Smart-contract vulnerability detection, auditing, and verification.
		Web/phishing/scam	Web threats, phishing, scams, and app-layer abuse.
		Repair/bug-fix	Patch generation, bug fixing, and vulnerability repair.
		Cyber defense / simulation	Defensive simulations, incidents, and cyber ranges.
		Security testing / fuzzing	API, program, and protocol testing or fuzzing.
		AI / agent security	Security risks and defenses for learned systems, LLMs, or agents.
		Asset discovery / OSINT	Asset, exposed-service, and OSINT discovery.
		Malware / Android apps	Malware, mobile apps, and Android artifacts.
	Task effectiveness metrics	Intrusion / SOC / SOAR	Intrusion data, security alerts, triage records, and SOAR workflows.
		Other security task	Security-task datasets outside the listed families.
		Accuracy/classification	Classification accuracy or labeled-output correctness.
		Precision/recall/F1	Retrieval or detection quality from TP/FP/FN counts.
		Error rates	Incorrect outputs, failures, false alarms, and error modes.
		Success/completion	Task completion or objective achievement.
		Findings/yield	Discovered vulnerabilities, bugs, exploits, alerts, or findings.
		Correctness/validity	Validity of reports, patches, exploits, or artifacts.
		Coverage	Codebase, task-space, dataset, or attack-surface coverage.
		Time/responsiveness	Elapsed time, latency, speed, or responsiveness.
	Safety & reliability metrics	Availability/reward	Benchmark availability, rewards, bounty, or payoff.
		Qualitative/user assess.	Human-rated usefulness, clarity, satisfaction, or value.
		Scope containment	Authorized-scope and sandbox adherence.
		Prompt injection robustness	Resistance to malicious, conflicting, or tool-mediated prompts.
		Consistency	Stability across runs, prompts, tasks, or environments.
	Agentic process / trajectory metrics	ASR	Attack success rate or adversarial outcome success.
		Defense success	Prevention, detection, or mitigation success.
		Utility-security tradeoff	Balance between utility and security constraints.
		Overhead	Added cost, latency, compute, or operational burden.
		Steps to completion	Reasoning, action, or workflow steps to finish.
		Tool call accuracy	Correct tool selection, parameters, and interpretation.
		Hallucination rate	Unsupported, fabricated, or misleading claims/actions.
		Cost / token efficiency	Token, API, compute, or per-task efficiency.
		Iteration count	Retries, planning loops, repair cycles, or attempts.
		Artifact correctness	Correctness of files, patches, reports, exploits, deliverables.
Comparative & baseline metrics		Report / explanation	Quality, faithfulness, and usefulness of reports.
		Economic / bounty value	Monetary value, bounty size, or economic significance.
		vs. non-AI tools	Comparison with traditional tools or non-AI automation.
		vs. prior ML / DL	Comparison with earlier ML or DL approaches.
		vs. plain LLMs	Comparison with a non-agent LLM under a comparable task setup.
		vs. humans	Comparison with analysts, developers, experts, or students.
		vs. agent systems	Comparison with other agents, frameworks, or baselines.
		Ablation studies	Component removal or variation to estimate contribution.

5.3 Resulting Taxonomy

Following the attribute/item identification and generalization steps, we derived our taxonomy (as outlined in Table 2), as elaborated below for each of the three high-level aspects separately.

5.3.1 Approach. In this aspect, we characterize how LLM-based agents for software and system security are technically constructed and operated. As summarized in Table 2, we identify seven attributes. The first three attributes, **agent architecture**, **agent perception**, and **agent memory**, describe the agent’s structural foundation. Agent architecture captures whether the system is single- or multi-agent, how its internal components are organized, and what role the backbone LLM plays. Agent perception captures the inputs and observation mechanisms through which the agent understands code, logs, binaries, traces, environments, or natural-language artifacts. Agent memory captures how security-relevant information is retained, retrieved, updated, and reused during or across tasks.

The remaining attributes describe how the agent acts over time. **Agent reasoning & planning** records the reasoning paradigms, planning strategies, and uncertainty-handling mechanisms used to derive and revise decisions. **Agent action space** specifies the tools and external operations available to the agent, including analysis tools, execution environments, retrieval systems, security platforms, inter-agent communication, and human interaction. **Agent workflow & orchestration** captures the process structure, such as sequential, iterative, parallel, hierarchical, or human-involved workflows. Finally, **agent self-improvement & learning** records whether the agent adapts from feedback, stores successful trajectories, or improves through reward-driven interaction. Together, these attributes treat an LLM security agent as an operational system rather than a single prompt-response model.

5.3.2 Application. In this aspect, we examine the concrete security tasks to which LLM-based agents are applied. The resulting taxonomy contains eleven application domains. Several domains follow the vulnerability lifecycle: **vulnerability detection & analysis** concerns discovering, localizing, classifying, triaging, or explaining weaknesses; **exploit development & analysis** concerns constructing, chaining, detecting, or analyzing exploits; **penetration testing & red-teaming** covers staged or end-to-end offensive assessment; and **vulnerability repair & hardening** addresses patching, validation, secure coding, code review, and defensive hardening.

Other domains capture specialized security-analysis tasks and operational defense. **Fuzzing & test generation**, **malware analysis & detection**, and **reverse engineering** cover testing, malicious-code analysis, and low-level software or protocol understanding. **Intrusion & threat detection**, **incident response**, **access control & authentication assessment**, and **threat intelligence & security operations (SecOps)** capture defensive monitoring, alert triage, access-policy assessment, threat-intelligence synthesis, and analyst-support workflows. Finally, **model attack generation & robustness assessment** accounts for work where the LLM, ML component, or agentic workflow itself becomes the target of security assessment. These domains are organized by task objective, so they remain applicable even when different papers use different architectures, datasets, or tools.

5.3.3 Assessment. In this aspect, we examine how surveyed works assess LLM-based security agents. Since these agents often act through multi-step trajectories, assessment cannot be limited to final-answer correctness. We therefore organize assessment around both datasets and metrics. For datasets, **dataset origin** distinguishes real-world subjects from synthetic or controlled environments, while **dataset characterisation axes** record properties such as realism, label quality, scale, artifact modality, vulnerability coverage, and accessibility. **Dataset by security task** further indicates which application area the dataset supports, such as vulnerability detection, penetration testing, repair, cyber-defense simulation, malware analysis, or SOC/SOAR workflows.

Table 3. Distribution of Publication Venues of Surveyed Papers

Type	Acronym	Description	# Papers
Conference	TrustCom	IEEE International Conference on Trust, Security and Privacy in Computing and Communications	5
	USENIX Security	USENIX Security Symposium	4
	ICSE	IEEE/ACM International Conference on Software Engineering	3
	ICAIC	IEEE International Conference on AI in Cybersecurity	3
	BigData	IEEE International Conference on Big Data	3
	MILCOM	IEEE Military Communications Conference	3
	NeurIPS	Conference on Neural Information Processing Systems	3
	ICML	International Conference on Machine Learning	3
	PST	Annual International Conference on Privacy, Security, and Trust	2
	ICLR	International Conference on Learning Representations	2
	ICMCIS	International Conference on Military Communication and Information Systems	2
	AsiaCCS	ACM Asia Conference on Computer and Communications Security	2
	ICAART	International Conference on Agents and Artificial Intelligence	2
Journal	IEEE Access	IEEE Access	3
	IEEE Commun. Mag.	IEEE Communications Magazine	2
Various other venues			58
All venues			100

For metrics, we distinguish outcome-oriented, safety-oriented, process-oriented, and comparative measurements.

Task effectiveness metrics capture whether the agent achieves the intended security outcome, such as successful detection, exploitation, patching, coverage, or report generation. **Safety & reliability metrics** capture whether the agent remains robust, bounded, and consistent under adversarial or high-impact conditions. **Agentic process / trajectory metrics** assess how the agent reaches its result, including tool calls, hallucinations, cost, iterations, artifacts, and explanations. Finally, **comparative & baseline metrics** record whether results are compared against non-AI tools, prior ML/DL methods, plain LLMs without agentic scaffolding, humans, other agent systems, or ablated variants.

6 Paper Attribution

The next phase of our survey process is to apply the attribution framework derived and survey aspects/attributes (in §5) to the relevant literature identified (in §4). In this section, we focus on summarizing the surveyed papers as per (i.e., mapping them to) our taxonomy of LLM-based agents for software and systems security. We start with statistics on the collected papers based on their venues (§6.1), followed by the summary of the research body in each of the three aspects, Approach (§6.2), Application (§6.3), and Assessment (§6.4), to answer the three RQs that guide our survey.

Note that our attribution records only what a paper explicitly describes. A paper is left unmarked under an attribute when the corresponding capability is optional in, and absent from, its agent design.

6.1 Paper Distribution by Venues

The 100 papers in our dataset were published between 2023 and March 2026 across 73 distinct publication venues. For this analysis, annual editions and minor naming variants of the same venue were consolidated under a single venue name. Table 3 lists the 15 venues represented by at least two papers: 13 conferences and two journals. Together, these venues represented by at least two papers account for 42 papers, whereas the remaining 58 venues each contribute one paper and are therefore summarized rather than listed individually.

The distribution reflects the interdisciplinary impact of LLM-based agents for software and systems security. Security- and privacy-focused conferences are the largest category among the recurring venues. TrustCom contributes 5 papers, the largest number from any single venue, followed by USENIX Security with 4. ICAIC contributes 3 papers, while PST and AsiaCCS contribute 2 papers each. Collectively, these 5 security venues account for 16% of the surveyed papers.

General AI and machine-learning venues are also well represented, contributing 10 papers across four recurring venues. NeurIPS and ICML each contribute 3 papers, while ICLR and ICAART each contribute 2, for a combined total of 10 papers. Software engineering and data-oriented research are represented by ICSE and IEEE BigData, with 3 papers each. MILCOM, ICMCIS, and IEEE Communications Magazine together contribute 7 papers.

6.2 Survey Result: Approach

Next, we present the results of our survey, with one subsection devoted to each of the three highest-level survey aspects: approach (§6.2), application (§6.3), and assessment (§6.4). Under each subsection (e.g., §6.2: **Survey Result: Approach**), we discuss the surveyed works along the respective taxonomies (e.g., the taxonomies of agentic approaches as shown in Table 4 and Table 5), using each sub-subsection (e.g., §6.2.1: *Agent architecture*), heading (e.g., **Agent multiplicity**), underline (e.g., Single-agent), italics (e.g., *Collaborative*) as structural anchors for the different (from high to low) levels of the respective categorization (taxonomy). Due to space constraints, the lowest-level categories are not always listed in respective taxonomy tables.

6.2.1 Agent architecture. Agents designed for software/system security have adopted various architectural designs in terms of agent multiplicity (i.e., single- or multi-agent), internal structure, and the role of the backbone LLM, as summarized in Table 4.

Agent multiplicity. Agent multiplicity describes whether a system employs a single autonomous agent or coordinates multiple interacting agents. In this dimension, architectures are classified as either single-agent or multi-agent.

Single-agent designs remain the most common architectural choice (e.g., [2, 10, 18, 20, 26, 30, 32, 35, 37, 41, 45, 54, 57, 80, 91, 102, 104, 113, 117, 119, 120]). In these systems, one agent typically handles the end-to-end loop of interpreting the task, invoking tools, and producing the final security outcome. For example, REPOAUDIT uses one autonomous repository-auditing agent that incrementally explores relevant functions, stores intermediate findings in memory, and validates candidate bug reports without delegating the task to peer agents [31]. Similarly, VVF-AI adopts a single-agent workflow in which an LLM-based agent generates and executes vulnerability-verification logic to filter false positives from detection results [48]. PentestGPT [22] adopts a stratified variant in which a Reasoning Module maintains a high-level Pentesting Task Tree while a Generation Module translates strategic goals into concrete commands, addressing context-loss by preventing the planner from being overwhelmed by execution detail.

Multi-agent design is also a major architectural pattern across the surveyed papers [1, 4, 5, 9, 12, 14, 23, 28, 34, 38, 42, 44, 46, 47, 53, 55, 58–64, 68, 70, 71, 76, 77, 79, 81, 83–85, 88, 89, 94, 95, 97, 99, 101, 106, 110, 111, 118], reflecting the increasing adoption of collaborative agent designs for complex security tasks.

In particular, the surveyed studies of multi-agent architecture fall into three types of structures:

Collaborative. A frequently used coordination strategy is task-specialised collaboration, where agents each own a distinct sub-task and their outputs are integrated to drive the overall workflow. For example, PentestAgent [85] deploys separate agents for intelligence gathering, vulnerability analysis, and exploitation, each equipped with a customised toolset tied together through a RAG-augmented knowledge pipeline. Similarly, AutoRestTest [44] assigns four agents — API, dependency, parameter, and value — to optimise orthogonal dimensions of REST API testing via multi-agent reinforcement learning, achieving coverage gains of 12–27% over single-agent baselines.

Hierarchical. Several studies structure collaboration vertically, with a high-level planning agent delegating to specialised sub-agents [5, 23, 28, 53, 55, 58, 63, 64, 68, 83, 94, 99, 101, 110, 118]. HPTSA [118] is a representative example: a planning agent analyses the target and autonomously launches specialised subagents for zero-day exploitation subtasks.

Peer-to-peer. Some studies adopt a flat topology in which agents of equal standing exchange information and resolve disagreements through debate or voting [53, 59, 77, 99].

Internal structure. The internal structure of an LLM-based security agent describes how the system decomposes the agent into functional components, and how it combines LLM reasoning with other computational mechanisms.

Table 4. Paper attribution for Approach: Agent architecture

Year	Paper	Agent multiplicity			Mixture-of-agents (MoA) (4%)	Fine-tuned LLM (7%)	Internal structure			Unspecified (3%)	Actor only (8%)	Backbone LLM role		
		Single-agent (54%)	Multi-agent systems (46%)	Modular pipeline (91%)			Hybrid ML+LLM (20%)	Guardrail/policy enforcement layer (13%)	Neuro-symbolic hybrid (18%)			Planner+actor (88%)	Critic/verifier/judge (15%)	All-in-one (4%)
2026	68		✓	✓	✓			✓	✓			✓		
	59		✓	✓								✓		
	60		✓	✓								✓		✓
	75	✓		✓		✓	✓		✓					
	47			✓		✓								✓
	112	✓		✓			✓							
	72		✓	✓										
	121			✓										
	119	✓		✓		✓								
	30	✓		✓										
	32	✓		✓										
	94	✓	✓	✓					✓					
	104	✓		✓										
	118	✓		✓										
	116	✓		✓			✓							
2025	11		✓	✓				✓	✓			✓		
	99	✓		✓				✓						
	69			✓										
	44		✓	✓			✓				✓			
	34		✓	✓			✓				✓			
	97		✓	✓								✓		
	46	✓		✓				✓			✓			✓
	113	✓		✓			✓				✓			
	42	✓		✓										
	58	✓		✓							✓			
	16	✓		✓							✓			
	92	✓		✓										
	71	✓		✓										
	53	✓		✓										✓
	56	✓		✓										
	63	✓		✓					✓				✓	
	29	✓		✓										
	98	✓		✓					✓				✓	
	108	✓		✓										
	19	✓		✓										
	13	✓		✓					✓				✓	
	8	✓		✓				✓					✓	
	5	✓		✓				✓					✓	
	84		✓	✓	✓								✓	
	77		✓	✓									✓	
	61		✓	✓		✓							✓	
	28		✓	✓									✓	
	101		✓	✓							✓			
	117	✓		✓			✓							
	91	✓		✓			✓							
	41	✓		✓			✓				✓			
	54	✓		✓	✓		✓							
	144	✓		✓				✓						
	2	✓		✓			✓							
	117	✓		✓			✓							
	45	✓		✓			✓							
	42	✓		✓			✓							
	79	✓		✓			✓							
	65	✓		✓										
	88	✓		✓				✓						
	26	✓		✓										
	89	✓		✓				✓	✓					
	80	✓		✓			✓							
	70	✓		✓			✓							
	64	✓		✓						✓	✓			
	55	✓		✓		✓		✓						
	4	✓		✓				✓						
	102	✓		✓					✓					
	81	✓		✓					✓					
	49	✓		✓					✓					
	40	✓		✓					✓					
	83	✓		✓					✓					
	62	✓		✓			✓							
	110	✓		✓								✓		
	109	✓		✓										
	85	✓		✓			✓							
	95	✓		✓	✓		✓							
	111	✓		✓					✓					
	51	✓		✓			✓							
	18	✓		✓			✓							
	10	✓		✓					✓				✓	
	51	✓		✓						✓				
	52	✓		✓										
	39	✓		✓		✓								
	24	✓		✓					✓					
	76	✓		✓					✓					
	48	✓		✓					✓					
2024	57	✓		✓			✓				✓			
	20	✓		✓										
	15	✓		✓			✓				✓			
	66	✓		✓										
	57	✓		✓		✓								
	53	✓		✓										
	120	✓		✓										
	111	✓		✓										
	106	✓		✓										
	74	✓		✓			✓							
2023	58	✓		✓										
	9	✓		✓										
	22	✓		✓										
	73	✓		✓										
	100	✓		✓			✓						✓	
	83	✓		✓										
	23	✓		✓				✓						
	36	✓		✓			✓							

Modular pipeline is the dominant internal organization across the architecture taxonomy. Within this broad category, *planner/executor modules* separate strategic decision-making from concrete action. For example, PENTESTAGENT uses a planning agent to consume reconnaissance results and generate exploitation plans, while other agents perform intelligence gathering, vulnerability analysis, and exploitation [85]. PTFusion follows a related pattern in web penetration testing: a MasterAgent maintains strategic planning, while ReconAgent and AttackAgent perform tactical tool-mediated execution through MCP-enabled tool interfaces [94].

Verifier/critic modules are another recurring modular pattern. They are introduced because security agents frequently generate uncertain intermediate claims: a suspected vulnerability, a candidate exploit, a patch, or a data-flow fact may look plausible but still be wrong. REPOAUDIT, for instance, consists of initiator, explorer, and validator components; the validator checks generated data-flow facts and path-condition satisfiability before accepting candidate bug reports [31]. PATCHAGENT similarly couples fault localization and patch generation with a verifier that tests candidate patches and feeds counterexamples back into the repair loop [109].

Summariser/reporter modules appear when the agent must transform low-level observations into analyst-facing outputs [29, 34, 53, 60, 70, 76, 79, 81, 84, 88, 111, 121]. For example, COGNITIVE SOC uses specialised Triage, Enrichment, and StoryWeaver agents: after triage classifies an alert and enrichment gathers contextual evidence, StoryWeaver turns the evidence into an incident narrative with citation chains [84].

Mixture-of-agents (MoA) structures combine multiple LLM agents or model instances as a deliberate ensemble rather than as a simple linear pipeline [14, 59, 77, 95]. In these systems, *model diversity and response aggregation* are part of the architecture. The Agentic Multi-LLM Network is a representative example: multiple LLM-equipped network nodes propose network-optimization strategies, and the framework uses collaboration plus a consensus-oriented trust layer to select reliable responses [59]. Perses also reflects this logic by assigning different small local models to distinct privilege-escalation roles, relying on heterogeneity rather than a single large model to carry the task [95].

Fine-tuned LLM component architectures include systems that adapt model behavior through domain-specific training data or specialised model components [3, 4, 47, 61, 72, 76, 119]. In this category, *task-specific model adaptation* supplements prompting and tool use. CYBER-ZERO, for example, synthesizes cybersecurity trajectories from public CTF writeups and persona-driven simulation, then uses those trajectories to train open-weight cybersecurity agents [119]. AVIATOR similarly targets vulnerability-injection workflows and dataset generation, using agentic processing to create high-fidelity security data for downstream training and assessment [47].

Hybrid ML + LLM architecture combines LLM reasoning with other machine-learning, reinforcement-learning, or learned prediction components [1, 17, 18, 34, 36, 38, 42, 44, 45, 54, 55, 57, 66, 70, 72, 75, 79, 91, 95, 110]. Here, *statistical learning and language reasoning* play complementary roles. AutoRestTest is illustrative: multi-agent reinforcement learning coordinates API, dependency, parameter, and value agents, while the LLM is used to generate domain-specific parameter values for REST API testing [44]. In autonomous cyber-defense work, hybrid architectures combine DRL policies, knowledge graphs, and LLM interfaces so that learned policies can act in cyber ranges while LLMs provide explanation, retrieval, or policy guidance [54, 55, 57].

Guardrail/policy enforcement layer architectures add explicit mechanisms that constrain, audit, or filter agent behavior [8, 12, 14, 23, 26, 59, 69, 79, 80, 84, 99, 102, 113]. In these papers, *trust and safety control* is part of the internal design rather than an external assessment concern. The Agentic Multi-LLM Network uses blockchain-based audit trails and Byzantine Fault Tolerance consensus to reject malicious or unreliable proposals from distributed LLM agents [59]. Agent Security Bench formalizes attacks and defenses against agent stages such as prompt handling, tool use, and memory retrieval, making guardrail design a central architectural dimension [113].

Neuro-symbolic hybrid architectures combine neural LLM components with symbolic analysis, formal reasoning, static analysis, or verification tools [13, 23, 31, 36, 47–49, 51, 63, 68, 76, 83, 89, 94, 98, 99, 102, 109]. The typical grouping is *LLM generation plus symbolic checking*. PROPERTYGPT is a clear example: the LLM generates smart-contract properties, while compilation, static analysis, and formal verification components check whether the generated properties are usable and meaningful [51]. REPOAUDIT also fits this category because its LLM-guided repository exploration is constrained by data-flow facts and satisfiability checks [31].

Unspecified internal structure is used only when a paper establishes that an agent is present but does not describe its internal organization precisely enough to distinguish a modular, ensemble, guardrailed, fine-tuned, or hybrid design [15, 35, 52]. “Unspecified” records insufficient evidence, not meaning that the system has no internal structure.

Backbone LLM role. The backbone LLM role captures what functional responsibility the LLM has inside the agent. Some systems use the LLM as a generator inside a larger architecture; others place it at the center of planning and tool use; still others use LLMs as judges, verifiers, or all-purpose agent backbones.

Actor only roles use the LLM mainly to produce a bounded artifact or local action, while another mechanism handles the broader workflow [3, 34, 35, 37, 41, 42, 44, 92]. The common grouping is *LLM as generator*. AutoRestTest is a representative case: the multi-agent RL system and semantic dependency graph coordinate REST API testing, while the LLM is used primarily by the value agent to generate realistic parameter values satisfying API constraints [44]. Similarly, IDS-rule generation uses the LLM to produce and generalize detection rules from vulnerability reports, payloads, and existing rules, but the surrounding IDS assessment and rule-deployment logic remain outside the LLM itself [37]. In this role, the LLM improves expressiveness and domain adaptation without becoming the main planner.

Planner + actor is the most expansive role: the LLM plans steps, selects tools, issues commands, interprets observations, and revises subsequent actions. In this grouping, *LLM as autonomous operator* is the central design idea. REPAIRAGENT, for example, treats the LLM as an autonomous repair agent that plans tool use, retrieves repair ingredients, generates patches, and validates candidate repairs [10]. PTFusion similarly uses LLM agents to plan and execute web-penetration-testing tasks while maintaining a dynamic knowledge graph over the target environment [94].

Critic / verifier / judge roles use the LLM, or an LLM-supported module, to assess another component’s output rather than to produce the primary action [13, 23, 29, 31, 36, 46, 48, 60, 61, 76, 77, 97, 99, 100, 109]. The narrative grouping here is *LLM as quality-control layer*. In REPOAUDIT, the validator critiques the explorer’s generated data-flow facts and checks path-condition satisfiability for bug candidates, reducing false-positive reports [31]. In smart-contract and patching systems, critic or verifier roles similarly help decide whether a vulnerability claim, generated mitigation, or patch should be trusted [48, 61, 76, 77, 97, 109].

All-in-one backbones absorb most roles into a single agent loop rather than clearly separating planner, executor, and verifier responsibilities [53, 75, 112, 113]. The grouping can be described as *LLM as unified task engine*. BountyBench exemplifies this style by assessing agents on real-world cybersecurity systems where the same agent loop must inspect code or services, reason about vulnerabilities, execute actions, and submit detection, exploitation, or patching outputs [112]. Agent Security Bench similarly treats the agent as a broad system whose prompt handling, tool use, and memory stages can all become attack surfaces [113].

6.2.2 Agent memory. Agents designed for software/system security also differ in how they store, retrieve, and revise information, in terms of memory types, memory operations, and security-specific memory, as summarized in Table 5.

Memory types. In-context working memory refers to task state carried inside the agent’s prompt or context window, including recent observations, intermediate decisions, tool outputs, and partially constructed findings [2–4, 8–10, 12–14, 17–20, 22, 23, 26, 28, 29, 31, 32, 34, 36, 38, 40–42, 44, 48, 49, 51, 54, 57, 59, 61–63, 65, 66, 69–73, 75–77, 80, 84, 92, 94, 98–100, 104, 108, 109, 113, 116, 119, 121]. *Task-progress memory* appears when the agent must remember what has already been tried. Ginige et al.’s AUTOPESTER [29], for instance, feeds previous testing results back into later decision steps so that the agent can continue a multi-step penetration-testing process rather than repeatedly restart from the target description. *Evidence-carrying context* is similarly important in auditing and vulnerability detection. Guo et al.’s REPOAUDIT [31] uses the current repository exploration path and accumulated data-flow evidence as local context while deciding which program locations deserve further inspection.

Table 5. Paper attribution for Approach: Agent memory

Year	Paper	Memory types					Memory operations			Security-specific memory				
		In-context working memory (60%)	External short-term memory (7%)	Long-term / persistent memory (57%)	Knowledge graph memory (10%)	Parametric memory (100%)	Read (61%)	Write (7%)	Update / reflection (42%)	Vulnerability knowledge bases (25%)	Code repositories and patch histories (23%)	Execution traces and fuzzing logs (33%)	Threat intelligence feeds (12%)	Tool documentation (49%)
2026	[68]	✓		✓	✓	✓	✓		✓	✓				✓
	[59]	✓		✓	✓	✓	✓		✓		✓	✓		✓
	[60]					✓	✓				✓			
	[75]					✓	✓							
	[47]	✓		✓		✓	✓		✓		✓	✓		✓
	[112]					✓	✓	✓						
	[72]					✓	✓							
	[121]	✓		✓		✓	✓				✓	✓		✓
	[119]	✓		✓		✓	✓				✓			
	[30]			✓		✓	✓				✓			
	[32]			✓		✓	✓							
	[94]	✓		✓	✓	✓	✓					✓		✓
	[104]	✓		✓		✓	✓				✓	✓		
	[118]	✓		✓		✓	✓				✓			
2025	[116]	✓		✓		✓	✓							
	[11]	✓		✓		✓	✓							✓
	[99]	✓		✓		✓	✓				✓	✓		✓
	[69]	✓		✓		✓	✓							✓
	[44]	✓			✓	✓	✓							✓
	[34]	✓				✓	✓							
	[97]		✓	✓		✓	✓		✓					
	[46]			✓		✓	✓			✓				
	[113]	✓	✓	✓		✓	✓				✓	✓		✓
	[42]	✓				✓	✓							
	[58]			✓	✓	✓	✓			✓			✓	✓
	[16]					✓	✓							✓
	[92]	✓				✓	✓						✓	✓
	[71]					✓	✓						✓	✓
	[53]					✓	✓						✓	✓
	[56]			✓	✓	✓	✓			✓				✓
	[63]			✓		✓	✓							✓
	[29]	✓		✓		✓	✓							✓
	[98]	✓		✓		✓	✓					✓		✓
	[106]	✓		✓		✓	✓				✓			✓
	[19]	✓				✓	✓							✓
	[13]	✓	✓			✓	✓							✓
	[8]	✓		✓		✓	✓							✓
	[5]	✓		✓		✓	✓							✓
	[84]	✓		✓		✓	✓	✓		✓			✓	✓
	[77]	✓		✓		✓	✓			✓				✓
	[61]	✓				✓	✓			✓				✓
	[28]	✓				✓	✓							✓
	[101]	✓		✓		✓	✓					✓		✓
	[117]	✓		✓		✓	✓				✓			✓
	[91]	✓		✓	✓	✓	✓				✓			✓
	[41]	✓				✓	✓							✓
	[54]	✓		✓		✓	✓	✓					✓	✓
	[14]	✓		✓		✓	✓				✓			✓
	[2]	✓				✓	✓				✓			✓
	[17]	✓				✓	✓							✓
	[45]	✓				✓	✓							✓
	[12]	✓		✓		✓	✓				✓			✓
	[79]	✓				✓	✓			✓		✓		✓
	[65]	✓				✓	✓							✓
	[88]	✓				✓	✓							✓
	[26]	✓				✓	✓							✓
	[89]	✓		✓		✓	✓							✓
	[80]	✓				✓	✓							✓
	[70]	✓				✓	✓							✓
	[64]	✓				✓	✓							✓
	[25]	✓	✓	✓		✓	✓							✓
	[4]	✓				✓	✓							✓
	[102]	✓				✓	✓						✓	✓
	[81]	✓				✓	✓							✓
	[49]	✓				✓	✓	✓		✓				✓
	[40]	✓				✓	✓							✓
	[83]	✓		✓		✓	✓			✓				✓
	[62]	✓		✓		✓	✓							✓
	[110]	✓				✓	✓							✓
	[109]	✓				✓	✓					✓		✓
	[85]	✓		✓	✓	✓	✓							✓
	[95]	✓		✓		✓	✓							✓
	[11]	✓		✓		✓	✓			✓				✓
	[51]	✓		✓		✓	✓			✓				✓
	[18]	✓	✓			✓	✓							✓
	[10]	✓		✓		✓	✓							✓
	[31]	✓		✓		✓	✓							✓
	[52]	✓		✓		✓	✓							✓
	[39]	✓		✓		✓	✓							✓
	[24]	✓				✓	✓							✓
	[76]	✓				✓	✓							✓
	[48]	✓				✓	✓						✓	✓
2024	[37]	✓		✓		✓	✓			✓				✓
	[20]	✓				✓	✓				✓			✓
	[15]	✓				✓	✓							✓
	[66]	✓				✓	✓							✓
	[57]	✓			✓	✓	✓						✓	✓
	[3]	✓				✓	✓							✓
	[120]	✓				✓	✓			✓				✓
	[111]	✓		✓		✓	✓				✓			✓
	[106]	✓				✓	✓							✓
	[74]	✓				✓	✓							✓
	[38]	✓				✓	✓	✓					✓	✓
	[9]	✓		✓		✓	✓							✓
	[22]	✓				✓	✓			✓		✓		✓
	[73]	✓	✓			✓	✓							✓
2023	[100]	✓				✓	✓					✓		✓
	[55]	✓				✓	✓							✓
	[23]	✓				✓	✓							✓
	[36]	✓		✓		✓	✓			✓				✓

External short-term memory stores temporary task state outside the immediate LLM context [13, 18, 35, 73, 97, 100, 113]. This pattern is useful when the agent must traverse a large state space, such as a binary, web target, or multi-step attack path, while keeping the prompt compact. Chen et al.’s CLEARAGENT [13] illustrates this design in binary vulnerability detection: the agent records an exploration trace over call-graph functions and control-flow basic blocks, then consults that trace when deciding where to inspect next and whether a candidate bug should be validated.

Long-term / persistent memory covers reusable information stored across sessions or beyond the current context window, including vector databases, knowledge bases, validated facts, past reports, examples, or learned task trajectories

Manuscript submitted to ACM

[3, 5, 9, 11, 12, 14–16, 18, 19, 22, 29–32, 35–37, 39–41, 46, 47, 49, 51, 52, 54, 56, 57, 59, 62, 63, 68, 69, 72, 75, 80, 83–85, 89, 91, 94, 95, 97, 99, 101, 104, 108, 109, 111, 113, 116–119, 121]. *Reusable domain exemplars* appear when the agent retrieves prior security artifacts to guide a new case. Liu et al.’s PROPERTYGPT [51] stores human-written smart-contract properties in a vector database; for a new contract, it retrieves a similar property as an in-context reference and then iteratively revises generated properties with compiler, static-analysis, and prover feedback. *Persistent task experience* appears in reflective penetration-testing systems such as Dai et al.’s REFPESTER [18], where experience from failed actions and stage transitions is retained to reduce repeated mistakes in later testing steps.

Knowledge graph memory represents security-relevant entities and relations explicitly, such as hosts, services, vulnerabilities, attack techniques, dependencies, or environment states [44, 54, 56–58, 63, 68, 85, 91, 94]. Compared with unstructured retrieval, this memory type gives agents a structured view of what is known and how facts are connected. Wang et al.’s PTFUSION [94] uses a dynamic knowledge graph to fuse web-penetration-testing context, executed actions, and discovered target facts, enabling the planner to choose later commands with awareness of the current attack surface. Loevenich et al. [54] similarly construct cybersecurity knowledge graphs from network logs, CTI reports, and vulnerability frameworks, then use these structures to support autonomous cyber defense and analyst-facing retrieval.

Parametric memory denotes the knowledge implicitly stored in the backbone LLM’s trained parameters. It appears throughout the surveyed agent systems. For example, in Kim et al.’s AUTORESTEST [44], the value agent uses the LLM’s learned knowledge of API naming conventions, parameter formats, and common web-service semantics to generate realistic REST input values from specifications and constraints.

Memory operations. Read operations retrieve stored information and inject it into the next reasoning or action step [15, 16, 29, 37, 47, 51, 56, 62, 63, 68, 75, 91, 101, 104]. For example, Liu et al.’s PROPERTYGPT [51] reads from a vector database of human-written properties to obtain a close reference before generating a new smart-contract property. Ginige et al.’s AUTOPENTESTER [29] reads retrieved penetration-testing knowledge and prior findings to produce more targeted commands for the next stage.

Write operations store newly produced artifacts, including generated reports, candidate patches, incident narratives, formal properties, or intermediate analysis results [38, 49, 51, 54, 84, 109, 112]. The important distinction is that the agent does not merely consume memory; it also turns its observations into reusable records. Sheikhi et al.’s COGNITIVE SOC [84], for example, converts alert evidence and enrichment results into an evidence-backed incident narrative for analyst review. In PROPERTYGPT, Liu et al. [51] also write generated properties and retain selected top-ranked candidates for later verification.

Update / reflection operations revise memory content, future plans, or action preferences based on execution feedback, failed attempts, self-critique, or validation results [5, 9, 10, 12–14, 18, 23, 26, 32, 39, 40, 46, 48, 51, 52, 54, 55, 59, 62, 64, 66, 68–71, 75, 79, 80, 83, 85, 89, 91, 94, 97, 99, 101, 104, 109–111, 116]. *Exploration reflection* appears in systems that must decide where to search next, such as Chen et al.’s CLEARAGENT [13], which reflects on visited binary locations and candidate bug evidence before continuing the analysis. *Failure-driven reflection* appears in Dai et al.’s REFPESTER [18], where unsuccessful penetration-testing actions and their rewards are used to adjust later behavior.

Security-specific memory. Vulnerability knowledge bases store or retrieve information about known vulnerabilities, CVEs, CWEs, attack patterns, exploit preconditions, security properties, and bug classes [3, 16, 19, 22, 29, 36, 37, 41, 47–49, 51, 54, 56, 61, 62, 68, 84, 97, 98, 101, 108, 109, 111, 117]. PROPERTYGPT [51], for example, uses vulnerability-related smart-contract properties as reusable references for formal verification, while AUTOPENTESTER [29] uses penetration-testing knowledge to guide scanning, assessment, and exploitation.

Code repositories and patch histories capture source files, vulnerable and fixed versions, commits, code slices, repository-level facts, and previous repair decisions [2, 10, 20, 22, 31, 32, 36, 41, 47, 49, 51, 60, 69, 79, 108, 111–113, 117–121]. Guo et al.’s REPOAUDIT [31] uses repository-level code facts and data-flow evidence to audit large code bases, whereas Bouzenia et al.’s REPAIRAGENT [10] searches the codebase for repair ingredients and uses validation feedback to refine candidate patches.

Execution traces and fuzzing logs include runtime outputs, command logs, failed exploit attempts, test results, path conditions, coverage observations, and fuzzer-produced evidence [8–11, 13, 14, 18, 19, 22, 26, 28, 31, 40, 49, 51, 58, 60, 64, 69, 70, 75, 79, 83, 88, 94, 98, 100, 101, 109, 112, 113, 118, 121]. In penetration testing, Dai et al.’s REFTESTER [18] uses execution results and failure feedback as evidence for reflection. In binary analysis, Chen et al.’s CLEARAGENT [13] uses exploration traces and concrete-input validation to check whether a suspected vulnerability is actually triggerable.

Threat intelligence feeds refer to CTI reports, indicators of compromise, MITRE ATT&CK-style tactics and techniques, security-operation evidence, and other external intelligence used to contextualize alerts or defensive actions [4, 5, 38, 48, 54, 56–58, 71, 81, 84, 102]. Sheikhi et al.’s COGNITIVE SOC [84] uses alert evidence and threat context to produce evidence-backed narratives for security analysts. Loevenich et al. [54] build cyber-defense knowledge graphs from network logs, open-source CTI reports, and vulnerability frameworks, allowing the agent to connect defensive observations with known adversary tactics.

Tool documentation covers command syntax, API specifications, tool manuals, usage constraints, expected outputs, and environment-specific operating instructions [2, 4, 5, 8–11, 13, 14, 16, 18, 20, 22–24, 29, 36, 38, 40, 44, 47, 48, 51, 52, 54, 56, 58, 59, 62, 63, 68, 69, 76, 84, 85, 88, 89, 92, 94, 95, 98–101, 109–111, 117, 121]. Kim et al.’s AUTORESTEST [44] uses API specifications and parameter constraints to generate valid REST inputs, while AUTOPENTESTER [29] uses penetration-testing knowledge to turn high-level goals into commands that can be executed against the target environment.

6.2.3 Agent perception. Agent perception concerns the observations that enter the agent loop and the mechanisms used to turn raw security artifacts into reasoning-ready context. Table 6 summarizes both the input sources perceived by security agents and the mechanisms they use to transform those observations into reasoning-ready context.

Input sources. Source code is the dominant code-centric input source for security tasks such as vulnerability detection, repository auditing, program repair, vulnerability injection, and smart-contract verification [2, 4, 10, 11, 23, 31, 32, 36, 40–42, 46–49, 51, 60–62, 69, 76, 77, 83, 89, 97, 101, 108, 109, 111, 112, 117, 120, 121]. Guo et al.’s REPOAUDIT [31] is an example: the agent perceives source files together with data-flow evidence so that later reasoning is grounded in concrete paths through the code. Liu et al.’s PROPERTYGPT [51] uses a different code-facing view. It reads smart-contract code as the object for which formal properties must be generated and verified.

Compiled binaries, disassembly, and decompiled output are used when source code is unavailable or when the security task is inherently binary-facing [4, 13, 42, 46, 121]. Here, perception must bridge the semantic gap between low-level representations and vulnerability concepts. Chen et al.’s CLEARAGENT [13] shows this contrast clearly: rather than asking the LLM to reason from source, the framework exposes binary representations through an analysis interface and lets the agent iteratively inspect functions, control-flow blocks, and candidate vulnerability locations.

Execution traces and system logs move perception from static artifacts to runtime evidence. Execution traces capture observed behavior, command results, paths, tests, or failed attempts, whereas system logs provide operational evidence from hosts, networks, services, or SOC pipelines. In penetration testing, Ginige et al.’s AUTOPENTESTER [29] observes tool outputs after each action and uses them as the basis for the next command. In SOC-style analysis, Sheikhi et al.’s

Table 6. Paper attribution for Approach: Agent perception

Year	Paper	Source code (33%)	Compiled binaries disassembly decompiled output (5%)	Execution traces (25%)	Input sources					Images / screenshots (3%)	Protocol specifications /standards (3%)	Perception mechanisms				
					System logs (55%)	Natural language (42%)	Structured data (60%)	Environment observations (66%)	Direct LLM ingestion (100%)			Retrieval-augmented perception (30%)	Summarisation / compression (35%)	Embedding /semantic similarity (10%)	Tool-mediated observation (68%)	
2026	[68]															
	[59]	✓		✓	✓	✓	✓	✓			✓	✓		✓	✓	
	[60]															
	[75]															
	[47]	✓		✓	✓	✓	✓	✓			✓	✓	✓	✓	✓	
	[112]					✓	✓	✓			✓			✓	✓	
	[72]			✓												
	[121]	✓	✓						✓						✓	
	[119]					✓	✓	✓								
	[30]				✓											
	[32]	✓									✓	✓				
	[94]								✓							
	[104]															
	[118]					✓						✓	✓			
	[116]															
	[11]					✓										
	[99]				✓						✓					
[69]	✓												✓	✓		
2025	[44]				✓		✓	✓	✓					✓	✓	
	[34]						✓	✓	✓						✓	
	[97]	✓					✓	✓	✓					✓	✓	
	[46]		✓				✓	✓	✓					✓	✓	
	[113]	✓	✓	✓		✓		✓	✓				✓		✓	
	[42]															
	[58]												✓		✓	
	[16]														✓	
	[92]									✓						
	[71]				✓											
	[53]			✓												
	[36]															
	[63]															
	[29]														✓	
	[98]														✓	
	[108]	✓														
	[19]				✓											
	[13]			✓												
	[81]				✓											
	[5]				✓											
	[84]															
	[77]	✓												✓	✓	
	[61]	✓													✓	
	[28]															
	[101]	✓														
	[117]	✓														
	[91]															
	[41]	✓														
	[54]	✓														
	[14]				✓									✓		
	[2]	✓														✓
	[17]															
	[45]															
	[12]															
	[79]															
	[65]															
	[85]															
	[26]															✓
	[89]	✓														✓
	[80]													✓		✓
	[70]				✓											
	[64]															
	[35]													✓		
	[4]	✓		✓												
	[102]				✓											
	[81]															✓
	[49]	✓														
	[40]	✓														
	[63]	✓														
	[62]	✓														
[110]				✓										✓		
[109]	✓									✓						
[85]															✓	
[95]															✓	
[11]	✓															
[51]	✓															
[18]	✓															
[100]	✓															
[31]				✓												
[52]																
[39]													✓			
[24]																
[76]	✓															
[48]															✓	
2024	[37]					✓	✓	✓						✓		
	[20]					✓	✓	✓								
	[15]					✓	✓	✓						✓		
	[66]					✓	✓	✓								
	[57]					✓	✓	✓							✓	
	[3]					✓	✓	✓								
	[120]	✓								✓						
	[111]															
	[106]															
	[74]			✓		✓	✓	✓								
	[38]					✓	✓	✓								
	[9]															
2023	[22]															
	[73]															
	[100]															
	[53]															
	[23]	✓														
	[36]	✓														

COGNITIVE SOC [84] perceives alert and enrichment evidence so that the final narrative can cite concrete operational signals rather than free-form speculation.

Natural language inputs include user goals, challenge descriptions, security policies, vulnerability reports, incident narratives, threat descriptions, and human-authored task instructions. Structured data covers API specifications, JSON-like tool output, CVE metadata, graph data, formal properties, tables, and benchmark records. These two sources often

appear together: the natural-language part gives the task intent, while the structured part gives machine-checkable constraints. Kim et al.’s `AUTORESTEST` [44] illustrates the structured side especially well, since the agent consumes REST API specifications, parameter types, and constraints before generating test inputs.

Environment observations appear when the agent is embedded in an interactive security environment rather than a one-shot analysis setting. In such systems, the agent sees a changing world: open ports, service banners, exploit feedback, browser states, or cyber-range state. Wang et al.’s `PTFUSION` [94] uses this kind of evolving context in web penetration testing, combining executed actions and discovered target facts before planning later steps.

Images / screenshots and protocol specifications / standards are more specialized perceptual sources. Images and screenshots appear in multimodal security settings, including phishing or interface-oriented analysis [11, 120, 121]. Protocol specifications and standards support agents that reason about protocol fields, message formats, or standards-derived constraints [62, 92, 99]. These categories show that perception is not limited to text and code; security agents may need to read visual evidence or normative protocol knowledge before they can act correctly.

Perception mechanisms. Direct LLM ingestion places perceived artifacts directly into the prompt or conversation state for interpretation. For example, [31] provides selected code facts and path evidence so that the LLM reasons over a narrower audit context.

Retrieval-augmented perception first searches an external corpus, knowledge base, vector store, or graph before the LLM interprets the current case [11, 15, 16, 18, 19, 29, 30, 35, 37, 40, 41, 46, 47, 51, 54, 56, 57, 62, 63, 68, 75, 83–85, 89, 101, 104, 108, 111, 113]. For example, Liu et al.’s `PROPERTYGPT` [51] retrieves similar human-written smart-contract properties before generating a new one. Shen et al.’s `PENTESTAGENT` [85] uses retrieval to compensate for limited penetration-testing knowledge, bringing relevant domain knowledge into the multi-agent testing workflow.

Summarisation / compression is used when the observation is too large, verbose, or noisy to pass forward unchanged [2, 8, 12, 13, 17–19, 22, 30, 38, 51, 52, 60, 64, 69–71, 74, 79, 81, 83–85, 89, 94, 95, 100, 101, 104, 109–111, 113, 120, 121]. For example, in `COGNITIVE SOC`, Sheikhi et al. [84] use this kind of evidence distillation to transform alert details and enrichment artifacts into an analyst-facing narrative with clearer attribution.

Embedding / semantic similarity perception maps artifacts into a semantic space so that the agent can match related code, properties, vulnerabilities, API elements, or threat descriptions [15, 37, 42, 44, 47, 54, 62, 69, 77, 99]. In `AUTORESTEST`, Kim et al. [44] use semantic information from API specifications and dependency graphs to guide test generation. In the autonomous cyber-defense setting, Loevenich et al. [54] use learned representations to connect CTI, CVEs, and ATT&CK-style tactics inside knowledge-graph-supported perception.

Tool-mediated observation makes perception active. The agent does not only read a provided artifact; it invokes scanners, debuggers, fuzzers, browsers, code-search tools, cyber-range interfaces, or verification tools, and then observes their outputs. For example, `CLEARAGENT` [13] obtains new binary-analysis context by interacting with analysis tools, while Bouzenia et al.’s `REPAIRAGENT` [10] observes code-search and validation feedback during autonomous repair. In both cases, perception and action form a loop: what the agent sees next is partly determined by what it decided to inspect or execute now.

6.2.4 Agent reasoning & planning. This attribute is how an agent turns perceived security evidence into ordered decisions. Among the surveyed papers, agents have adopted various types of reasoning and planning design, in terms of their reasoning paradigm, in how they plan across multi-step tasks, and in how they handle uncertainty when evidence is incomplete or actions may fail, as shown in Table 7.

Table 7. Paper attribution for Approach: Agent reasoning & planning

Year	Paper	Reasoning paradigms								Planning strategies				Decision-making under uncertainty						
		ReAct (15%)	CoT (15%)	Reflection /self-critique (10%)	Reflexion (2%)	Prompt chaining (2%)	Few-shot prompting (10%)	Self-debug /self-repair (15%)	Least-to-most task decomposition (46%)	Hypothesis-driven reasoning (29%)	Graph-based reasoning / attack graph construction (2%)	Unspecified (18%)	Dynamic / reactive planning (80%)	Hierarchical task decomposition (22%)	Backtracking on failure (4%)	Unspecified (16%)	Confidence-based branching (23%)	Majority voting (7%)	Human-in-the-loop checkpoints (4%)	
2026	[68]									✓		✓						✓		
	[59]											✓								
	[60]											✓								
	[75]												✓							
	[47]			✓			✓			✓										
	[112]	✓																		
	[72]																✓			
	[121]																		✓	
	[119]														✓					
	[30]																		✓	
	[32]			✓																
	[94]																			
	[104]	✓																		
	[118]														✓					
	[116]											✓								
2025	[1]															✓				
	[99]			✓					✓					✓				✓		
	[69]							✓												
	[44]						✓													
	[34]																			
	[97]			✓													✓			
	[46]																			
	[113]	✓															✓			
	[42]																			
	[58]	✓															✓			
	[16]																			
	[92]					✓											✓			
	[71]																			
	[53]																			
	[56]																			
	[63]																			
	[29]										✓				✓					
	[98]	✓													✓					
	[108]	✓						✓												
	[19]	✓																		
	[13]	✓																		
	[8]																			
	[5]											✓					✓			
	[84]																			
	[77]						✓											✓		✓
	[61]																	✓		
	[28]																			
	[101]																			
	[117]																			
	[91]												✓							
	[41]																✓			
	[54]	✓																		
	[14]														✓				✓	
[2]								✓												
[17]																				
[45]																				
[12]																				
[79]						✓									✓					
[65]																				
[88]																				
[26]	✓																			
[89]						✓													✓	
[80]																				
[70]															✓					
[64]																				
[35]																				
[4]																				
[102]																				
[81]																				
[49]																✓				
[40]																				
[83]																				
[62]																				
[110]	✓																			
[109]				✓											✓					
[85]																				
[95]																				
[11]																				
[51]																✓				
[18]																				
[10]																				
[31]																				
[52]																				
[39]																				
[24]																				
[76]																				
[48]																				
2024	[37]	✓	✓									✓	✓							
	[20]																			
	[15]											✓								
	[66]	✓																		
	[57]																			
	[3]																			
	[120]																			
	[111]																			
	[106]																		✓	
	[74]																			
	[38]																			
	[9]																			
	[22]																			
	[79]																			
	[100]	✓				✓														
[55]																				
[23]																				
2023	[36]		✓		✓		✓									✓	✓			

Reasoning paradigms. ReAct reasoning interleaves reasoning, tool action, and observation, making it a natural fit for interactive security tasks where each command changes what the agent knows next [16, 19, 20, 26, 54, 57, 62, 73, 88, 98, 100, 104, 108, 112, 113]. Rather than producing a single final answer from a static prompt, these agents repeatedly decide what to inspect, execute, or query. Wu et al.’s AutoPT [98], for example, frames web penetration testing as an iterative process in which the agent observes tool feedback and then chooses the next testing action. The same pattern

appears in benchmark-style agent settings such as BountyBench [112], where code inspection, command execution, and final vulnerability handling are all part of the action-observation loop.

Chain-of-Thought (CoT) makes intermediate reasoning explicit, usually by asking the LLM to decompose the problem, compare evidence, or justify a next step before acting [12, 13, 29, 32, 34, 36, 37, 41, 62, 63, 71, 92, 94, 99, 108]. This paradigm is especially visible when the agent must translate noisy observations into a plausible security interpretation. Ginige et al.’s AUTOPESTER [29] uses CoT-style reasoning in its strategy analysis stage to interpret previous penetration-testing results and choose subsequent attack strategies. Wang et al.’s PTFUSION [94] uses preference-based CoT prompting to align heterogeneous penetration-testing tool outputs with the current strategic plan.

Reflection / self-critique gives the agent an explicit opportunity to assess its own intermediate products, failed attempts, or candidate findings before continuing [13, 18, 23, 30, 32, 47, 66, 97, 99, 109]. The role of reflection varies by task. In Chen et al.’s CLEARAGENT [13], reflection is tied to exploration: the agent reconsiders visited binary locations and candidate bug evidence before deciding where to inspect next. In Dai et al.’s REFPESTER [18], reflection has a more operational role, turning failed penetration-testing attempts into guidance for later actions.

Reflexion is a narrower pattern in which feedback from previous attempts is converted into reusable verbal guidance for future trials [18, 23]. Its main value is continuity across attempts: the agent does not merely observe failure, but writes down a lesson that changes later behavior. This is closely aligned with self-reflective penetration testing, where the same class of mistake can otherwise recur across multiple stages.

Prompt chaining separates a complex task into a sequence of prompts, each responsible for a narrower subproblem [92, 100]. Few-shot prompting instead provides examples inside the prompt so that the model can imitate the desired analysis pattern or output form [26, 31, 36, 44, 47, 73, 77, 79, 108, 110]. These two techniques address different forms of task complexity: prompt chains control workflow order, while few-shot examples calibrate local reasoning behavior. Kim et al.’s AUTORESTEST [44], for instance, uses example-guided generation to help produce API inputs that respect parameter semantics and constraints.

Self-debug / self-repair appears when the agent generates an artifact, tests or checks it, and then revises the artifact based on feedback [2, 10, 31, 36, 40, 47, 48, 51, 69, 83, 85, 109, 112, 119, 121]. Bouzenia et al.’s REPAIRAGENT [10] illustrates the repair side: the agent searches for repair ingredients, proposes a fix, and uses validation feedback to revise its candidate patch. Liu et al.’s PROPERTYGPT [51] follows a similar loop for formal properties, using compiler, static-analysis, and prover feedback to revise generated specifications.

Least-to-most task decomposition breaks a large security objective into smaller subtasks or stages before solving them [5, 14, 16, 18, 22–24, 26, 28, 29, 32, 34, 38, 39, 44, 46, 47, 56, 58, 60, 62–64, 68–70, 72, 76, 79, 80, 83, 84, 88, 89, 91, 92, 95, 98–101, 104, 106, 119, 121]. For example, Deng et al.’s PENTESTGPT [22] captures this idea through a pentesting task tree that keeps high-level strategy separate from command-level execution.

Hypothesis-driven reasoning starts from possible vulnerabilities, attack paths, causes, or explanations and then seeks evidence to support or reject them [3–5, 11–13, 19, 22–24, 31, 32, 39, 48, 49, 51, 53, 54, 56, 57, 61, 70, 75, 76, 79, 99, 101, 110, 111]. In REPOAUDIT, Guo et al. [31] use repository exploration and validation to move from suspected data-flow facts toward actionable bug reports. In PROPERTYGPT, Liu et al. [51] use formal checking to determine whether generated properties are compilable, appropriate, and verifiable.

Graph-based reasoning / attack graph construction is important for tasks whose logic is relational, multi-hop, or path-dependent [56, 68]. Graph structures can represent preconditions, dependencies, attack steps, or environment states, giving the agent a more explicit reasoning substrate than a flat prompt.

Unspecified reasoning paradigm denotes papers that do not name or provide enough procedural evidence for a particular reasoning paradigm [1, 8, 9, 15, 17, 35, 45, 52, 55, 59, 65, 74, 81, 102, 116–118, 120]. We do not infer ReAct or chain-of-thought from generic iteration, tool use, or multi-step execution alone; accordingly, “Unspecified” means that the paradigm is under-reported, not that the agent performs no reasoning.

Planning strategies. Planning strategies capture how an agent plans. A paper can assign a named Planner agent without describing a specific planning strategy (e.g., a brief one-line mention of “planning” inside a larger pipeline), and a paper can plan dynamically without ever naming a distinct Planner role (e.g., a single ReAct-style loop that revises its next action after every observation). The two tags therefore overlap substantially but are not interchangeable, and their totals should not be read as describing the same set of papers. Dynamic / reactive planning is the dominant planning style: agents revise their next steps according to new observations, failed attempts, tool output, or environment changes [2, 4, 5, 9, 10, 12–14, 16–20, 22–24, 26, 29–32, 35, 38–40, 44–49, 51–60, 62, 64–66, 68–75, 79, 80, 83, 85, 88, 89, 91, 94, 97–102, 104, 106, 108–110, 112, 113, 116–121]. The important feature is not merely iteration, but contingency: the next plan depends on what the agent just learned. CLEARAGENT [13] chooses new binary-analysis targets based on its current exploration context, whereas REPAIRAGENT [10] changes repair behavior after tests or validation expose problems with a candidate patch. REDAGENT [104] dynamically selects refinement actions based on real-time responses from the target model, and the ReAct agents benchmarked in JITVUL [108] and Agent Security Bench [113] inherit the same thought-action-observation contingency from their underlying ReAct paradigm.

Hierarchical task decomposition separates high-level objectives from lower-level execution choices [5, 18, 23, 28, 44, 54, 55, 57, 63, 64, 70, 83, 94, 95, 98, 99, 101, 110, 111, 117, 118, 121]. Zhu et al.’s HPTSA [118] is a clear example: a planning agent analyzes the target and launches specialized subagents for exploitation subtasks. REFPESTER [18] uses a staged penetration-testing structure, letting the current stage constrain which tactical actions are reasonable. The NVIDIA CVE-triage system of ZeMicheal et al. [111] follows the same pattern at the task level: a Plan-and-Execute-style LLM planner first decomposes each CVE into a context-sensitive checklist, which is then executed step by step.

Backtracking on failure appears when the agent returns to an earlier choice, abandons a weak path, or retries from a different branch after evidence does not support the current plan [12, 13, 54, 80]. CLEARAGENT [13] provides a compact example at the analysis level, revising its exploration direction when the current binary path does not substantiate a candidate vulnerability.

Unspecified planning strategy denotes papers that mention planning only in passing, or not at all, without enough procedural detail to classify the planning behavior as dynamic/reactive, hierarchical, or backtracking [1, 3, 8, 11, 15, 34, 36, 37, 41, 42, 61, 76, 77, 81, 84, 92]. As with unspecified reasoning paradigms, this label reflects under-reporting rather than the absence of any planning; we introduce it as a fourth planning strategy so that under-specified papers are marked explicitly instead of silently contributing to the denominator without a tag.

Decision-making uncertainty. Confidence-based branching lets the agent choose different actions depending on the strength of evidence, estimated risk, or confidence in an intermediate finding [1, 5, 12, 16, 19, 22, 29, 36, 39, 40, 54, 61, 66, 72, 76, 81, 85, 94, 98, 99, 101, 104, 121]. PTFUSION [94] represents this idea at the planning level by using context-aware knowledge fusion and executed actions to guide more precise next commands.

Majority voting handles uncertainty by comparing outputs from multiple agents and selecting the most supported answer [53, 54, 59, 61, 64, 77, 99]. This pattern is most natural when the task admits plausible disagreement, such as smart-contract vulnerability classification or ambiguous defensive decisions. In these settings, the system treats disagreement itself as useful evidence rather than assuming that a single generation is authoritative.

Table 8. Paper attribution for Approach: Agent action space

Year	Paper	Static analysis tools				Dynamic analysis tools				Code execution & environment				Information retrieval tools				Security-specific platforms				Human interaction									
		Linters and pattern matchers (12%)	Data flow/taint analyzers (3%)	Symbolic execution engines (2%)	Formal verification tools (5%)	Binary analysis frameworks (6%)	Parsers (4%)	Debuggers (4%)	Execution sandboxes (17%)	Network traffic analyzers (9%)	Compilers/interpreters (5%)	REPL/shell execution (19%)	Containerised environments (11%)	Browser/web automation (7%)	Code search (17%)	Documentation retrieval (8%)	Vector store/RAG retrieval (29%)	CTP platforms (14%)	Penetration testing frameworks (25%)	Vulnerability scanners (6%)	SSEM/SCAPE integration (6%)	MITRE ATT&CK integration (9%)	Cloud/IaC platform tools (9%)	Cyber range/network simulation environment (12%)	Asset search/OSINT platforms (1%)	Message passing between agents (20%)	Voting/aggregation protocols (6%)	Blockchain consensus/judicial trail (1%)	Querying human expert (1%)	Human interaction/feedback for human review (12%)	
2026	[13]	✓		✓	✓			✓		✓	✓		✓	✓	✓	✓	✓	✓	✓	✓				✓		✓	✓	✓		✓	
	[23]	✓	✓					✓						✓					✓			✓	✓							✓	
	[31]																														
	[42]		✓		✓											✓				✓						✓	✓			✓	
	[47]																														
	[49]																														
	[51]																														
	[68]																														
	[76]																														
	[89]																														
2025	[26]	✓																													
	[84]																														
	[111]																														
	[121]																														
	[122]																														
	[123]																														
	[124]																														
	[125]																														
	[126]																														
	[127]																														
2024	[128]																														
	[129]																														
	[130]																														
	[131]																														
	[132]																														
	[133]																														
	[134]																														
	[135]																														
	[136]																														
	[137]																														
2023	[138]																														
	[139]																														
	[140]																														
	[141]																														
	[142]																														
	[143]																														
	[144]																														
	[145]																														
	[146]																														
	[147]																														

Human-in-the-loop checkpoints reserve key decisions for human approval, verification, or guidance [26, 84, 111, 121]. This is a practical response to uncertainty and risk: the agent may gather evidence, rank hypotheses, or draft a recommendation, while a human analyst validates the finding before a sensitive action is taken. In Sheikhi et al.’s COGNITIVE SOC [84], this boundary is visible in the analyst-facing narrative: the agent organizes evidence and explanation, but the human remains the decision maker for security-operation response.

6.2.5 Agent action space. The security capability of an agent is often determined less by the language model alone than by what the model is allowed to inspect, execute, query, and validate through tools. The agent action space describes the external operations that an LLM-based security agent can invoke after reasoning about a task. In this survey, actions range from conventional software-analysis utilities to security platforms, multi-agent coordination mechanisms, and human-facing review steps, as summarized in Table 8.

Static analysis tools. Linters and pattern matchers give agents lightweight static checks over source code, configuration files, vulnerability templates, and suspicious code idioms [13, 23, 31, 42, 47–49, 51, 68, 76, 83, 89, 94, 102, 109]. These actions usually serve as a first filter: they point the agent toward likely relevant regions before deeper reasoning begins. Data-flow/taint analyzers go further by exposing how values move through a program [13, 31, 49, 69, 94]. Guo et al.’s REPOAUDIT [31] uses demand-driven data-flow evidence and validation to decide whether a suspected bug is feasible along a program path.

Symbolic execution is used to reason about feasible paths and path conditions [13, 60], while formal verification tools checks the generated or retrieved properties against the precise semantic requirements [47, 51, 60, 92, 99]. Liu

et al.’s PROPERTYGPT [51] generates smart-contract properties, but the workflow does not stop at generation. It uses compilation, static analysis, ranking, and a prover to determine whether the properties are usable for formal verification.

Binary analysis frameworks support reverse engineering and vulnerability detection when source code is unavailable [2, 4, 13, 40, 62, 120]. Chen et al.’s CLEARAGENT [13] shows how this action class changes the role of the LLM. The agent interacts with binary-analysis interfaces, inspects functions and control-flow structures, and attempts to validate candidate bugs, so binary understanding is mediated through analysis actions rather than unconstrained text generation.

Dynamic analysis tools. Fuzzers let agents generate or mutate inputs to expose crashes, protocol violations, or hidden vulnerability conditions [31, 49, 62, 109]. Debuggers give agents a way to inspect intermediate execution states, crashes, and binary behavior [2, 13, 83, 121].

Execution sandboxes provide controlled environments for running risky commands, malware-like behaviors, exploit attempts, or benchmark tasks [4, 8, 17, 26, 40, 45, 58, 68, 69, 72, 80, 85, 98, 102, 111, 112, 117]. In BountyBench [112], sandboxed environments are central to assessing agents that must inspect code, exploit vulnerabilities, and produce patches in realistic targets. Network traffic analysers extend dynamic observation to packets, flows, IDS evidence, and protocol behavior [12, 19, 24, 37, 62, 70, 75, 84, 110].

Code execution & environment. Compilers / interpreters enable agents to build, run, and check generated code or specifications [2, 4, 31, 60, 109]. REPL / shell execution gives the agent direct command-level access to a target or analysis environment [2, 10, 16, 18, 19, 22, 26, 28, 29, 32, 40, 58, 68, 94, 98, 100, 106, 112, 121]. Containerised environments isolate vulnerable systems, reproduce experiments, and standardize execution contexts [4, 8, 14, 26, 45, 68, 85, 98, 111, 112, 117]. Shen et al.’s PENTESTAGENT [85] uses this kind of controlled setting to support end-to-end penetration-testing workflows, where reconnaissance, vulnerability analysis, and exploitation must be assessed against concrete targets. Browser / web automation appears in web exploitation, prompt-injection assessment, and UI-driven security tasks [20, 44, 66, 88, 94, 98, 101].

Information retrieval tools. Code search lets agents locate functions, dependencies, vulnerable files, proof targets, exploit-relevant snippets, or repair ingredients [2, 10, 22, 31, 32, 49, 51, 60, 79, 108, 109, 111–113, 117, 118, 121]. Bouzenia et al.’s REPAIRAGENT [10], for example, searches the codebase for repair ingredients before constructing and validating candidate patches. Documentation retrieval covers API references, tool manuals, exploit writeups, vulnerability reports, cloud documentation, protocol standards, and remediation guidance [2, 5, 9–11, 14, 18, 22–24, 29, 38, 40, 47, 48, 51, 52, 54, 56, 58, 62, 63, 68, 69, 76, 81, 84, 85, 89, 94, 95, 98, 99, 101, 110, 111, 117, 121]. Vector store / RAG retrieval gives agents a more targeted retrieval action over embedded corpora or knowledge bases [11, 15, 16, 18, 19, 29, 30, 35, 37, 40, 41, 46, 47, 51, 54, 57, 62, 63, 68, 75, 83–85, 89, 101, 104, 108, 111, 113]. The difference is visible in PROPERTYGPT: Liu et al. [51] retrieve similar human-written smart-contract properties from a vector database and use them as references for generating new formal properties. Dai et al.’s REFPESTER [18] applies the same general idea to penetration testing, retrieving stage-relevant knowledge before choosing later actions.

Security-specific platforms. CTF platforms provide controlled exploitation, reverse-engineering, and challenge-solving environments [2, 4, 8, 13, 22, 40, 80, 85, 98, 101, 109, 119–121]. Penetration testing frameworks embed agents into offensive-security workflows and toolchains [3, 4, 8, 9, 16, 18, 22, 28, 29, 32, 38, 56, 58, 63, 68, 72, 80, 85, 88, 94, 95, 98, 100, 101, 106]. Vulnerability scanners appear as actions or baselines that agents invoke, interpret, or coordinate with [4, 52, 68, 69, 80, 98]. In these offensive settings, the agent’s action space resembles a security practitioner’s toolbox: scan, enumerate, exploit, validate, and report.

SIEM / SOAR integration places agents in security-operation workflows for alert investigation, evidence synthesis, triage, and response support [5, 24, 39, 84, 102, 110]. Sheikhi et al.’s COGNITIVE SOC [84] is a representative defensive

example: agents enrich alerts, reason over evidence, and generate analyst-facing narratives. MITRE ATT&CK integration gives agents a shared language for tactics, techniques, and attack-chain reasoning [9, 12, 39, 54, 56, 57, 72, 84, 91]. Loevenich et al. [54] connect CTI, CVEs, and ATT&CK-style tactics through cybersecurity knowledge graphs to support autonomous cyber defense.

Cloud / IaC platform tools support cloud defense, infrastructure policy, IaC vulnerability analysis, and privilege-escalation workflows [14, 26, 55, 80, 89, 95, 110, 111, 116]. Cyber range / network simulation environments provide controlled networks for assessing attack, defense, and autonomous cyber operations [12, 17, 45, 54, 55, 57, 65, 71–74, 91]. Asset search / OSINT platforms connect agents to internet-exposed asset discovery and vulnerability assessment [52]. Together, these platform actions show that security agents are often embedded in domain infrastructures, not merely attached to generic programming tools.

Inter-agent communication. Message passing between agents lets specialized agents exchange intermediate findings, divide labor, and coordinate multi-step workflows [12, 14, 34, 36, 53, 55, 58, 59, 61, 62, 64, 70, 71, 83, 95, 97, 99–101, 110]. This is common when no single agent owns the entire task, such as incident correlation, multi-stage penetration testing, or collaborative vulnerability analysis. Voting / aggregation protocols combine multiple judgments to reduce single-agent errors or resolve disagreement [53, 59, 77, 99]. Blockchain consensus / audit trail appears as a stronger accountability mechanism in one multi-LLM network, where agent proposals and decisions are recorded and checked through consensus [59]. These communication actions matter because security work often requires defensible coordination, not just individual prediction.

Human interaction. Querying human expert appears when the agent explicitly asks a human for clarification, guidance, or execution support [22]. Deng et al.’s PENTESTGPT [22] reflects this interactive design: the human can guide the penetration-testing loop and may execute or validate steps that the agent proposes. Findings for human review is broader, covering reports, alerts, explanations, remediation recommendations, and analyst-facing summaries [1, 3, 5, 18, 24, 26, 34, 39, 40, 75, 111, 121].

6.2.6 Agent workflow & orchestration. Agent workflow and orchestration describe how an LLM agent organizes work over time, divides responsibilities among modules or agents, and decides where human users enter the loop. Table 9 summarizes the workflow topologies, coordination patterns, and forms of human involvement identified in the surveyed systems.

Workflow topology. Workflow topology captures the structural pattern of the agent process. A sequential pipeline is the most basic form: the agent progresses through ordered stages such as collecting context, analyzing evidence, planning a response, executing commands, and reporting findings. For example, PentestGPT follows a staged penetration-testing workflow in which high-level reasoning, task generation, parsing of tool outputs, and next-step selection are connected in a serial process [22].

Parallel dispatch is used when different agents, tools, or subtasks can run concurrently and then merge their results [1, 12, 26, 34, 36, 40, 47, 55, 59, 61, 62, 64, 70, 77, 99, 101, 109, 110]. Parallelism is useful when the target has multiple independent surfaces, such as several APIs, hosts, logs, or vulnerability hypotheses. Debate and discussion are a related but more deliberative form of topology: agents exchange competing judgments before a final decision is made [1, 12, 53, 59, 61, 77, 81, 99].

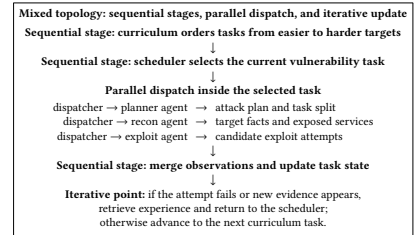


Fig. 3. CURRICULUMPT workflow.

Table 9. Paper attribution for Approach: Agent workflow & orchestration

Year	Paper	Sequential pipeline (96%)	Parallel dispatch (18%)	Workflow topology Iterative loop (78%)	Hierarchical decomposition (15%)	Debate / discussion (8%)	Adversarial red / blue team (6%)	Planner (74%)	Analyst (93%)	Executor (92%)	Exploit developer (7%)	Agent roles Patch generator (6%)	Verifier / tester (14%)	Reporter (11%)	Critic / judge (6%)	Orchestrator (18%)	Fully autonomous (95%)	HTL integration Human-on-the-loop (8%)	Human-in-the-loop (5%)	Interactive / collaborative (3%)
2026	63	✓		✓				✓	✓	✓	✓						✓			
	59	✓	✓	✓		✓		✓	✓	✓							✓			
	60	✓		✓				✓	✓	✓							✓			
	75	✓		✓				✓	✓	✓			✓				✓			
	47	✓	✓	✓				✓	✓	✓			✓				✓			
	112	✓		✓				✓	✓	✓							✓			
	72	✓		✓				✓	✓	✓							✓			
	121	✓		✓	✓		✓	✓	✓	✓						✓	✓			
	119	✓		✓				✓	✓	✓							✓			
	30	✓		✓				✓	✓	✓							✓			
	32	✓		✓				✓	✓	✓	✓						✓			
	94	✓		✓	✓			✓	✓	✓						✓	✓			
	104	✓		✓	✓			✓	✓	✓						✓	✓			
	118	✓		✓	✓			✓	✓	✓						✓	✓			
	116	✓		✓				✓	✓	✓						✓	✓			
	11	✓		✓		✓		✓	✓	✓						✓	✓			
	99	✓	✓	✓	✓	✓		✓	✓	✓			✓			✓	✓			
	69	✓		✓				✓	✓	✓						✓	✓			
2025	44	✓		✓				✓	✓	✓							✓			
	34	✓	✓	✓				✓	✓	✓				✓	✓		✓			
	97	✓		✓				✓	✓	✓							✓			
	86	✓		✓				✓	✓	✓							✓			
	113	✓		✓				✓	✓	✓							✓			
	42	✓		✓			✓	✓	✓	✓							✓			
	58	✓		✓				✓	✓	✓							✓			
	16	✓		✓				✓	✓	✓							✓			
	92	✓		✓				✓	✓	✓				✓			✓			
	71	✓		✓				✓	✓	✓							✓			
	53	✓		✓	✓	✓		✓	✓	✓				✓			✓			
	56	✓		✓				✓	✓	✓							✓			
	63	✓		✓				✓	✓	✓				✓			✓			
	29	✓		✓				✓	✓	✓							✓			
	98	✓		✓				✓	✓	✓				✓			✓			
	108	✓		✓				✓	✓	✓							✓			
	19	✓		✓				✓	✓	✓							✓			
	13	✓		✓				✓	✓	✓							✓			
	5	✓		✓	✓		✓	✓	✓	✓							✓			✓
	5	✓		✓				✓	✓	✓							✓			
	94	✓		✓	✓	✓		✓	✓	✓				✓			✓			
	77	✓		✓				✓	✓	✓							✓			
	61	✓	✓	✓	✓	✓		✓	✓	✓				✓			✓			
	28	✓		✓	✓			✓	✓	✓							✓			
	101	✓	✓	✓	✓			✓	✓	✓							✓			
	117	✓		✓				✓	✓	✓							✓			
	91	✓		✓				✓	✓	✓							✓			
	43	✓		✓				✓	✓	✓							✓			
	54	✓		✓	✓			✓	✓	✓							✓			
	14	✓		✓				✓	✓	✓							✓			
	2	✓		✓				✓	✓	✓							✓			
	17	✓		✓				✓	✓	✓							✓			
	45	✓		✓				✓	✓	✓							✓			
	12	✓	✓	✓		✓		✓	✓	✓							✓			
	79	✓		✓				✓	✓	✓				✓			✓			
	65	✓		✓				✓	✓	✓							✓			
	85	✓		✓				✓	✓	✓				✓			✓			
	26	✓	✓	✓				✓	✓	✓							✓			
	89	✓		✓				✓	✓	✓							✓			
	80	✓		✓				✓	✓	✓							✓			
	70	✓	✓	✓	✓			✓	✓	✓							✓			
	64	✓		✓				✓	✓	✓							✓			
	35	✓		✓				✓	✓	✓							✓			
	14	✓		✓				✓	✓	✓							✓			
	102	✓		✓				✓	✓	✓							✓			
	81	✓		✓		✓		✓	✓	✓				✓			✓			
	49	✓		✓				✓	✓	✓							✓			
	40	✓	✓	✓				✓	✓	✓							✓			
	83	✓		✓	✓			✓	✓	✓							✓			✓
	62	✓	✓	✓				✓	✓	✓							✓			
	110	✓		✓				✓	✓	✓							✓			
	109	✓	✓	✓				✓	✓	✓							✓			
	157	✓		✓				✓	✓	✓							✓			
	95	✓		✓				✓	✓	✓							✓			
	11	✓		✓				✓	✓	✓							✓			
	34	✓		✓	✓			✓	✓	✓							✓			
	18	✓		✓				✓	✓	✓							✓			
	10	✓		✓				✓	✓	✓							✓			
	31	✓		✓				✓	✓	✓							✓			
	52	✓		✓				✓	✓	✓							✓			
	39	✓		✓				✓	✓	✓							✓			
	24	✓		✓				✓	✓	✓				✓	✓		✓			
	75	✓		✓				✓	✓	✓							✓			
	48	✓		✓				✓	✓	✓							✓			
2024	37	✓		✓				✓	✓	✓							✓			
	20	✓		✓			✓	✓	✓	✓							✓			
	15	✓		✓				✓	✓	✓							✓			
	68	✓		✓				✓	✓	✓							✓			
	27	✓		✓				✓	✓	✓							✓			
	3	✓		✓				✓	✓	✓							✓			
	120	✓		✓				✓	✓	✓							✓			
	111	✓		✓				✓	✓	✓				✓			✓			
	106	✓		✓				✓	✓	✓							✓			
	74	✓		✓				✓	✓	✓							✓			
	58	✓		✓				✓	✓	✓							✓			
	9	✓		✓				✓	✓	✓							✓			
	22	✓		✓				✓	✓	✓							✓			✓
	73	✓		✓				✓	✓	✓							✓			
	100	✓		✓				✓	✓	✓							✓			
	33	✓	✓	✓	✓		✓	✓	✓	✓							✓			
2023	23	✓		✓				✓	✓	✓							✓			
	36	✓	✓	✓				✓	✓	✓							✓			

Iterative loops are used when the agent must repeatedly act, observe, and revise its state. Such loops appear throughout the surveyed systems [2, 9, 11, 16–19, 22, 23, 29, 31, 36, 45, 49, 51–53, 56, 59, 60, 63, 68–71, 73, 75, 79, 83, 89, 94, 97–100, 102, 108, 116]. CLEARAGENT [13], for example, iteratively explores binary code, updates its analysis context, and validates candidate vulnerabilities with concrete inputs. Hierarchical decomposition adds a manager, planner, controller, or chief agent above specialized workers [5, 18, 23, 28, 53–55, 64, 83, 94, 99, 101, 110, 118, 121]. For example, Zhu et al.’s HPTSA [118] illustrates the pattern in zero-day exploitation: a planning agent analyzes the target and launches specialized subagents for exploitation subtasks. Adversarial red/blue-team topology appears when agents are explicitly assigned opposing attacker and defender roles [8, 20, 55, 58, 72, 113].

A mixed topology can combine several of these structures. As shown in Figure 3, CURRICULUMPT [101] provides such an example: the overall curriculum proceeds sequentially from easier to harder penetration-testing tasks; within a selected task, work can be dispatched to specialized planning, reconnaissance, and exploitation components; and the workflow iterates by storing successful strategies and reusing experience in later tasks.

Agent roles. Agent roles describe the functional responsibilities assigned inside the workflow. Planner, analyst, and executor roles form the common backbone of agent workflows. A paper is tagged with a Planner role when it names or describes a component responsible for producing a plan, independent of which planning strategy that component uses; the two tags are related but answer different questions, and a paper need not carry both.

More specialized roles encode security-domain labor. Exploit developer roles generate or refine attack steps [9, 32, 68, 85, 101, 109, 118], whereas patch generator roles produce fixes or remediation artifacts [10, 26, 76, 89, 109, 112]. Verifier / tester roles run tests, validate exploit success, check generated properties, or reduce false positives [13, 23, 29, 31, 36, 47, 48, 51, 60, 61, 69, 99, 100, 109]. Reporter roles convert evidence into human-readable findings, incident narratives, or remediation summaries [29, 34, 53, 76, 79, 81, 84, 88, 92, 97, 111]. Critic / judge roles provide a second opinion or quality filter [23, 36, 61, 76, 77, 97], and orchestrator roles coordinate subagents, maintain global state, or assign subtasks [5, 18, 23, 28, 53–55, 58, 63, 64, 83, 94, 99–101, 110, 118, 121].

For example, in REPAIRAGENT [10], the agent must search for repair ingredients, propose a patch, execute validation, and revise after feedback. In PROPERTYGPT [51], generation is paired with verification: the system generates formal properties for smart contracts, then checks whether they compile, fit the target, and can be verified.

HITL integration. Fully autonomous workflows let the agent proceed without routine human intervention, which is common in benchmarked penetration testing, cyber-defense simulation, vulnerability scanning, repair, and analysis pipelines [5, 8, 9, 13, 15, 16, 19, 20, 23, 24, 28, 36–39, 41, 42, 47, 48, 52, 54, 55, 58, 61, 66, 71–73, 75–77, 85, 91, 92, 94, 101, 108, 109, 111–113, 117, 119, 121]. Human-on-the-loop workflows keep the system mostly autonomous while allowing

analysts to monitor, review, or approve high-level outcomes [22, 39, 54, 55, 57, 58, 79, 84]. Human-in-the-loop workflows require human input at particular decision points, such as executing commands, providing clarifications, or approving uncertain actions [3, 18, 22, 120, 121]. Interactive or collaborative workflows go further by treating the human as

Manuscript submitted to ACM

Table 10. Paper attribution for Approach: Agent self-improvement & learning

Year	Paper	In-context adaptation		Cross-session learning		RL-based improvement	
		Learning from feedback within session (32%)	Example-guided correction (1%)	Storing successful trajectories (3%)	Updating fine-tuning data (2%)	Reward signal design (9%)	Environment-based RL (9%)
2026	[68]	✓					
	[59]	✓					
	[60]						
	[75]	✓		✓			
	[47]						
	[112]						
	[72]						
	[121]	✓				✓	
	[119]			✓	✓		
	[30]	✓					
	[32]			✓			
	[94]	✓					
	[104]						
	[118]	✓					
	[116]						
	[1]	✓					
	[99]	✓					
	[69]	✓					
	[44]	✓				✓	✓
	[34]						
	[97]						
2025	[46]						
	[113]						
	[42]						
	[58]						
	[16]						
	[92]						
	[71]	✓			✓		
	[53]						
	[56]						
	[63]						
	[29]	✓					
	[98]						
	[108]						
	[19]						
	[13]						
	[8]						
	[5]						
	[84]						
	[77]						
	[61]						
	[28]						
	[101]	✓					
	[117]	✓					
	[41]					✓	✓
	[54]	✓				✓	✓
	[14]						
	[2]						
	[17]					✓	✓
	[45]						
	[12]	✓					
	[79]		✓				
	[65]						
	[88]						
	[26]	✓					
	[69]	✓					
	[80]	✓					
	[70]	✓					
	[64]	✓					
	[35]						
	[4]						
	[102]						
	[81]						
	[49]						
	[40]						
	[83]	✓					
	[62]	✓					
	[110]	✓					
	[109]						
	[85]	✓					
	[95]	✓					
	[11]						
	[51]						
	[18]	✓					
	[10]						
	[31]						
	[52]						
	[39]	✓					
	[24]						
	[76]						
	[48]						
2024	[57]						
	[20]						
	[15]						
	[66]	✓				✓	✓
	[57]						
	[3]						
	[120]						
	[111]						
	[106]						
	[74]						✓
2023	[38]						
	[9]						
	[22]						
	[73]					✓	✓
	[100]	✓					
	[55]	✓				✓	✓
	[23]	✓					
	[36]						

a continuing collaborator rather than only an approver [22, 83, 84]. Deng et al.’s PENTESTGPT [22] combines these patterns. The system maintains a pentesting task tree and uses reasoning, generation, and parsing modules to propose next actions and interpret outputs. The human is on the loop when monitoring the agent’s evolving task tree and strategic recommendations. The human is in the loop when executing commands in the target environment and feeding results back to the agent.

6.2.7 Agent self-improvement & learning. Agent self-improvement and learning describe whether a security agent changes its behavior from feedback, examples, stored experience, fine-tuning data, or reward-driven interaction. The identified learning and adaptation mechanisms are summarized in Table 10.

In-context adaptation. Learning from feedback within session refers to improvement that happens inside the current task episode, without necessarily changing model weights [12, 18, 23, 26, 29, 30, 39, 44, 54, 55, 57, 59, 64, 66, 68–71, 75, 79, 83, 85, 89, 91, 94, 95, 99–101, 110, 116, 121]. The feedback may come from tool output, failed commands, execution traces, analyst observations, retrieved evidence, peer-agent critique, or changes in the target environment. In penetration testing, this usually looks like an agent trying a command, reading the result, and adjusting the next step. Ginige et al.’s AUTOPENTESTER [29], for example, uses the results of previous testing actions as context for later strategy selection. Dai et al.’s REFENTESTER [18] makes the feedback loop more explicit by reflecting on failed operations and using the result to guide subsequent penetration-testing stages.

Example-guided correction is a narrower form of in-context adaptation in which the system uses examples, demonstrations, or corrected instances to steer later outputs [79]. Schuring et al. [79] use this idea for generating software-security learning materials: traceability links and contextual examples help the agent refine generated educational content so that it better aligns with security requirements. Here, the correction signal is not a reward from an environment, but an example of what a better output should resemble.

Cross-session learning. Storing successful trajectories preserves useful interaction traces beyond a single run so that future tasks can reuse solved strategies, action sequences, or reasoning patterns [32, 75, 119]. Zhuo et al.’s CYBER-ZERO [119] is an example. Instead of requiring access to the original runtime environments, it reconstructs long-horizon cybersecurity trajectories from public CTF writeups and simulated personas, then uses those trajectories as reusable experience for training cybersecurity agents.

Updating fine-tuning data carries improvement further by turning solved trajectories, generated instructions, or adapted strategies into training data for later model behavior [71, 119]. In CYBER-ZERO, Zhuo et al. [119] use synthesized trajectories to train more capable open-weight cybersecurity agents. Qin et al. [71] describe a self-evolving security framework for 6G space-air-ground integrated networks, where updated instruction data helps the security-strategy generator adapt to changing or unknown threats. In both cases, improvement is not confined to the current prompt; the learning artifact is carried into later deployments or training cycles.

RL-based improvement. Reward signal design defines what the agent should optimize, such as API fault discovery, attack progress, service preservation, threat mitigation, mission impact, or successful recovery [17, 44, 45, 54, 55, 57, 72, 73, 91]. Kim et al.’s AUTORESTEST [44] shows how reward design can be tied directly to a software-security task: its API, dependency, parameter, and value agents receive feedback from REST API responses and use multi-agent reinforcement learning to coordinate exploration and improve fault detection.

Environment-based RL uses a cyber range, simulator, network-security game, or API-testing environment as the substrate for repeated interaction and policy improvement [17, 44, 45, 54, 55, 57, 73, 74, 91]. Rigaki et al. [73] place LLM agents in network-security environments and study their behavior under repeated prompt-exploit-observe cycles.

Loevenich et al. [54] assess autonomous cyber-defense agents in a cyber-operations environment against attacker strategies, combining DRL, augmented LLM components, and knowledge-graph support.

6.3 Survey Result: Application

We analyze the surveyed LLM agents' security applications along eleven level-1 categories. Six of these—*vulnerability detection & analysis*, *exploit development & analysis*, *penetration testing & red-teaming*, *vulnerability repair & hardening*, *intrusion & threat detection*, *incident response*, and *threat intelligence & security operations (SecOps)*—each account for more than 10% of the surveyed papers and are presented with individual taxonomy tables. The remaining lower-frequency categories—*fuzzing & test generation*, *malware analysis & detection*, *reverse engineering*, *access control & authentication assessment*, and *model attack generation & robustness evaluation*—share a single table. Within each category, we use the level-2 task groupings shown in the corresponding table to organize the discussion.

6.3.1 Vulnerability detection & analysis.

This is one of the largest application areas in the taxonomy [5, 13, 14, 23, 28, 29, 31, 36, 38, 41, 42, 44, 47–49, 51, 52, 60, 61, 68, 69, 76, 77, 83, 88, 89, 94, 95, 97, 98, 100, 106, 108, 109, 111, 112, 117, 118], as summarized in Table 11. These agents support the discovery, localization, classification, prioritization, and validation of vulnerabilities across source code, smart contracts, binaries, APIs, and infrastructure configurations.

Vulnerability detection. Vulnerability detection refers to the identification of security weaknesses in a given software artifact, whether source code, bytecode, binary, or configuration file. In this sub-task the agent inspects program entities, forms candidate vulnerability hypotheses, and refines its assessment through tool use or iterative reasoning [13, 23, 28, 29, 31, 36, 38,

Table 11. Paper attribution for Application: Vulnerability detection & analysis

Year	Paper	Vulnerability detection (32%)	Vulnerability localization (3%)	Vulnerability classification (3%)	Root cause analysis (3%)	Vulnerability prioritization / triage (2%)	Bug triaging (2%)	Vulnerability correlation (1%)	Zero-day discovery (4%)	API / input-surface security testing (21%)
2026	[68]	✓								✓
	[59]	✓								
	[60]	✓								
	[75]	✓								
	[47]	✓	✓							✓
	[112]	✓							✓	✓
	[72]									
	[121]									
	[119]									
	[30]									
	[32]									✓
	[94]									✓
	[104]									✓
	[118]								✓	✓
	[116]									
	[1]									
	[99]	✓								
	[69]									
2025	[44]									✓
	[34]	✓								✓
	[97]									✓
	[46]									
	[113]									
	[42]	✓								✓
	[58]									
	[16]									
	[92]									
	[71]									
	[53]									
	[36]									
	[63]									
	[29]	✓								
	[98]	✓								✓
	[108]	✓								
	[19]	✓	✓							
	[13]									
	[8]									
	[5]				✓					
	[84]									
	[77]	✓		✓	✓					
	[61]	✓								
	[28]	✓								
	[101]	✓								✓
	[117]	✓								
	[91]	✓								✓
	[41]	✓								✓
	[54]									
	[14]						✓			
	[2]									
	[17]									
	[45]									
	[12]									
	[79]									
	[65]	✓								✓
	[88]	✓								
	[26]	✓								
	[89]									
	[80]									
	[70]									
	[64]									
	[35]									
	[4]									
	[102]									
	[81]	✓				✓			✓	✓
	[49]	✓								
	[40]	✓								
	[83]	✓								
	[62]	✓	✓							✓
	[110]	✓				✓	✓			✓
	[109]	✓								
	[85]	✓								✓
	[95]	✓								✓
	[11]	✓							✓	
	[51]	✓								
	[18]	✓								
	[10]	✓								✓
	[51]	✓								✓
	[32]	✓								
	[39]	✓								
	[24]	✓		✓	✓					
	[76]	✓								
	[48]	✓								
2024	[37]									
	[20]									
	[15]									
	[66]									
	[57]									
	[3]									
	[120]	✓		✓						
	[111]	✓								✓
	[106]	✓								
	[74]	✓								✓
2023	[38]	✓								
	[9]	✓								
	[22]	✓								
	[73]	✓								
	[100]	✓						✓		
	[55]	✓								✓
	[23]	✓								✓
	[36]	✓								✓

41, 42, 47–49, 51, 52, 60, 61, 68, 69, 76, 77, 83, 88, 89, 95, 97, 100, 106, 108, 109, 111, 112, 117]. Smart-contract auditing is heavily represented in this sub-task [36, 51, 61, 76, 77, 97]. For example, GPTLENS [36] decomposes auditing into a two-stage auditor/critic process in which one agent proposes candidate weaknesses and another suppresses false positives. LLM-SMARTAUDIT [97] extends this into a multi-agent conversational architecture with a buffer-of-thought mechanism that propagates intermediate insights across agents, while IAUDIT [61] fine-tunes separate Detector and Reasoner models and subjects candidates to a Ranker/Critic debate. General source-code detection forms a second cluster [23, 31, 41, 42, 83, 108]. DEEPVULHUNTER [41] grounds multi-round reasoning in retrieval over semantically similar code snippets, and JITVUL [108] shows on a benchmark of 879 CVEs that ReAct-style agents outperform raw prompting. AGENT4VUL [42] treats detection as an agentic code-analysis task in which Commentator and Vectorizer agents reason over program context rather than classify isolated snippets. A representative repository-scale instance is REPOAUDIT [31], which traverses interprocedural data-flow facts on demand and uses a path-condition validator to suppress false positives, achieving 78.4% precision at roughly \$2.54 per project. Binary and infrastructure detection extends the sub-task beyond conventional source code [13, 52, 88, 89, 95, 106]. CLEARAGENT [13] detects vulnerabilities in COTS binaries where no source is available, the IaC misconfiguration agent [89] analyses infrastructure-as-code definitions, and the multi-agent SQLi pipeline [88] targets deployed web services.

API / input-surface security testing. This sub-task concerns testing for vulnerabilities through external interfaces—APIs, web surfaces, network endpoints, and infrastructure configurations—rather than by inspecting source code alone [23, 31, 36, 38, 41, 42, 44, 47, 49, 52, 68, 88, 94, 95, 97, 98, 106, 109, 112, 117, 118]. AUTORESTTEST [44] decomposes REST API testing into four cooperating agents trained via multi-agent reinforcement learning, coordinating over a semantic dependency graph of API operations. AUTOPT [98] establishes an end-to-end web-pentest benchmark and finds that agents are procedurally fluent in the workflow but frequently fail to synthesise commands that work against real targets. LLMSQLi [106] provides a black-box SQL injection detection tool driven by multi-agent payload generation.

Zero-day discovery. Zero-day discovery refers to the identification of previously-unknown vulnerabilities in realistic settings, as opposed to classification of known weakness patterns [49, 51, 112, 118]. For example, AGENTFUZZ [49] reports 34 zero-day vulnerabilities (23 CVEs assigned) across 20 popular open-source LLM-agent applications, and PROPERTYGPT [51] discovers 12 zero-days in smart contracts through retrieval-augmented formal property generation. BOUNTYBENCH [112] instantiates 25 real-world systems with 40 monetary bug bounties and separate Detect/Exploit/Patch tasks, while HPTSA [118] exploits 14 real-world zero-day vulnerabilities via a planner that dispatches specialist subagents.

Vulnerability localization. Vulnerability localization concerns identifying the precise code regions responsible for a weakness, as opposed to merely flagging a file or function as vulnerable [13, 47, 109]. CLEARAGENT [13] localises bugs in binaries by combining an analyzer-friendly intermediate representation with an LLM-friendly natural-language view, then verifying candidates by constructing concrete triggering inputs. PATCHAGENT [109] performs fault localization as the first stage of its repair loop, and AVIATOR [47] localises injection points when synthesising training vulnerabilities.

Vulnerability classification. Vulnerability classification maps detected findings to established taxonomies such as CWE types or CVSS severity levels [61, 76, 111]. IAUDIT [61] classifies smart-contract vulnerabilities through its Ranker/Critic debate mechanism, the VEX-justification agent of [111] maps CVE observations to impact categories across containerised environments, and VULNPATCH [76] couples classification with explanation and downstream patching.

Root cause analysis. Root cause analysis reconstructs the underlying cause of a flaw rather than merely reporting its symptoms [5, 61, 76]. CLOUSEAU [5] traces attack chains back to root causes by autonomously traversing system logs from

a single point-of-interest. **IAUDIT** [61] provides root-cause explanation through its Reasoner agent, and **VULNPATCH** [76] generates natural-language explanations of the vulnerability mechanism as part of its detect-explain-patch pipeline.

Vulnerability prioritization / triage. Vulnerability prioritization concerns ordering findings by severity, exploitability, or remediation cost to guide effort [49, 109]. **AGENTFUZZ** [49] prioritises candidate taint-style findings by exploitability before reporting them, and **PATCHAGENT** [109] orders localised faults to determine which to repair first within its autonomous loop.

Bug triaging. Bug triaging refers to the assignment and routing of detected findings to the appropriate remediation workflow [14, 109]. **LLM2POLICY** [14] routes configuration findings to the corresponding policy layer, while **PATCHAGENT** [109] determines which findings are actionable within its repair pipeline. This sub-task overlaps with prioritization but concerns the routing decision rather than the ordering itself.

Vulnerability correlation. Vulnerability correlation links observations across multiple data sources to build a coherent picture of a weakness and its impact [100]. **PTGROUP** [100] correlates findings discovered across separate stages of an engagement through chained prompt sequences, representing an early form of cross-artifact vulnerability management.

6.3.2 Exploit development & analysis. These agents, as summarized in Table 12, synthesise and analyse working exploits once a vulnerability is known [3, 4, 48, 56, 58, 69, 80, 101, 111, 112, 117, 118]. Much exploit-related activity is subsumed by penetration testing; the papers here treat exploit synthesis or analysis as a primary objective.

Exploit generation. Exploit generation concerns synthesising payloads or scripts from vulnerability descriptions [3, 4, 101, 112, 117, 118]. For example, **HPTSA** [118] dispatches specialist subagents from a planning agent, achieving 4.3× improvement over single-agent baselines on 14 real zero-day vulnerabilities. The study by Happe et al. [3] compares five prompt formulations for CVE-to-Metasploit-script generation across GPT-4o, WhiteRabbitNeo, and Mistral in a military coalition-network context.

Payload crafting. Payload crafting refers to the construction of concrete attack payloads that trigger the intended vulnerability behaviour [3, 4, 101, 112, 117, 118]. In our corpus this sub-task is co-extensive with exploit generation: every paper that synthesizes an exploit also constructs a target-specific payload satisfying constraints such as input filtering or memory layout. In general, the two remain distinct capabilities, though.

Table 12. Paper attribution for Application: Exploit development & analysis

Year	Paper	Exploit generation (6%)	Exploit chaining / attack-path construction (3%)	Payload crafting (6%)	Exploit analysis / reverse engineering (1%)	Exploit detection (3%)
2026	[68]					
	[59]					
	[60]					
	[75]					
	[47]					
	[112]	✓		✓		
	[72]					
	[121]					
	[119]					
	[30]					
	[32]					
	[94]					
	[104]	✓		✓		
	[118]					
	[116]					
	[1]					
	[99]					✓
	[69]					
	[44]					
	[34]					
2025	[97]					
	[46]					
	[113]					
	[42]		✓			
	[58]					
	[16]					
	[92]					
	[71]					
	[53]		✓			
	[56]					
	[63]					
	[29]					
	[98]					
	[108]					
	[19]					
	[13]					
	[8]					
	[5]					
	[84]					
	[77]					
	[61]					
	[28]					
	[101]	✓		✓		
	[117]					
	[91]					
	[41]					
	[54]					
	[14]					
	[7]					
	[17]					
	[45]					
	[12]					
	[79]					
	[65]					
	[88]					
	[26]					
	[89]					
	[80]		✓			
	[70]					
	[64]					
	[35]	✓		✓	✓	
	[14]					
	[102]					
	[81]					
	[49]					
	[40]					
	[83]					
	[62]					
	[110]					
	[109]					
	[85]					
	[95]					
	[11]					
	[51]					
	[18]					
	[10]					
	[51]					
	[52]					
	[39]					
	[24]					
	[76]					
	[48]					✓
2024	[37]					
	[20]					
	[15]					
	[66]					
	[57]					
	[3]	✓		✓		
	[120]					
	[111]					✓
	[106]					
	[74]					
2023	[58]					
	[9]					
	[22]					
	[73]					
	[100]					
	[55]					
	[23]					
	[36]					

Exploit chaining / attack-path construction. Exploit chaining concerns assembling multi-step attack paths from individual vulnerability primitives [56, 58, 80]. In these papers agentic generative AI combines cybersecurity knowledge graphs with LLM agents to compose chains against tactical network targets, reasoning about preconditions and privilege transitions between steps.

Exploit detection. Exploit detection concerns identifying the presence or feasibility of exploitable weaknesses from an external perspective [48, 69, 111]. VVF-AI [48] builds a proof-of-concept-based verification framework to filter false-positive reports, and ZT-ICAS [69] uses agentic scanning to detect exploitable weaknesses while hardening the scanner itself against adversarial manipulation.

Exploit analysis / reverse engineering. Exploit analysis concerns understanding the mechanism and impact of existing exploits [4]. Only one paper addresses this sub-task, targeting the reverse engineering of exploits as a precursor to developing defensive countermeasures.

6.3.3 Penetration testing & red-teaming. Agents in this category simulate adversarial activity against a target, interleaving reconnaissance, exploitation, and reporting [2–4, 9, 16, 18, 20, 22, 28, 29, 32, 38, 40, 52, 56, 58, 63, 68, 72–74, 80, 85, 88, 94, 95, 98, 100, 101, 117–121]. This was the earliest application area to attract LLM-agent attention. Table 13 summarizes these applications.

Red team automation. Red team automation refers to the end-to-end orchestration of adversarial campaigns in which the agent selects the next action based on the current state of the engagement [3, 4, 9, 16, 18, 22, 28, 29, 38, 56, 58, 63, 68, 72–74, 80, 85, 88, 94, 98, 100, 101, 117, 118]. For example, AUTO-PENTESTER [29] accepts only a target IP and iteratively invokes standard security tools, outperforming PENTESTGPT by 27% in subtask completion with substantially less human intervention. PENTEST-AI [9] structures attack chains around MITRE ATT&CK, PTFUSION [94] introduces a semi-decentralised multi-agent design with Model Context Protocol-based tool invocation, and REF-PENTESTER [18] uses knowledge self-reflection to mitigate hallucinated commands. The controller-based framework of [28] adds explicit workflow management to reduce stage-skipping and token waste.

Table 13. Paper attribution for Application: Penetration testing & red-teaming

Year	Paper	Reconn- aissance (17%)	Initial access (14%)	Privilege escalation (3%)	Lateral movement (2%)	Exfiltration simulation (2%)	Full end-to- end pentest (14%)	CTF challenge solving (7%)	Red team automation (25%)
2026	[68]	✓							✓
	[59]								
	[60]								
	[73]								
	[47]								
	[112]								
	[121]	✓	✓	✓	✓	✓	✓	✓	✓
	[119]							✓	
	[30]								
	[52]			✓					
	[94]	✓	✓				✓		✓
	[104]								✓
	[118]	✓							✓
	[116]								
	[11]								
	[99]								
	[69]								
2025	[44]								
	[34]								
	[97]								
	[46]								
	[113]								
	[42]								
	[58]								✓
	[16]								✓
	[92]								
	[71]								
	[53]								
	[56]								✓
	[63]	✓	✓				✓		✓
	[29]	✓	✓				✓		✓
	[98]	✓	✓				✓		✓
	[108]								
	[19]								
	[13]								
	[8]								
	[5]								
	[84]								
	[77]								
	[61]	✓	✓				✓		✓
	[28]								✓
	[101]								✓
	[117]								✓
	[91]								
	[41]								
	[54]								
	[14]								
	[2]							✓	
	[17]								
	[45]								
	[12]								
	[79]								
	[65]								
	[88]								✓
	[26]								
	[89]								
	[80]	✓	✓				✓	✓	✓
	[70]								
	[64]								
	[35]								
	[4]							✓	✓
	[102]								
	[81]								
	[49]								
	[40]							✓	
	[83]								
	[62]								
	[110]								
	[109]								
	[85]	✓	✓				✓		✓
	[95]			✓					
	[11]								
	[18]	✓	✓		✓		✓		✓
	[10]								
	[31]	✓							
	[52]								
	[39]								
	[24]								
	[76]								
	[48]								
2024	[20]					✓			
	[15]								
	[66]								
	[57]								
	[3]								✓
	[120]							✓	
	[111]								
	[106]								
	[74]								✓
	[38]	✓	✓				✓		✓
2023	[9]	✓	✓				✓		✓
	[22]	✓	✓				✓		✓
	[73]	✓	✓				✓		✓
	[100]	✓	✓				✓		✓
	[55]								
	[23]								
	[36]								

Reconnaissance. Reconnaissance concerns the identification of hosts, services, attack surfaces, and environmental cues prior to exploitation [18, 22, 28, 29, 38, 52, 63, 68, 72, 73, 80, 85, 94, 98, 100, 101, 118]. Most end-to-end penetration-testing frameworks incorporate reconnaissance as the initial phase. The FOFA-based asset-search agent of [52] contributes context-aware reconnaissance queries over internet-exposed assets, and the HPTSA planner [118] performs reconnaissance to inform specialist subagent dispatch.

Initial access. Initial access refers to the step where the agent gains a first foothold in the target system [18, 22, 28, 29, 38, 63, 72, 73, 80, 85, 94, 98, 100, 101]. In these papers the agent must translate reconnaissance findings into a concrete exploitation attempt against a live service. PENHEAL [38] couples this offensive phase with a remediation module via counterfactual prompting, improving vulnerability coverage by 31% and reducing cost by 46%.

Full end-to-end pentest. These pentests require the agent to coordinate the entire loop from initial probing through exploitation and, in some cases, reporting or remediation [18, 22, 28, 29, 38, 63, 72, 73, 80, 85, 94, 98, 100, 101]. The local-LLM study of [72] highlights the privacy, operational, and reproducibility implications of deploying offensive agents without cloud-hosted models, while CURRICULUMPT [101] organises the task as a curriculum that proceeds from easier to harder targets and reuses stored experience across engagements.

CTF challenge solving. CTF challenge solving uses capture-the-flag environments as controlled settings for studying offensive agent capabilities [2, 4, 40, 80, 119–121]. For example, ENIGMA [2] introduces Interactive Agent Tools—a gdb-attached debugger and a persistent network client—that let an LM agent drive genuinely interactive utilities, reaching state-of-the-art results on 390 challenges across NYU CTF, Intercode-CTF, and CyBench. CYBER-ZERO [119] synthesises agent trajectories from public writeups via persona-driven simulation, CTFAGENT [121] uses a plan-and-execute pattern with adaptive problem decomposition, and CTFKnow [40] provides a 3,992-question benchmark measuring technical CTF knowledge.

Privilege escalation. Privilege escalation concerns actions taken after initial access to obtain higher-level permissions on the compromised host [32, 72, 95]. HACKINGBUDDYGPT [32] targets autonomous Linux escalation, and PERSES [95] tests whether small local models can achieve escalation results comparable to frontier models.

Table 14. Paper attribution for Application: Vulnerability repair & hardening

Year	Paper	Automated patch generation (6%)	Patch validation / verification (5%)	Code review / auditing (13%)	Code hardening (5%)	Security policy enforcement (4%)
2026	[68]					
	[59]					
	[60]					
	[75]					
	[47]					
	[112]	✓	✓			
	[72]					
	[121]					
	[119]					
	[30]					
	[32]					
	[94]					
	[104]					
	[118]					
	[116]					
	[1]			✓		
	[99]			✓		
	[69]					
2025	[44]					
	[34]			✓		
	[97]			✓		
	[46]					
	[113]			✓		
	[42]					
	[58]					
	[16]					
	[92]					
	[71]					
	[53]					
	[36]					
	[63]					
	[29]					
	[98]					
	[108]					
	[19]					
	[13]					
	[8]					
	[5]					
	[84]			✓		
	[77]			✓		
	[61]					
	[28]					
	[101]					
	[117]			✓		
	[91]					
	[41]					
	[54]				✓	✓
	[14]					
	[2]					
	[17]					
	[45]					
	[12]					
	[79]					
	[65]					
	[88]				✓	✓
	[26]	✓			✓	✓
	[69]					
	[80]					
	[70]					
	[64]					
	[35]					
	[4]					
	[102]					
	[81]				✓	
	[49]					
	[40]			✓		
	[83]					
	[62]					
	[110]	✓	✓		✓	
	[109]					
	[85]					
	[95]			✓		
	[11]		✓	✓		✓
	[51]					
	[18]	✓	✓			
	[10]			✓		
	[31]					
	[52]					
	[39]					
	[24]	✓	✓	✓		
	[76]					
	[48]					
2024	[37]					
	[20]					
	[15]					
	[66]					
	[57]					
	[3]					
	[120]					
	[111]					
	[106]					
	[74]	✓				
2023	[38]					
	[9]					
	[22]					
	[73]					
	[100]					
	[35]			✓		
	[23]			✓		
	[36]			✓		

Lateral movement. This refers to an attacker’s traversal across a network from one compromised host to others [18, 72]. Only two papers address this sub-task, both within broader end-to-end penetration-testing frameworks rather than as a dedicated capability.

Exfiltration simulation. Exfiltration simulation concerns the data-extraction phase of offensive operations [20, 72]. AGENTDOJO [20] includes data-exfiltration objectives among its adversarial tasks. The sparsity of work on lateral movement and exfiltration, and the absence of any paper addressing persistence, indicate that post-access phases remain substantially less developed than initial-access and reconnaissance capabilities.

6.3.4 Vulnerability repair & hardening. Agents in this category (Table 14) generate and validate patches and hardening modifications once a vulnerability has been identified [10, 14, 23, 26, 31, 36, 38, 41, 42, 49, 51, 61, 69, 76, 77, 83, 89, 97, 99, 109, 112]. Many of these papers also appear under vulnerability detection & analysis, reflecting a common detect-then-repair design.

Code review / auditing. Code review and auditing concern systematic inspection of code for security weaknesses, often combining automated detection with human-readable explanations [23, 31, 36, 41, 42, 51, 61, 69, 76, 77, 83, 97, 99]. This sub-task overlaps substantially with detection, since identifying a weakness and reasoning about how to remediate it are closely connected. The multi-agent code-review framework of [83] integrates review, bug detection, and security analysis with a FAISS-memory feedback mechanism, PROPERTYGPT [51] retrieves and adapts human-authored Certora properties to produce verifiable invariants, and VULNGPT [23] layers a controller-and-evaluator AutoGPT loop on top of GPT-4.

Automated patch generation. Automated patch generation concerns synthesising candidate fixes for identified vulnerabilities [10, 38, 76, 89, 109, 112]. For example, PATCHAGENT [109] integrates fault localisation, patch synthesis, and test-suite validation into a single autonomous loop, repairing over 90% of 178 real-world vulnerabilities and outperforming specialised program-repair tools. VULNPATCH [76] delegates detection, explanation, and patch generation to three fine-tuned LLM agents, REPAIRAGENT [10] interleaves test execution with fix synthesis, and BOUNTYBENCH [112] contributes the empirical finding that frontier agents are notably stronger at patching than at exploitation.

Patch validation / verification. Patch validation concerns checking whether a candidate fix actually resolves the targeted vulnerability without introducing new problems [10, 51, 76, 109, 112]. Validation typically involves running the test suite, checking formal properties, or executing candidates against proof-of-concept inputs. In PROPERTYGPT [51] verification is itself an iterative agentic loop: the agent generates smart-contract properties and then uses compilation, static analysis, and a prover to determine whether they are usable.

Code hardening. Code hardening concerns preventive or structural changes that reduce attack surface rather than targeting a specific vulnerability [14, 26, 49, 89, 109]. LLM2POLICY [14] generates fine-grained zero-trust policies from Kubernetes configurations, the IaC remediation agent of [89] issues policy-level recommendations for CI/CD pipelines, and the autonomous cloud agent of [26] includes hardening among its responsibilities.

Security policy enforcement. Security policy enforcement concerns generating and applying rules that constrain system behaviour to meet security requirements [14, 26, 51, 89]. LLM2POLICY [14] and the IaC agent of [89] generate and enforce infrastructure-level policies, while PROPERTYGPT [51] enforces formally-specified invariants as a policy layer over smart contracts.

6.3.5 Intrusion & threat detection, incident response. Agents for these applications (summarized in Table 15) detect active or recent compromises, attribute them to actors or techniques, and reconstruct attack chains to support remediation [1, 3–5, 11–13, 17, 19, 22, 24, 26, 31, 34, 35, 37, 39, 45, 53–57, 59, 63–65, 70, 71, 75, 84, 85, 89, 91, 102, 110, 111, 116]. It is tied

with vulnerability detection & analysis as the largest category in the taxonomy.

Log / traffic analysis & anomaly detection. This sub-task concerns reasoning over runtime telemetry—logs, alerts, network flows, and packet captures—to identify suspicious or anomalous patterns [5, 12, 17, 19, 24, 26, 34, 35, 37, 39, 54, 55, 57, 59, 65, 70, 71, 75, 84, 91, 110, 116]. For example, COGNITIVE SOC [84] deploys Triage, Enrichment, and StoryWeaver agents that transform raw alerts into structured narratives where every claim is linked to MITRE ATT&CK, Sigma, or CVE sources, achieving 99.6% evidence linkage on 1,000 UNSW-NB15 alerts. The memory-augmented agent of [75] provides IoT/IIoT anomaly detection with edge-optimised SHAP explanations, NETMONIAI [110] deploys micro-agents at each network node for local detection with central aggregation, and LAMA-SON [71] introduces a self-evolving framework for 6G space-air-ground integrated networks that updates its threat model as new attack types appear.

Incident response automation. Incident response automation concerns autonomous or semi-autonomous execution of defensive actions in response to detected threats [5, 17, 19, 24, 26, 39, 45, 53–55, 57, 64, 65, 84, 91, 110, 116]. Autonomous cyber-defence agents (ACDs) evaluated in CAGE-style reinforcement-learning environments form a substantial cluster [17, 45, 54, 55, 57, 65, 91]. The pure LLM-based ACD of [65] matches the strongest RL agent submitted to CAGE-2 without retraining; hybrid DRL+LLM architectures appear in [17, 54, 57]; and MARL+LLM blue/red training is explored

in [55]. SOC orchestration forms the second cluster [39, 53, 84]. AUTOBNB [53] compares centralised, decentralised, and hybrid agent team structures for incident response using the Backdoors & Breaches tabletop framework, and the agentic

Table 15. Paper attribution for Application: Intrusion & threat detection, incident response

Year	Paper	Log / traffic analysis & anomaly detection (22%)	DDoS detection & mitigation (3%)	Phishing & social-engineering detection (3%)	Alert triage (2%)	Threat hunting (1%)	Attack attribution (5%)	Incident investigation (13%)	Incident response automation (17%)	Forensic analysis (3%)
2026	[68]									
	[59]	✓								
	[60]									
	[75]	✓								
	[47]									
	[112]									
	[72]									
	[121]									
	[119]									
	[30]									
	[32]									
	[94]									
	[104]									
	[118]									
	[116]	✓	✓						✓	
	[1]			✓						
	[99]									
	[69]									
2025	[44]									
	[34]	✓		✓	✓					
	[97]									
	[46]									
	[113]									
	[42]									
	[58]									
	[16]									
	[92]									
	[71]	✓	✓							
	[53]									
	[36]									
	[63]						✓	✓	✓	
	[29]									
	[95]									
	[108]									
	[19]	✓					✓	✓	✓	✓
	[13]									
	[8]	✓								
	[5]	✓						✓	✓	✓
	[84]	✓								
	[77]									
	[61]									
	[28]									
	[101]									
	[117]									
	[91]	✓							✓	
	[41]									
	[54]	✓						✓	✓	
	[14]									
	[2]	✓								
	[17]	✓								
	[45]	✓	✓						✓	
	[12]									
	[79]	✓								
	[65]	✓							✓	
	[88]									
	[26]	✓							✓	
	[89]						✓			
	[80]									
	[70]	✓						✓	✓	
	[64]									
	[35]	✓							✓	
	[4]									
	[102]						✓	✓		
	[81]									
	[49]									
	[40]									
	[63]									
	[62]									
	[110]	✓							✓	
	[109]									
	[85]						✓			
	[95]			✓				✓		
	[11]									
	[51]									
	[18]									
	[10]									
	[31]									
	[52]	✓								
	[39]	✓			✓	✓		✓	✓	✓
	[24]									
	[76]									
	[48]									
2024	[37]	✓								
	[20]									
	[15]									
	[66]									
	[57]	✓						✓	✓	
	[5]									
	[120]									
	[111]									
	[106]									
	[74]									
2023	[98]									
	[9]									
	[22]									
	[73]							✓		
	[100]									
	[55]	✓							✓	
	[25]									
	[36]									

SOAR system of [39] replaces rigid no-code execution with LLM-driven orchestration that interprets natural-language playbook descriptions and branches dynamically on intermediate results.

Incident investigation. This task concerns the reconstruction of what happened during or after a security event, including timeline recovery, evidence assembly, and causal chain analysis [3–5, 11, 19, 22, 24, 31, 39, 53, 54, 56, 57, 70, 111]. CLOUSEAU [5] starts from a single point-of-interest and reconstructs attack chains without prior training or predefined heuristics, achieving an average F1 of 99.78% across 21 scenarios including DARPA OpTC and ATLAS APT cases. CFA-BENCH [19] provides a controlled benchmark for evaluating investigation capability, and the workflow of [24] automates first-stage triage using structured queries over Suricata logs.

Attack attribution. This task concerns linking observed attack evidence to a responsible actor, campaign, or technique [13, 19, 63, 85, 89, 102, 111]. MAD-AGENT [102] produces family-attribution reports via MCP-exposed threat-intelligence tools, and CFA-BENCH [19] benchmarks agent performance on attribution across controlled scenarios.

Forensic analysis. Forensic analysis concerns the systematic collection, preservation, and interpretation of digital evidence for post-incident use [5, 19, 24]. CFA-BENCH [19] provides a controlled forensic benchmark, CLOUSEAU [5] performs autonomous forensic investigation from a single seed event, and the alert-investigation workflow of [24] assembles structured evidence for analyst review.

DDoS detection & mitigation. This sub-task concerns identifying and responding to volumetric or protocol-level denial-of-service attacks [12, 71, 116]. LAMASON [71] addresses DDoS within its self-evolving 6G defence framework, the zero-trust SAGIN framework of [12] integrates detection into distributed network defence, and the proactive cloud defence of [116] combines anomaly detection with automated mitigation.

Phishing & social-engineering detection. This sub-task concerns detection of attacks that manipulate users through deceptive communications or counterfeit interfaces [1, 11, 34]. PHISHAGENT [11] combines online brand records with offline cached fingerprints and a multimodal

Table 16. Paper attribution for Application: Threat intelligence & security operations (SecOps)

Year	Paper	Threat intelligence synthesis (19%)	Vulnerability report generation (4%)	CVE / advisory drafting (2%)	Security policy generation (5%)	Security Q&A assistant (3%)	CTI analysis (8%)
2026	[68]	✓					✓
	[59]	✓					
	[60]						
	[75]						
	[47]						
	[112]						
	[72]						
	[122]						
	[119]						
	[30]						
	[32]						
	[94]						
	[104]						
	[118]						
	[116]	✓			✓		
	[1]						
	[99]						
	[69]						
2025	[44]	✓					✓
	[34]	✓	✓	✓			
	[97]						
	[46]						
	[113]						
	[42]	✓					✓
	[58]	✓					
	[16]						
	[92]	✓					
	[71]	✓					
	[53]	✓					✓
	[56]						
	[63]						
	[29]						
	[98]						
	[108]						
	[19]						
	[13]						
	[8]						
	[5]	✓					✓
	[84]	✓					
	[77]						
	[61]						
	[28]						
	[101]						
	[117]	✓					
	[91]	✓					
	[41]	✓					
	[54]	✓			✓	✓	✓
	[14]						
	[2]	✓					
	[17]	✓					
	[45]	✓					
	[12]	✓					
	[79]	✓				✓	
	[65]	✓	✓				
	[68]				✓		
	[26]				✓		
	[89]				✓		
	[80]						
	[79]						
	[64]						
	[35]						
	[4]	✓					✓
	[102]	✓					✓
	[81]						
	[49]						
	[40]						
	[83]						
	[62]						
	[110]						
	[109]						
	[85]						
	[95]						
	[11]						
	[51]						
	[18]				✓		
	[10]						
	[31]	✓					
	[52]						
	[39]		✓				
	[24]						
	[76]						
	[48]						
2024	[37]						
	[20]						
	[15]						
	[66]	✓				✓	
	[57]						
	[3]						
	[120]						
	[111]	✓	✓	✓			
	[106]						
	[74]						
2023	[38]						
	[9]						
	[22]						
	[73]						
	[100]						
	[55]	✓					
	[23]						
	[36]						

LLM to improve recall on novel brand-impersonation attacks, and TRUSTNET [1] uses a hybrid Random Forest and LLM-feature-characterisation pipeline for scam-website detection, reporting 96.94% accuracy.

Alert triage. This concerns the initial classification and prioritization of security alerts before deeper investigation [24, 34]. The cross-domain multi-agent of [34] correlates email-verification, log-analysis, and IP-scanning agents through a contextual-recommendation layer, achieving 93.6% detection accuracy, and the workflow of [24] automates first-stage triage over Suricata logs.

Threat hunting. This refers to proactive, hypothesis-driven searching for threats that evade automated detection [39]. The agentic SOAR system of [39] supports proactive hunting by autonomously orchestrating investigative playbooks over collected telemetry, representing one of the few genuinely proactive defensive capabilities in the surveyed corpus.

6.3.6 Threat intelligence & security operations (SecOps). Agents serving SecOps automate human-in-the-loop security workflows, including threat-intelligence ingestion, reporting, policy generation, and analyst support [12, 14, 17, 18, 26, 34, 52, 54–59, 65, 68, 71, 76, 79, 81, 84, 88, 89, 91, 97, 102, 111, 116], as summarized in Table 16.

Threat intelligence synthesis. Threat intelligence synthesis concerns the collection, correlation, and structuring of security information from heterogeneous sources such as advisories, dark-web material, system telemetry, and vulnerability reports [12, 17, 34, 52, 54–59, 65, 68, 71, 81, 84, 91, 102, 111, 116]. The cross-domain multi-agent of [34] correlates email-verification, log-analysis, and IP-scanning agents through a contextual-recommendation system, and the trustworthy multi-LLM network of [59] addresses collaborative reasoning under adversarial-host risks using blockchain-based audit trails and Byzantine Fault Tolerance consensus.

CTI analysis. CTI analysis concerns extracting indicators of compromise, threat-actor tactics, and attack-chain structures from textual and semi-structured intelligence sources [34, 54, 56, 58, 68, 81, 84, 102]. MAD-CTI [81] scrapes and classifies dark-web sources—hacker forums, breach announcements, advisory posts—for structured extraction, the CTI annotation system of [56] builds attack chains via cybersecurity knowledge graphs, and Loevenich et al. [54] construct knowledge graphs from network logs, CTI reports, and vulnerability frameworks to support autonomous cyber defence.

Security policy generation. Security policy generation concerns translating natural-language security objectives or system configurations into enforceable rules [14, 18, 26, 89, 116]. LLM2POLICY [14] generates zero-trust policies from Kubernetes configurations, the IaC agent of [89] issues policy-level recommendations, the autonomous cloud agent of [26] includes policy generation among its duties, and the proactive cloud defence of [116] translates objectives into firewall rules.

Vulnerability report generation. Vulnerability report generation concerns producing structured, human-readable reports from detection and analysis outputs [76, 88, 97, 111]. The VEX-justification agent of [111] automates CVE impact analysis in containerised environments via plan-and-execute LLM agents operating over SBOM, source, and documentation, representing one of the earliest end-to-end agentic vulnerability-management deployments.

Security Q&A assistant. Security Q&A assistants answer analyst or learner queries by drawing on knowledge graphs, documentation, prior incident records, or security curricula [54, 57, 79]. The system of [79] uses trace links and a multi-agent design to convert real vulnerability scan results into contextualised security learning materials, functioning as an interactive educational assistant.

CVE / advisory drafting. CVE and advisory drafting concerns producing formal advisories from detection and classification outputs [97, 111]. These agents complement report generation with an output format suitable for distribution through CVE or VEX channels.

6.3.7 Other (Lower-frequency) security domains. The remaining application areas [2, 4, 8, 13–15, 20, 30, 44, 46, 49, 60, 62, 66, 69, 92, 99, 102, 104, 113] each account for a small share of the corpus and are consolidated into a single taxonomy table (Table 17). They nonetheless indicate the breadth of emerging agentic security applications beyond the dominant vulnerability-analysis and offensive-security workflows.

Model attack generation & robustness evaluation. This category concerns generating adversarial inputs against learned models and evaluating their robustness [8, 15, 20, 30, 46, 49, 66, 69, 104, 113]. Jailbreak generation and prompt injection generation / detection are addressed by the same four papers [20, 69, 104, 113]. AGENTDojo [20] provides a dynamic environment for evaluating prompt-injection attacks and defences, AGENT SECURITY BENCH [113] formalises attacks and defences across 10 scenarios and 10 agents, and REDAGENT [104] is an autonomous context-aware red-teamer that jailbreaks deployed LLM applications within five queries. Agent safety & guardrail evaluation is the most represented sub-task here [8, 15, 20, 49, 69, 104, 113]. ZT-ICAS [69] proposes zero-trust defence with input neutralisation and capability-bounded tool invocation, and the deception framework of [8] exploits LLM biases and tokenisation quirks to cloak assets and lure attacking agents. Adversarial example generation against ML/LLM components covers attacks on non-agent learned models [15, 30, 46, 66, 113]. AGENTPOISON [15] demonstrates that poisoning a retrieval knowledge base compromises downstream behaviour, CHEATAGENT [66] constructs black-box adversarial perturbations in user-recommender dialogues, and AGENTSA [30] deploys LLM user-agents with coherent fake personas for training-time shilling attacks.

Fuzzing & test generation. This category concerns generating test inputs that drive programs toward unexpected or security-relevant states [14, 44, 49, 60, 62, 99]. Test case generation for security properties is the dominant sub-task [44, 49, 60, 62, 99]: CONCOLLMic [60] uses an LLM agent as a symboliser and natural-language constraint reasoner for concolic execution,

achieving 115–233% higher coverage than KLEE across twelve real-world subjects, and MULTIFuzz [62] couples dense retrieval over protocol RFCs with multi-agent decomposition for network-protocol fuzzing. Smart seed mutation appears in [49, 62], symbolic execution guidance in CONCOLLMic [60], and crash triage & deduplication in [14]. The absence of

Table 17. Paper attribution for Application: other domains

Year	Paper	Fuzzing & test generation (5%)	Malware analysis & detection (2%)	Reverse engineering (5%)	Access control & authentication assessment (1%)	Model attack generation & robustness evaluation (10%)
2026	[68]					
	[59]					
	[60]	✓				
	[75]					
	[47]					
	[112]					
	[72]					
	[121]					
	[119]					
	[30]					✓
	[32]					
	[94]					
	[104]					✓
	[118]					
	[116]					
	[11]	✓		✓		
	[99]					✓
	[69]					
	[64]	✓				
	[54]					
2025	[97]					
	[46]		✓			✓
	[113]					✓
	[42]					
	[58]					
	[16]					
	[92]			✓		
	[71]					
	[53]					
	[56]					
	[63]					
	[29]					
	[98]					
	[108]					
	[19]			✓		
	[13]					✓
	[8]					
	[5]					
	[84]					
	[77]					
	[61]					
	[28]					
	[101]					
	[117]					
	[91]					
	[41]					
	[54]				✓	
	[14]					
	[2]			✓		
	[17]					
	[45]					
	[12]					
	[79]					
	[65]					
	[88]					
	[26]					
	[89]					
	[50]					
	[70]					
	[64]					
	[35]			✓		
	[4]		✓	✓		
	[102]					
	[81]	✓				✓
	[49]					
	[40]					
	[83]					
	[62]	✓				
	[110]					
	[109]					
	[85]					
	[95]					
	[11]					
	[51]					
	[18]					
	[10]					
	[31]					
	[52]					
	[39]					
	[24]					
	[76]					
	[48]					
2024	[37]					
	[20]					✓
	[15]					✓
	[66]					
	[57]					
	[3]					
	[120]					
	[111]					
	[106]					
	[74]					
2023	[38]					
	[9]					
	[22]					
	[73]					
	[100]					
	[55]					
	[23]					
	[56]					

work on fuzzing harness generation, seed input generation, and coverage-guided orchestration indicates that agents are currently applied to the reasoning-heavy parts of fuzzing rather than its infrastructure.

Reverse engineering. This category concerns recovering structure and semantics from compiled artifacts or undocumented protocols [2, 4, 13, 92, 99]. Disassembly & decompilation is addressed by three papers [2, 4, 13]: CLEARAGENT [13] exposes both an analyzer-friendly intermediate representation and an LLM-friendly natural-language view of a binary, letting the agent form vulnerability hypotheses linguistically and verify them by constructing concrete triggering inputs, and ENIGMA [2] supports binary reverse engineering through Interactive Agent Tools in CTF settings. Protocol reverse engineering appears in [92, 99], where FLOWFSM [92] uses prompt chaining to extract finite-state machines from RFC documents with reduced hallucinated transitions. Variable & type recovery is addressed only by CLEARAGENT [13].

Malware analysis & detection. This category concerns the analysis and classification of malicious software [46, 102]. Malware detection is addressed by both papers [46, 102], while malware classification / family attribution and malware behavior analysis appear only in MAD-AGENT [102], which orchestrates static analysis, dynamic sandbox analysis, and threat intelligence through MCP-exposed tools. Anti-malware evasion analysis is addressed by LAMLAD [46], which uses a dual-agent manipulator/analyzer loop to perturb malicious Android APKs while preserving functionality, achieving a 97% attack success rate in an average of three queries. The absence of work on obfuscation detection and malware generation marks this as the least developed area in the corpus.

Access control & authentication assessment. This category concerns evaluating whether access-control and authentication mechanisms are correctly specified and enforced [14]. LLM2POLICY [14] is the sole representative, contributing to both firewall / ACL policy analysis and access control policy generation / enforcement by extracting microservice entity information from Kubernetes manifests and generating fine-grained zero-trust access policies. The absence of any work on authentication or authorization testing indicates that this domain remains largely untouched by agentic approaches.

6.4 Survey Result: Assessment

6.4.1 Metric. An assessment metric is an observable measure used to judge an agent’s outcome, trajectory, safety, or comparative advantage. We organize the reported measures into four attributes: task effectiveness, agentic process/trajectory, safety/reliability, and comparative/baseline evidence.

The tables use non-exclusive coding: a paper receives every attribute directly supported by its assessment, so percentages within a table need not sum to 100%. We audited the full text of every paper with a blank row and retained a blank only when the paper reports no measure in that table’s scope; the blank therefore means *unspecified for that attribute*, not that the paper lacks an assessment altogether. After this audit, six task-effectiveness rows remain blank: four safety-focused studies [15, 69, 104, 113], Cognitive SOC’s process/report assessment [84], and an attack-chain demonstration without a formal outcome metric [58]. Twenty-nine process rows remain blank because those papers report outcomes without a trajectory measure, 70 safety rows remain blank because the papers do not assess the agent’s boundedness or adversarial reliability, and four comparative rows remain blank for the specific reasons given below.

Task Effectiveness. Task effectiveness is the outcome-level attribute that measures whether an agent accomplishes its intended security task, such as finding a vulnerability, completing an exploit, producing a valid patch, classifying an alert, or preserving service availability. As shown in Table 18, the surveyed papers use ten task-metric families. Unlike process-oriented metrics, these measures judge the result rather than how the agent reasoned or used tools.

Accuracy and classification. Accuracy-oriented metrics are used when the agent’s output can be judged against a discrete label, verdict, class, or action. This family includes top-*k* accuracy and CWE classification for vulnerability

tasks, intrusion or log-detection accuracy, malware detection and family classification, web/ phishing/scam classification accuracy, property or exploitability verification accuracy, response-action accuracy, asset-search accuracy, and investigation verdict accuracy. Such metrics appear in papers on vulnerability detection, malware analysis, phishing/scam detection, incident response, cloud operations, asset discovery, command generation, forensics, CTF knowledge, and CTI extraction [1, 5, 11, 12, 14, 16, 19, 24, 26, 36, 39–41, 46, 48, 49, 52, 53, 70, 71, 81, 102, 111]. For example, Trust-Net [1] assesses a hybrid machine-learning and multi-agent LLM detector for scam websites with the standard classification suite of accuracy, precision, recall, and F1, reporting that the LLM-agent team improves over the Random Forest baseline on the labeled scam-detection task. In a different setting, MAD-Agent [102] treats malware analysis as a combination of malware detection, behavior classification, family attribution, and report generation, so task effectiveness is assessed not only by whether the sample is detected but also by whether the agent assigns the right behavioral interpretation.

Table 18. Paper attribution for Assessment: Task effectiveness metric families

Year	Paper	Accuracy/ classification (23%)	Precision/ recall/F1 (34%)	Error rates (12%)	Success/ completion (51%)	Findings/ yield (7%)	Correctness/ validity (8%)	Coverage (10%)	Time/ responsiveness (25%)	Availability/ reward (7%)	Qualitative/ user assess. (5%)
2026	[68]		✓		✓				✓		
	[59]				✓			✓	✓		
	[60]		✓	✓					✓		
	[75]		✓		✓						
	[47]				✓		✓				
	[112]				✓						
	[72]				✓						
	[121]				✓	✓					
	[119]				✓						
	[30]			✓	✓				✓		
	[32]				✓						
	[94]				✓						
	[104]				✓						
	[118]				✓				✓		
	[116]	✓	✓				✓	✓			
2025	[1]										
	[99]										
	[69]										
	[44]		✓	✓				✓			
	[34]		✓						✓		
	[97]										
	[46]	✓									
	[113]		✓								
	[42]										
	[58]										
	[16]	✓	✓		✓						
	[92]		✓		✓						
	[71]	✓			✓						
	[53]		✓				✓				
	[56]										
	[63]				✓						
	[29]				✓						
	[98]				✓						
	[108]		✓								
	[19]	✓			✓						
	[13]				✓						
	[8]	✓									
	[84]		✓						✓		
	[77]										
	[61]		✓								
	[28]				✓						
	[101]				✓				✓		
	[117]				✓						
	[91]									✓	
	[41]	✓	✓		✓					✓	
	[54]		✓		✓				✓		
	[14]	✓		✓	✓	✓	✓	✓	✓		
	[2]		✓		✓			✓		✓	
	[17]				✓				✓		
	[45]				✓					✓	
	[12]	✓			✓				✓		✓
	[79]				✓						
	[65]				✓					✓	
	[85]				✓						
	[26]	✓			✓				✓		
	[89]		✓		✓			✓			
	[80]				✓						
	[70]	✓	✓		✓						
	[64]		✓		✓						
	[35]		✓		✓						
	[4]				✓			✓			
	[102]	✓	✓			✓		✓	✓		✓
	[81]	✓	✓					✓			
	[49]	✓	✓			✓		✓			
	[40]	✓	✓					✓			
	[83]		✓				✓	✓			
	[62]						✓	✓			
	[110]										
	[109]			✓	✓		✓	✓	✓		
	[85]				✓			✓			
	[95]				✓			✓			
	[11]	✓		✓		✓					
	[51]		✓								
	[18]				✓		✓				✓
	[10]										
	[31]		✓								
	[52]	✓	✓						✓		
	[39]	✓									
	[24]	✓	✓	✓	✓		✓				
	[76]		✓	✓							
	[48]			✓							
2024	[37]		✓	✓	✓						
	[20]				✓						
	[15]				✓						
	[66]				✓					✓	
	[57]				✓						
	[3]				✓						
	[120]	✓	✓			✓		✓			
	[114]		✓								
	[106]				✓						
	[74]				✓						
2023	[38]		✓		✓						
	[9]				✓						✓
	[22]				✓						
	[75]				✓						
	[100]				✓						
	[35]			✓							
	[23]		✓	✓						✓	
	[36]	✓	✓	✓							

Precision, recall, and F1. Precision, recall, and F1 are the dominant metrics for detection-style tasks, especially vulnerability detection and classification, intrusion detection, malware or phishing detection, property generation, repository auditing, state-machine extraction, and CTI analysis [1, 17, 23, 24, 31, 34–38, 41, 42, 47–49, 51, 52, 54, 56, 61, 68, 70, 75–77, 81, 83, 89, 92, 97, 102, 106, 108, 111]. These metrics are useful when false alarms and missed findings

have different operational costs: precision reflects whether reported findings are trustworthy, while recall or detection rate reflects whether important security issues are being missed. Agent4Vul [42], for instance, assesses a multi-agent smart-contract vulnerability detector on more than 40,000 contracts and reports F1 improvements over 19 baselines across four vulnerability types. PropertyGPT [51] illustrates the same family in formal-verification settings: it assesses generated smart-contract properties using precision and recall against ground-truth properties, and further reports how many known CVEs and attack incidents are detected from the generated specifications.

Error rates. Error-rate metrics provide the complementary view of task effectiveness by measuring how often the agent is wrong. Papers in this group report false-positive rate, false-negative rate, RMSE/MAE, or related error rates in vulnerability detection, intrusion detection, recommender-system attacks, access-policy generation, and web-security classification [11, 14, 23, 24, 30, 34, 36, 37, 48, 55, 75, 109]. These metrics matter because some agentic systems are intended for analyst-facing use: a high false-positive rate can overload analysts, while a high false-negative rate can make an autonomous detector unsafe to rely on. For example, vulnerability-detection papers that report false positives make clear whether an agent is merely increasing the number of warnings or actually improving the quality of surfaced findings; web and intrusion-detection papers similarly use FP/FN rates to expose the tradeoff between aggressive detection and operational noise.

Success and completion. Success and completion metrics are the largest task-effectiveness family. They are used when a security task has an executable or benchmark-defined endpoint, such as exploit or attack success, CTF or penetration-testing completion, patch success, test passing, remediation completion, or successful policy enforcement [2–4, 8–10, 12–14, 16–18, 20, 22, 26, 28–30, 32, 38, 45, 54, 55, 57, 59, 63–66, 71–74, 76, 80, 85, 88, 89, 91, 94, 95, 98, 100, 101, 109, 112, 116–118, 120, 121]. In offensive settings, success typically means that the agent compromises the target, captures the flag, reaches the vulnerable state, executes a proof-of-concept exploit, or achieves a defined adversarial objective. CVE-Bench [117] is a representative example: it assesses agents against real-world critical-severity CVEs in sandboxed web applications and scores whether the agent can complete exploitation against a reference target. BountyBench [112] broadens the idea by assessing detect, exploit, and patch tasks over real bug-bounty issues, so completion is measured separately for recognizing the bug, weaponizing it, and repairing it. In repair settings, success is instead tied to whether the generated patch applies, passes tests, and fixes the vulnerability; RepairAgent [10] follows this pattern by validating autonomous patches on Defects4J bugs and reporting repaired-bug counts as the primary task outcome.

Findings and yield. Finding-yield metrics count the security artifacts produced by an agent: valid bugs, confirmed vulnerabilities, captured flags, CVEs, exploit chains, or bounty-relevant findings. This family appears in work on penetration testing, exploit generation, formal verification, vulnerability discovery, and security education or challenge environments [2, 4, 40, 51, 119–121]. These metrics are most informative when the task is exploratory and the target set is not naturally reduced to a single label. For example, PropertyGPT [51] reports not only precision and recall for generated formal properties, but also the number of known CVEs, historical attack incidents, and zero-day bugs surfaced by the agent-generated properties. This makes the assessment more security-relevant than a pure classification score, because it connects property generation to concrete vulnerability discovery.

Correctness and validity. Correctness and validity metrics ask whether the produced artifact is semantically acceptable, executable, or security-relevant. This family includes exploitability-verification accuracy, attack-chain correctness, policy exact match, patch correctness, test-pass or regression-preservation metrics, valid-test ratios, and other validity checks for generated outputs [10, 14, 56, 62, 76, 99, 109, 112]. These metrics are especially important for agentic systems that generate executable artifacts, because a plausible-looking exploit, test case, policy, or patch can still be invalid. MultiFuzz [62], for instance, assesses generated protocol-fuzzing inputs in terms of their ability to exercise valid protocol

behavior and reach meaningful states rather than merely producing syntactically varied messages. RepairAgent [10] similarly uses patch validation through compilation and tests, making the metric about whether the agent’s edit actually repairs the program rather than whether the proposed fix appears reasonable in natural language.

Coverage. Coverage metrics measure how much of the target space the agent explores. The surveyed papers use code coverage, branch coverage, protocol-state or transition coverage, challenge-category coverage, human-expert comparison, and other exploration-oriented measures [2, 4, 40, 44, 49, 60, 62, 80, 99, 120]. This family is common in fuzzing, testing, exploit exploration, and benchmark design, where a single success outcome can hide shallow exploration. MultiFuzz [62] provides a clear example: it assesses whether a retrieval-augmented multi-agent fuzzer covers more branches and protocol states than baselines such as NSFuzz, AFLNet, and ChatAFL. In penetration-testing and challenge settings, category coverage serves a related role by showing whether the agent can handle diverse vulnerability classes rather than overfitting to one familiar exploit pattern.

Time and responsiveness. Time-oriented task metrics measure whether the agent completes a security task quickly enough for operational use. Papers in this family report response time, latency, mean time to respond or remediate, report-generation time, exploit time, and asset-discovery speed [11, 12, 14, 17, 26, 32, 34, 39, 49, 52, 59, 60, 75, 77, 83, 85, 89, 95, 97, 101, 102, 109, 110, 116, 120]. These metrics are particularly relevant for incident response, SOC automation, cloud operations, malware analysis, network monitoring, vulnerability analysis, and penetration testing, where a technically correct response may still be ineffective if it arrives too late. For example, the cloud-automation agent in [26] assesses mean time to respond and remediation latency alongside accuracy and policy-adherence metrics, reflecting the operational requirement that an autonomous cloud-security agent detect an anomalous event, select an action, and apply mitigation promptly. Similarly, MAD-Agent [102] reports the end-to-end time needed for tool use, reasoning, and report generation, while NetMoniAI [110] measures detection latency under degraded links and multi-node simulations.

Availability and reward. These metrics appear when security effectiveness is measured by the state of an environment rather than by a single prediction or generated artifact. They include cumulative reward, mission or service availability, and defender-performance scores in cyber-defense simulations and network-security games [17, 45, 54, 55, 57, 65, 91]. These metrics are useful for defensive agents because the correct action is often not simply to block every suspicious event; the agent must also preserve normal service. For example, the CAGE-2 cyber-defense study [65] assesses LLM-based defenders by balancing attacker disruption against network functionality, which makes task effectiveness a joint measure of security control and operational continuity. Other simulation-based defender studies similarly use reward signals to capture whether the agent’s sequence of actions improves the environment state over time.

Qualitative and user assessment. Some papers assess task effectiveness with expert judgments, user ratings, report-quality assessments, or learning-gain measures [9, 18, 22, 79, 102]. These metrics are used when the output is difficult to reduce to a single executable success condition, such as a security report, educational artifact, analyst-facing explanation, or interactive penetration-testing support. For example, MAD-Agent [102] includes report generation quality as part of malware-analysis effectiveness, because a malware analyst needs a coherent account of observed behavior and threat indicators rather than only a binary malicious/benign label. PentestGPT [22] is another example: because the system is designed for interactive penetration-testing assistance, user-facing usefulness and human assessment complement task-completion metrics by capturing whether the agent’s reasoning and recommendations are practically helpful.

Agentic process / trajectory. Agentic process and trajectory is the attribute that assesses the path by which an agent reaches an outcome, including its steps, tool calls, hallucinations, resource use, iterations, intermediate artifacts, explanations, and economic value. These metrics are particularly important because many security tasks are long-horizon, tool-mediated, and partially observable. A final success or failure score does not reveal whether the agent used

tools correctly, fabricated evidence, wasted iterations, produced a weak intermediate artifact, or generated an auditable explanation. Table 19 groups these process metrics into eight families.

Steps to completion. Step-based metrics measure how many actions, subtasks, commands, or reasoning steps an agent needs before reaching a task endpoint. They appear in penetration testing, software testing, cyber-defense, vulnerability repair, fuzzing, and agent-security benchmarks [2, 10, 19, 20, 28, 29, 32, 40, 64, 73, 74, 88, 91, 94, 98, 100, 101, 104, 108, 113, 116]. These metrics are useful because two agents with the same final success rate may differ substantially in operational efficiency and risk exposure: a shorter trajectory may reduce cost and attack surface, while an excessively short trajectory may indicate shallow exploration. AgentDojo [20], for example, assesses agents in stateful tool-calling tasks under adversarial data, where progress through the environment matters because prompt injection can alter not only the answer but also the sequence of tool calls. The privilege-escalation study of [32] similarly records command counts and contrasts the trajectories of autonomous agents with professional penetration testers.

Tool-call accuracy. Tool-call accuracy measures whether the agent invokes the right tool, target, or environment operation for the current task state. This metric is currently rare in the surveyed literature, with CVE-Bench [117] explicitly foregrounding the need to assess agents that interact with sandboxed web applications and execute attacks against concrete targets. The rarity is notable: many security agents are advertised as tool-using systems, but most assessments score only the final result. Tool-call accuracy gives a more diagnostic signal by distinguishing reasoning failure from execution failure, such as choosing an irrelevant scanner, issuing a malformed command, or interacting with the wrong component of a web application.

Hallucination rate. Hallucination metrics measure unsupported claims, fabricated evidence, invalid vulnerability explanations, or inconsistent security reasoning in the agent trajectory. They are used in vulnerability analysis, red teaming, SOC narrative generation, fuzzing, repository auditing, and repair [16, 18, 31, 40, 41, 59, 62, 68, 72, 76, 84]. This family is central for security agents because a hallucinated finding can become a false alarm, an unsafe patch, or an incorrect incident narrative. Cognitive SOC [84]

Table 19. Paper attribution for Assessment: Agentic process / trajectory metrics

Year	Paper	Steps to completion (21%)	Tool call accuracy (1%)	Hallucination rate (11%)	Cost / token efficiency (32%)	Iteration count (10%)	Artifact correctness (3%)	Report / explanation (11%)	Economic /bounty value (2%)
2026	[68]			✓	✓				
	[99]				✓				
	[60]				✓				
	[75]				✓		✓		
	[47]								
	[112]								✓
	[121]			✓		✓			
	[119]				✓				
	[30]	✓			✓				
	[32]	✓			✓				
	[94]	✓							
	[104]	✓							
	[118]	✓			✓				
	[116]								
	[1]								
2025	[99]				✓				
	[69]								
	[44]								
	[34]				✓	✓			
	[97]								
	[46]	✓							
	[113]								
	[42]								
	[58]			✓					
	[16]						✓		
	[92]								
	[21]							✓	
	[53]								
	[56]				✓		✓		
	[63]	✓				✓			
	[89]	✓				✓			
	[98]	✓				✓			
	[108]	✓				✓			
	[19]	✓							
	[43]								
	[8]								
	[5]							✓	
	[84]			✓	✓				
	[77]				✓				
	[61]				✓				
	[28]	✓							
	[101]	✓			✓				
	[117]	✓	✓						
	[91]	✓				✓			
	[41]	✓		✓					
	[54]							✓	
	[14]				✓				
	[72]	✓			✓				
	[17]							✓	
	[45]							✓	
	[12]				✓				
	[79]							✓	
	[65]								
	[88]	✓							
	[26]				✓				
	[89]				✓				
	[80]				✓				
	[70]				✓				
	[64]	✓							
	[85]								
	[14]								
	[102]				✓				
	[81]				✓			✓	
	[49]				✓				
	[40]	✓		✓		✓			
	[83]			✓	✓				
	[62]			✓	✓				
	[110]				✓				
	[109]				✓				
	[85]				✓				
	[95]				✓	✓			
	[11]				✓				
	[51]								✓
	[18]			✓					
	[10]	✓			✓	✓			
	[31]			✓	✓				
	[32]								
	[39]							✓	
	[24]							✓	
	[76]			✓					
	[48]								
2024	[37]	✓							
	[20]								
	[15]								
	[66]								
	[57]								
	[3]				✓				
	[120]							✓	
	[111]								
	[106]	✓							
	[74]				✓				
2023	[38]				✓				
	[9]				✓				
	[22]								
	[73]	✓				✓			
	[100]								
	[55]								
	[23]								

is a clear example: it assesses evidence-backed security narratives with evidence linkage, citation coverage, and hallucination rate, reporting a 0.1% hallucination rate on 1,000 alerts while producing citation-backed narratives. RepoAudit [31] attacks the same problem in repository-level auditing by adding a validator that checks data-flow facts and path-condition satisfiability before bug reports are accepted, thereby treating hallucination mitigation as part of the agent trajectory.

Cost and token efficiency. Cost and token-efficiency metrics measure the resource burden of running an agent, including token usage, wall-clock time, monetary cost, and assessment-time reductions. Papers in this family study trajectory synthesis, CTF solving, SOC automation, cloud operations, edge deployment, malware analysis, repository auditing, program repair, fuzzing, and penetration testing [2, 10–12, 14, 22, 26, 31, 32, 38, 49, 59, 60, 63, 69, 70, 75, 77, 83–85, 89, 95, 97, 101, 102, 109, 110, 118–121]. These metrics matter because many security workflows operate over large codebases, long logs, interactive targets, or repeated benchmark trials. CTFAgent [121], for example, reports interaction rounds, token volumes, and monetary cost per solved challenge, while the privilege-escalation study of [32] reports token and dollar cost per exploited machine. RepoAudit [31] gives a complementary repository-scale example, reporting an average of 0.44 hours and \$2.54 per project while auditing real-world codebases.

Iteration count. Iteration-count metrics capture how many revise-act-observe cycles, conversational turns, rounds, or repeated attempts the agent needs. They appear in multi-step vulnerability workflows, cyber-defense simulation, exploit or CTF tasks, program repair, and agent orchestration studies [10, 19, 29, 40, 91, 95, 97, 98, 100, 121]. Iteration counts are useful when the agent’s main advantage is adaptivity: the assessment should show whether repeated interaction actually helps or whether the agent is looping unproductively. RepairAgent [10] is representative because the agent must propose a patch, validate it, and use test feedback to revise the candidate; the number of iterations is therefore tied to both efficiency and the quality of feedback use. In offensive or challenge environments, the same metric distinguishes agents that converge on a viable exploit path from agents that repeatedly explore irrelevant actions.

Artifact correctness. Artifact-correctness metrics assess intermediate or final artifacts produced by the trajectory, such as generated tests, exploits, prompts, proofs, or analysis artifacts [47, 56, 92]. This family differs from task success because it asks whether a generated artifact is itself well-formed, executable, or semantically faithful, even before measuring the downstream security outcome. For agentic systems, this is an important diagnostic layer: an exploit attempt can fail because the target is not vulnerable, or because the generated artifact is invalid; a test can fail because it reveals a bug, or because it is malformed. Artifact-correctness metrics help separate these cases.

Report and explanation. Report and explanation metrics assess whether the agent’s output is traceable, complete, understandable, and useful for security practitioners. These metrics appear in papers on SOC automation, incident response, vulnerability reporting, security education, cloud operations, cyber-defense analysis, and auditing [5, 17, 39, 45, 53, 54, 76, 79, 81, 84, 111]. Cognitive SOC [84] is again illustrative because it treats evidence-backed narrative generation as the core output: the assessment measures evidence linkage and citation coverage, not only classification. In SOAR-style systems [39], explanation quality is similarly tied to operational usefulness, because analysts need to understand why an investigation verdict or response recommendation is justified before acting on it.

Economic and bounty value. Economic metrics map security outcomes to monetary value, which can make benchmark progress more interpretable for real-world vulnerability workflows. They are reported by BountyBench [112] and PropertyGPT [51]. BountyBench assesses agents over real-world bug-bounty systems and reports not only detect, exploit, and patch success rates, but also dollar-valued outcomes derived from bounty awards; PropertyGPT reports that a previously unknown bug found through its generated properties received an \$8,256 bounty. This metric is useful

because two vulnerabilities with the same binary success label may differ substantially in practical impact; dollar value provides a coarse but concrete proxy for the economic importance of agent-discovered or agent-repaired vulnerabilities.

Safety & reliability. Safety and reliability is the attribute that measures whether the agent remains bounded and dependable under adversarial inputs, repeated execution, prompt injection, poisoned memory, or constrained operational settings. This group treats the agent itself as part of the security boundary. As Table 20 shows, seven metric families cover containment, robustness, consistency, attack success, defense effectiveness, utility tradeoffs, and overhead.

Scope containment. Scope-containment metrics ask if the agent stays within authorized goals, tools, data access, and execution boundaries. They appear in work on jailbreak red teaming, zero-trust vulnerability scanning, executable exploit benchmarks, prompt-injection-aware agents, and constrained security workflows [12, 69, 104, 113, 117]. These metrics are important because security agents often interact with code, logs, metadata, web applications, or external tools that may contain adversarial instructions. ZT-ICAS [69] is a direct example: it designs agentic vulnerability scanning around semantic input neutralization, ephemeral context sharding, and capability-bounded tool invocation, then assesses whether those constraints preserve analysis integrity when code comments or dependency metadata are adversarially manipulated. CVE-Bench [117] complements this defensive view by recording whether an exploiting agent takes actions outside the authorized target scope.

Prompt-injection robustness. Prompt-injection robustness measures whether the agent resists malicious instructions embedded in data, tool outputs, retrieved documents, code comments, or environment state. It is assessed in prompt-injection benchmarks, context-aware red teaming, agentic scanners, and other tool-using security systems [11, 20, 49, 69, 104, 113]. AgentDojo [20] is a useful benchmark example because it assesses agents that execute tools over untrusted data with 97 realistic tasks and 629 security test cases. Its design makes robustness observable through both utility checks and attacker-goal checks over

Table 20. Paper attribution for Assessment: Safety & reliability metrics

Year	Paper	Scope containment (5%)	Prompt injection robustness (6%)	Consistency (18%)	Attack success rate (ASR) (10%)	Defense success (8%)	Utility-security tradeoff (4%)	Overhead (3%)
2026	[68]							
	[59]							
	[60]							
	[75]			✓				
	[47]							
	[112]							
	[72]							
	[121]							
	[119]			✓				
	[30]							
	[32]							
	[94]			✓				
	[104]	✓	✓		✓			
	[118]							
	[116]							
2025	[11]							
	[99]			✓				
	[69]	✓	✓		✓	✓	✓	✓
	[44]							
	[34]							
	[97]			✓				
	[46]	✓	✓		✓	✓	✓	
	[113]							
	[42]							
	[58]							
	[16]							
	[92]							
	[71]							
	[53]							
	[56]							
	[63]							
	[29]							
	[98]							
	[108]							
	[19]			✓				
	[13]							
	[8]				✓	✓		✓
	[5]							
	[84]							
	[77]			✓				
	[61]			✓				
	[28]							
	[101]	✓						
	[117]							
	[91]							
	[41]							
	[54]							
	[14]							
	[2]							
	[17]			✓				
	[45]	✓				✓		
	[12]							
	[79]							
	[65]			✓				
	[88]			✓				
	[26]			✓				
	[89]							
	[80]							
	[70]							
	[64]							
	[35]							
	[4]							
	[102]							
	[81]		✓	✓	✓			
	[49]							
	[40]							
	[83]							
	[62]							
	[110]			✓				
	[109]							
	[85]			✓				
	[95]		✓					
	[11]							
	[51]							
	[18]							
	[10]							
	[31]							
	[52]							
	[59]							
	[24]			✓				
	[76]							
	[48]							
2024	[37]		✓		✓	✓	✓	
	[20]				✓			
	[15]				✓			
	[66]							
	[57]							
	[3]							
	[120]							
	[111]			✓				
	[106]							
	[74]							
2023	[38]							
	[9]							
	[22]							
	[73]							
	[100]				✓	✓		✓
	[53]			✓				
	[23]							

the environment state. ZT-ICAS [69] addresses the same risk in code-security settings, where adversarial comments and poisoned metadata can manipulate the scanner’s reasoning.

Consistency. Consistency metrics assess whether repeated runs, alternative prompts, inference budgets, or model configurations produce stable security conclusions. Papers in this family apply repeated-run or variance analysis to vulnerability detection, cyber defense, cloud automation, remediation, network monitoring, penetration testing, and prompt-injection-robust workflows [17, 19, 23, 24, 26, 47, 49, 61, 65, 77, 89, 94, 95, 97, 99, 110, 111, 119]. Consistency is a reliability concern because security users need to know whether a finding is robust or merely an artifact of stochastic generation. VulnGPT [23], for example, repeats identical vulnerability queries, documents non-deterministic findings, and assesses whether a self-reflection step changes those conclusions. PTFusion [94] instead uses a reasoning-similarity score across runs, while NetMoniAI [110] reports stable sub-five-second latency over repeated tests.

Attack success rate. Attack success rate (ASR) is used when the assessment is adversarial: the metric measures how often an attack against the agent, model, recommender, or agent-mediated system succeeds. This family includes jailbreaks, prompt injection, memory/RAG poisoning, adversarial training data, recommender manipulation, and agent red-teaming studies [8, 15, 20, 46, 49, 55, 66, 69, 104, 113]. RedAgent [104] assesses context-aware jailbreak generation and reports that context-specific attacks substantially improve ASR against customized LLM applications. AgentPoison [15] studies a different attack surface: it poisons long-term memory or RAG knowledge bases so triggered queries retrieve malicious demonstrations, reporting high retrieval and end-to-end attack success with very low poisoning rates. Together these papers show why ASR is essential for agentic security assessment: attacks can target the prompt, context, memory, retrieval layer, training data, recommendation dialogue, or tool-mediated action path.

Defense success. Defense-success metrics measure whether a mitigation reduces adversarial compromise while preserving useful behavior. They appear in papers that assess defenses against jailbreaks, prompt injection, memory poisoning, poisoned samples or training data, and unsafe agent actions [8, 12, 15, 20, 46, 55, 69, 113]. AgentDojo [20] provides a concrete example by comparing attacks and defenses over stateful tool-calling tasks; in its initial environment, deploying existing prompt-injection defenses reduces attack success but does not eliminate the broader utility-security tension. AgentPoison [15] assesses its attack under perplexity filtering and query rephrasing, while LLM-SA [12] measures how accurately its analysis remains under poisoning and the ACD-training study [55] defines poisoned-data and backdoor-trigger detection rates for defensive training pipelines.

Utility-security tradeoff. Utility-security tradeoff metrics assess whether robustness gains come at the cost of task completion or user utility. This family is currently small but important [15, 20, 69, 113]. AgentDojo [20] explicitly motivates this tradeoff by assessing both user-task utility and attacker-goal success over the same environment state. AgentPoison [15] measures benign accuracy alongside attack success, and ZT-ICAS [69] uses a utility-resilience test that penalizes over-defensive behavior. These are stronger assessment patterns than reporting defense success alone: an overly restrictive defense can appear secure simply because the agent stops doing useful work.

Overhead. Overhead metrics measure the added cost of safety mechanisms, such as latency, compute, token usage, or reduced throughput [8, 55, 69]. These metrics are necessary because safety constraints are unlikely to be adopted in operational security workflows if they impose prohibitive delay or cost. ZT-ICAS [69], for example, reports that its zero-trust constraints reduce analysis compromise with manageable performance overhead, while the ACD-training study [55] explicitly includes the compute and memory burden of robustness controls. This kind of measurement is important because defended agents must still scale to realistic codebases, networks, and security pipelines.

Comparative & baseline. Comparative and baseline is the attribute that assesses an agent relative to traditional tools, prior learned methods, a non-agent LLM, humans, other agent systems, or its own ablated variants. These comparisons

make raw task scores interpretable across benchmarks, vulnerability classes, and target environments. Table 21 groups them into six families. Four blank rows remain for papers that provide no matching comparator—for example, a benchmark that compares attacks and defenses rather than agent approaches [113], two assessments without a conventional baseline [102, 110], and a conceptual design study [55].

Comparison with non-AI tools. The most common comparison is against traditional security tools, program-analysis tools, fuzzers, scanners, policy generators, runbooks, or other non-agent baselines [3, 4, 11, 14, 16, 18, 23, 26, 31, 32, 34, 37, 39, 42, 44, 47–49, 52, 56, 58, 60, 62–64, 68, 77, 80, 84, 88, 89, 92, 94, 97, 99, 106]. These comparisons clarify whether agentic behavior improves over established automation rather than merely producing plausible natural-language output. AutoRestTest [44] is a strong example: it compares its multi-agent REST API tester against leading black-box REST testing tools, including RESTler, EvoMaster, MoRest, and ARAT-RL, and reports improvements in coverage and fault detection. ClearAgent [13] is instead counted under agent-system comparisons because its reported baselines are CRAKEN and EnIGMA, whereas VulnGPT [23] directly compares its scorecard with conventional SAST tools.

Comparison with prior ML/DL methods. Some papers compare agentic systems with earlier machine-learning, deep-learning, reinforcement-learning, or learned attack approaches [1, 5, 10, 12, 15, 17, 30, 35, 42, 46, 54, 57, 59, 64, 65, 71–75, 81, 91, 97, 101, 109, 116, 119]. These comparisons are useful when the task was already studied before LLM agents, such as intrusion detection, cyber-defense simulation, vulnerability repair, CTF solving, or adversarial attack generation. AgentPoison [15], for example, compares with four learned trigger-optimization and poisoning attacks, while PatchAgent [109] compares an end-to-end repair agent with prior automated program repair methods.

Comparison with plain LLMs. Plain-LLM baselines hold the underlying model family close to the agent under test but remove agentic scaffolding such as iterative planning, memory, tool feedback, role decomposition, or critic stages [23, 38, 41, 42, 70, 76, 80, 97, 108]. They provide the most direct evidence that a gain comes from the agent design rather than from access to a stronger language model. For example, the penetration-testing assessment in [80] compares its interactive architecture with a single-shot GPT-4 plan, while VulnGPT [23] contrasts one-shot ChatGPT with the same models augmented by controller-driven self-reflection.

Comparison with humans. Human baselines are used when the task is traditionally performed by analysts, penetration testers, educators, CTF participants, bug-bounty participants, or human system designers [9, 18, 22, 32, 40, 79, 80, 95, 111, 112, 120, 121]. These comparisons are valuable but difficult to standardize because expertise varies and human solutions often include tacit strategy not captured in benchmark artifacts.

Table 21. Paper attribution for Assessment: Comparative & baseline metrics

Year	Paper	vs. non-AI tools (36%)	vs. prior ML/DL (27%)	vs. plain LLMs (9%)	vs. humans (12%)	vs. agent systems (28%)	Ablation studies (26%)
2026	[68]	✓	✓			✓	✓
	[59]	✓	✓				
	[60]		✓				✓
	[75]	✓	✓				
	[47]						
	[112]				✓	✓	
	[72]		✓				
	[121]				✓		
	[119]		✓				
	[30]		✓				
	[32]	✓			✓		
	[94]	✓					
	[104]					✓	✓
	[118]					✓	
	[116]		✓				
2025	[1]	✓	✓				
	[99]	✓				✓	
	[69]						
	[44]	✓				✓	✓
	[34]	✓				✓	✓
	[97]	✓	✓	✓			✓
	[46]		✓				
	[113]	✓	✓	✓			✓
	[42]	✓					
	[58]	✓					
	[16]	✓					
	[92]	✓					
	[71]		✓				✓
	[53]	✓					
	[56]	✓					
	[63]	✓				✓	
	[29]					✓	
	[98]					✓	
	[108]			✓		✓	
	[119]					✓	
	[13]					✓	
	[8]					✓	
	[3]		✓			✓	
	[34]	✓				✓	
	[77]	✓				✓	
	[61]	✓				✓	✓
	[28]					✓	
	[101]		✓				
	[117]		✓			✓	
	[91]		✓				
	[41]		✓	✓			✓
	[54]		✓				
	[14]	✓					
	[2]		✓			✓	
	[17]		✓				
	[45]		✓				✓
	[12]		✓			✓	
	[79]		✓		✓		
	[65]		✓				
	[88]	✓					
	[26]	✓					
	[89]	✓					
	[80]	✓		✓	✓		
	[70]	✓					
	[64]	✓	✓			✓	
	[35]		✓				
2024	[4]	✓					
	[102]						
	[81]		✓			✓	✓
	[49]	✓				✓	✓
	[40]				✓		
	[83]					✓	✓
	[62]	✓				✓	
	[110]						
	[109]		✓			✓	✓
	[85]					✓	✓
	[95]				✓	✓	✓
	[11]	✓					
	[51]	✓					✓
	[18]	✓			✓		
	[10]	✓	✓			✓	✓
	[31]	✓				✓	✓
	[52]	✓					
	[39]	✓					
	[24]	✓					
	[76]	✓		✓			✓
	[48]	✓					
2023	[37]	✓					✓
	[20]		✓				✓
	[15]		✓				✓
	[66]		✓				
	[57]		✓				
	[3]	✓					
	[120]				✓		
	[111]				✓		
	[106]	✓					✓
	[74]		✓				
2022	[38]		✓	✓		✓	
	[9]				✓	✓	
	[22]				✓	✓	
	[73]		✓			✓	
	[100]					✓	✓
	[55]	✓					✓
	[23]	✓		✓			✓
	[36]						✓

The privilege-escalation study of [32] compares success, command behavior, latency, and cost with professional penetration testers, while CTFagent [121] and CTFknow [40] compare to competition teams or human CTF participants.

Comparison with other agent systems. Many assessments compare one agent design with other agent frameworks, model-backed agents, or scaffold variants [2, 8, 12, 13, 19, 22, 24, 28, 29, 31, 34, 38, 63, 64, 68, 69, 81, 83–85, 95, 97, 98, 100, 104, 112, 117, 118]. This comparison family is becoming more important as memory, decomposition, multi-agent orchestration, retrieval, and tool-use policies can affect outcomes as much as the underlying LLM. ClearAgent [13], for example, compares on the same NYU CTF subset with CRAKEN and EnIGMA, while BountyBench [112] assesses 10 agents across detect, exploit, and patch tasks under shared systems and task definitions.

Ablation studies. Ablation studies isolate which components of an agent contribute to performance. They appear across REST API testing, vulnerability detection, agent security, repair, formal verification, fuzzing, and penetration testing [15, 20, 23, 31, 36, 38, 41, 42, 44, 45, 49, 51, 53, 61, 66, 68, 75, 76, 81, 83, 85, 95, 97, 100, 104, 109]. AutoRestTest [44] removes its semantic dependency graph, LLM value generation, and reinforcement-learning component; AgentPoison [15] disables each loss term; and VulnGPT [23] contrasts one-shot analysis with its self-reflection stage. Such ablations are important because the agent label can hide many independent design choices.

6.4.2 Dataset. An assessment dataset is the collection of subjects, environments, tasks, or observations on which an agent is tested. We characterize datasets by their origin, the security task they exercise, and cross-cutting properties such as realism, label quality, scale, modality, coverage, and accessibility. Dataset origin and security task are integral attributes, so every paper has at least one supported mapping in both tables. Within the characterisation table, however, a blank cell means that the paper does not provide enough evidence for that particular axis; we treat the information as *unspecified* rather than infer a label, scale, modality, or access condition.

Origin. Dataset origin is the attribute that records where assessed subjects, environments, alerts, programs, or tasks come from: production systems, competitions, threat feeds, curated public artifacts, or controlled/generated sources. Origin determines whether an assessment measures operationally realistic systems, reusable benchmark tasks, adversarially controlled settings, or synthetic artifacts whose behavior is easier to validate. Table 22 separates real-world from synthetic or controlled sources.

Real-world sources. Production systems are used when the assessment is built from deployed services, realistic repositories, cloud environments, bug-bounty systems, web applications, penetration-testing targets, or other systems

Table 22. Paper attribution for Assessment: Dataset origin

Year	Paper	Real-world			Synthetic / controlled			
		Production systems (28%)	Competitions (11%)	Threat feeds (17%)	Curated public artifacts (23%)	Purpose-built programs (50%)	Mutated corpora (5%)	LLM-generated (10%)
2026	68			✓		✓		
	59				✓			
	60				✓			
	75							
	47							✓
	112	✓						
	72					✓		
	121		✓			✓		
	119		✓			✓		
	30					✓		
	32					✓		
	94					✓		
	104				✓			✓
	118	✓						
	116					✓		
	11					✓		
	99				✓			✓
69				✓				
2025	44	✓			✓			✓
	34				✓			
	97	✓		✓		✓		✓
	46				✓			
	113				✓		Mutated	
	42	✓				✓		
	58			✓		✓		
	16			✓				
	92				✓			✓
	71					✓		
	53			✓		✓		
	96			✓		✓		
	63					✓		
	29					✓		
	98	✓			✓	✓		
	108	✓		✓	✓	✓		
	19		✓		✓	✓		
	13				✓			
	8		✓			✓		
	5					✓		
	84				✓			
	77						✓	
	61	✓						✓
	28	✓						
	101	✓		✓	✓			
	117	✓		✓	✓			
	91				✓	✓		
	41			✓	✓			
	54			✓		✓		
	14				✓	✓		
	2		✓			✓		
	17					✓		
	45					✓		
	12					✓		
	79	✓				✓		
	65					✓		
	88	✓				✓		
	26					✓		
	89					✓		
	80		✓			✓		✓
	70	✓						
64	✓							
35	✓							
4		✓			✓			
102								
81	✓			✓				
49		✓	✓					
40						✓		
83					✓		✓	
62					✓	✓		
110	✓				✓	✓		
109	✓				✓			
85	✓	✓						
95	✓				✓			
11	✓							
51	✓							
18	✓				✓			
30					✓			
31					✓			
52				✓				
39					✓			
24	✓							
76					✓			
48				✓				
2024	37			✓		✓		
	20				✓			
	15	✓			✓		✓	
	66							
	57							
	3					✓		
	120		✓			✓		
	111	✓				✓		
	106			✓		✓		
	74					✓		
	38					✓		
	9					✓		
	22	✓	✓			✓		
2023	73					✓		
	100					✓		
	55				✓	✓		
	23				✓	✓		
	36	✓						

with operational structure [11, 18, 22, 24, 26, 28, 35, 36, 42, 44, 49, 61, 64, 66, 70, 79, 85, 97, 98, 101, 106, 108–112, 117, 118]. These datasets are valuable because agent behavior depends heavily on real system structure: repository layout, service state, execution dependencies, and operational constraints can all affect the agent’s trajectory. BountyBench [112] is representative because it assesses agents on 25 real-world systems with bug-bounty tasks that cover detection, exploitation, and patching. CVE-Bench [117] similarly grounds exploitation assessment in vulnerable real-world web applications reproduced inside sandboxes.

Competition-derived datasets are common in offensive-security work, especially CTF and cyber-range settings [2, 4, 8, 13, 22, 40, 80, 85, 119–121]. These datasets offer well-defined success conditions, reusable tasks, and rich community writeups, but they may also reward puzzle-solving behavior that differs from real production intrusion. ClearAgent [13], for example, is assessed on binary challenges from NYU CTF Bench, while Cyber-Zero [119] leverages public CTF writeups to synthesize long-horizon agent trajectories when the original runtime environments are unavailable.

Threat feeds and security databases provide another real-world source, including CVE/NVD data, vulnerability advisories and proof-of-concept feeds, attack frameworks, threat-intelligence resources, and incident-related feeds [16, 19, 37, 48, 49, 52, 54, 56, 58, 68, 81, 84, 97, 101, 108, 111, 117]. These sources are useful for vulnerability classification, exploitability assessment, SOC enrichment, and asset-discovery tasks because they connect agent outputs to recognized security knowledge. For example, Cognitive SOC [84] enriches alerts with threat-intelligence sources such as MITRE ATT&CK, Sigma rules, and CVE databases, making dataset origin part of the evidence chain for generated incident narratives.

Curated public artifacts include open-source repositories, malware corpora, standards, benchmark applications, human-written properties, and other reusable public collections [10, 13–15, 23, 31, 40, 41, 44, 46, 51, 60, 69, 75–77, 92, 99, 102, 104, 108, 109, 117]. This broader label avoids treating public malware, RFCs, CTF writeups, prompts, or smart-contract properties as software repositories. These datasets balance realism and repeatability by retaining real artifacts while allowing researchers to package, label, and rerun assessments.

Synthetic and controlled sources. Purpose-built programs and environments are used when researchers need tight control over vulnerabilities, attack paths, services, state transitions, or agent-security tasks [1–5, 9, 12, 14, 17, 19, 20, 22, 23, 26, 29, 30, 32, 34, 38, 39, 45, 48, 53–59, 63, 65, 68, 71–74, 80, 83, 88, 89, 91, 94, 95, 98, 100, 110, 111, 113, 116, 119]. This is common in cyber-defense simulation, penetration-testing benchmarks, adversarial-agent assessment, and controlled vulnerability tasks. The advantage is measurability: the assessor can know the intended flag, exploit condition, network state, or successful defense outcome. The limitation is that the resulting task may underrepresent the messiness of production systems.

Mutated corpora and generated variants are less common but important for stress-testing coverage and robustness. Mutated corpora appear when studies adversarially alter applications, contracts, inputs, or retrieved content [15, 46, 49, 62, 77]. LLM-generated datasets are used when a task requires scalable prompts, examples, protocol models, negative samples, test inputs, or challenge-like artifacts [32, 34, 40, 44, 47, 61, 80, 92, 99, 104]. These are multi-label origins: e.g., CTFKnow [40] generates questions from public competition writeups and then filters and manually verifies them.

Dataset by security task. Dataset by security task is the attribute that records the security capability an assessment exercises, such as auditing, penetration testing, smart-contract analysis, repair, defense, fuzzing, agent security, malware analysis, or SOC operations.

This view distinguishes assessments that use similarly realistic artifacts for different capabilities. Table 23 uses named benchmark families where possible and broader other-task columns when a paper uses a task-relevant corpus outside those named families.

Table 23. Paper attribution for Assessment: Dataset by security task

Year	Paper	Vuln. detection & classification					Penetest & CTF										AI / agent security (9%)	Asset discovery / OSINT (1%)	Malware / Android apps (2%)	Intrusion / SOC / SOAR (12%)	Other security task (2%)
		BigVul (2%)	ReVeal (1%)	PrimeVul (1%)	NVD / CVE database (12%)	Other vuln. / audit corpora (6%)	InterCode-CTF (3%)	PicoCTF (2%)	HackTheBox (5%)	VulnHub (6%)	AutoAttacker benchmark (6%)	Other pentest / CTF (13%)	Smart contracts (8%)	Web phishing / scam (2%)	Repair bug-fix (4%)	Cyber defense simulation (16%)	Security testing / fuzzing (5%)				
2026	[68]				✓											✓	✓				
	[59]																				
	[60]																				
	[75]																			✓	
	[47]	✓	✓	✓	✓	✓						✓			✓						
	[112]															✓					
	[72]																				
	[121]																				
	[119]						✓		✓									✓			
	[80]																				
	[32]											✓						✓			
	[94]									✓											
	[104]																				
	[118]				✓							✓						✓			
	[116]															✓					
	[11]													✓							
	[99]																✓				
	[69]																	✓			
2025	[44]																				
	[34]				✓								✓				✓				
	[97]																				
	[46]																				
	[111]																		✓		
	[42]																				
	[58]				✓							✓									
	[16]																				
	[92]																✓				
	[71]															✓					
	[53]				✓															✓	
	[56]									✓											
	[63]								✓	✓											
	[29]								✓												
	[28]																				
	[108]				✓								✓								
	[19]											✓									
	[133]																				
	[8]																	✓			
	[51]				✓															✓	
	[64]																				
	[77]									✓										✓	
	[61]											✓									
	[28]																				
	[101]									✓											
	[117]				✓																
	[91]															✓					
	[41]	✓														✓					
	[54]															✓					
	[144]																				✓
	[21]																				
	[117]															✓					
	[45]															✓					
	[112]															✓					
	[79]																				✓
	[65]															✓					
	[68]										✓										
	[26]																			✓	
	[89]					✓									✓						
	[80]																				
	[70]											✓								✓	
	[64]															✓				✓	
	[15]											✓									
	[41]																				
	[102]																				
	[81]																			✓	
	[49]																	✓			
	[40]						✓		✓												
	[83]					✓															
	[62]																				
	[110]																				
	[109]																				
	[65]											✓				✓					
	[95]											✓									
	[11]																				
	[53]													✓							
	[18]											✓									
	[10]																				
	[31]					✓															
	[52]																				
	[39]																			✓	
	[24]																			✓	
	[76]													✓							
	[48]				✓																
2024	[37]																			✓	
	[20]																				
	[15]																	✓			
	[66]																	✓			
	[57]																				
	[71]																				
	[120]																				
	[111]				✓								✓								
	[106]																				
	[74]																				
	[38]										✓										
	[81]																				
	[22]								✓	✓											
	[73]									✓											
	[100]																				
	[55]					✓															
2023	[23]																				
	[36]													✓							

Vulnerability detection & classification. Vulnerability-detection datasets include named corpora such as BigVul, ReVeal, and PrimeVul [41, 47], CVE/NVD-derived data [16, 19, 34, 47, 56, 68, 84, 97, 108, 111, 117, 118], and other vulnerability or audit corpora [23, 31, 48, 83, 89, 112]. The broader other-audit column prevents custom Infrastructure-as-Code, repository, PoC, and benchmark collections from being left unmapped merely because they do not use one of the three named corpora.

Penetration testing & CTF. Penetration-testing and CTF datasets cover InterCode-CTF [2, 40, 119], PicoCTF [40, 121], HackTheBox [18, 22, 29, 85, 98], VulnHub [22, 28, 63, 94, 98, 100], AutoAttacker-style benchmarks [18, 38, 85, 88, 95, 101],

and other custom pentest or CTF suites [3, 4, 9, 13, 28, 32, 58, 80, 100, 106, 112, 118, 120]. These datasets are well suited to long-horizon assessment because the agent must gather evidence, choose tools, execute actions, and adapt to observations. A paper may legitimately receive both a named-benchmark and an other-pentest mark when it is assessed across multiple suites.

Smart contracts. Smart-contract datasets form a distinct application domain spanning contract vulnerability detection, auditing, and property verification [36, 42, 51, 61, 76, 77, 97, 108]. This attribute was added because these eight papers previously had no integral task-domain column even though their datasets and assessment targets were explicit.

Web, phishing, and scam. Web, phishing, and scam datasets assess whether agents can identify malicious sites, web threats, or scam behavior [1, 11]. TrustNet [1], for example, assesses a hybrid ML and LLM-agent detector for scam websites using labeled examples and standard classification metrics. This category differs from CVE exploitation because the task is often judgment or classification over web-facing evidence, not interaction with a vulnerable application.

Repair and bug-fix. Repair datasets assess whether agents can modify code correctly, usually with tests, proof-of-concept inputs, or known bug labels [10, 89, 109, 112]. PatchAgent [109] uses real-world vulnerability cases with proof-of-concept tests and functional test suites, while BountyBench [112] couples repair with detection and exploitation tasks; its multiple task marks therefore reflect a genuinely multi-task benchmark.

Cyber defense and simulation. Cyber-defense datasets and environments support defender agents, network-security games, attack-defense simulations, and autonomous response assessment [12, 17, 35, 45, 54, 55, 57, 59, 64, 65, 71–74, 91, 116]. These datasets often define stateful environments where the agent must preserve service availability while detecting or mitigating an attacker. The CAGE-2 study [65] is representative because it assesses LLM-based cyber defenders in a simulated network environment where reward reflects both security and operational continuity.

Security testing and fuzzing. Security-testing datasets cover REST API and program-level testing as well as RFC-derived protocol models and fuzzing targets [44, 60, 62, 92, 99]. MultiFuzz [62] uses RFC-derived knowledge for protocol exploration, whereas AutoRestTest [44] assesses graph- and agent-guided REST API input generation. The broadened label records the shared testing objective without incorrectly describing every assessment as protocol fuzzing.

AI and agent security. AI- and agent-security datasets assess prompt injection, jailbreaks, memory poisoning, unsafe tool use, taint-style agent vulnerabilities, and attacks on other learned systems [8, 15, 20, 30, 49, 66, 69, 104, 113]. AgentDojo [20] provides realistic tool-calling tasks with prompt-injection tests, while AgentFuzz [49] targets vulnerabilities in LLM applications and [30, 66] assess agent-generated attacks on recommender systems.

Asset discovery and OSINT. Asset-discovery and OSINT datasets assess whether an agent can search, correlate, or prioritize exposed assets and vulnerability-relevant information [52]. This category is small in the current taxonomy, but it is practically important as many security workflows begin with asset visibility rather than code or exploit generation. Dataset design in this category needs to capture both retrieval accuracy and the operational speed of discovery.

Malware and Android apps. Malware and Android-app datasets support agentic analysis of suspicious software, app behavior, family attribution, or malware reports [46, 102]. MAD-Agent [102] illustrates this task family by combining static and dynamic analysis tools with threat-intelligence access, then assessing detection, behavioral classification, family attribution, and report quality. Compared with vulnerability datasets, malware datasets often require interpreting multiple evidence streams rather than only matching a code location to a vulnerability label.

Intrusion, SOC, and SOAR. This broader family covers intrusion or traffic detection as well as alert triage, enrichment, reporting, response recommendation, and automated investigation [5, 24, 26, 37, 39, 53, 64, 70, 75, 81, 84, 110]. Cognitive SOC [84] assesses evidence linkage, citation coverage, hallucination, and time-to-recommendation on 1,000 alerts. The broader label prevents intrusion datasets from being excluded merely because they are not packaged as SOC alerts.

Other security tasks. The residual task category is used for two explicit but otherwise uncovered assessment targets: cloud-native access-control policy generation [14] and context-aware software-security education [79]. It is not an unknown or unspecified label; it records a defined task that falls outside the listed families.

Dataset characterisation axes. Dataset characterisation axes are cross-cutting attributes of the assessment data: realism, label quality, scale, artifact type, vulnerability-type coverage, and accessibility.

These axes explain why results may not be directly comparable even for the same application. Table 24 applies every supported item to each paper; multiple checkmarks are therefore expected when an assessment combines modalities or access conditions. Realism and scale are coded at the level of the assessed collection, while unsupported or unreported axis values remain blank and are interpreted as unspecified.

Realism. The surveyed datasets span fully synthetic, semi-synthetic, and fully real-world settings. Fully synthetic datasets are used when the authors construct all or most of the assessed artifacts or environment states [17, 23, 30, 45, 53, 55, 59, 77, 88]. Semi-synthetic datasets combine real components with controlled modifications, generated tasks, simulated environments, or benchmark wrappers [1, 2, 4, 5, 8, 9, 12–14, 19, 20, 22, 26, 29, 32, 34, 37, 39, 40, 44, 47–49, 54, 56–58, 62, 63, 65, 68, 71–73, 79, 80, 84, 91, 94, 95, 98, 100, 110, 111, 113, 116, 119]. Fully real-world datasets use real vulnerabilities, applications, repositories, malware, alerts, or production-style targets [10, 11, 15, 16, 18, 24, 28, 31, 35, 36, 41, 42, 46, 51, 52, 60, 64, 66, 69, 70, 75, 76, 81, 85, 97, 101, 102, 104, 106, 108, 109, 112, 117, 118, 120, 121]. The tradeoff is consistent across the survey: real-world datasets improve ecological validity, while synthetic and semi-synthetic datasets improve control, repeatability, and safety.

Label quality. Label quality determines whether the assessment target is trustworthy. Some datasets rely on automated labels, such as generated labels, oracle checks, or test-derived labels [20, 51, 61, 109]. Competition-verified labels appear in CTF and cyber-range datasets where a flag, official solution, or challenge infrastructure validates success [2, 4, 8, 13, 40, 80, 85, 117, 119–121]. Expert/reference-verified labels are grounded in official behavior, human-written references, manual annotation, or review by domain or security experts [3, 5, 11, 14, 23, 40, 47–49, 51, 76, 77, 92, 102, 104, 111]. Noisy or weak labels appear when large vulnerability corpora or generated benchmark artifacts may contain imperfect ground truth [47, 80]. When no evidence supports one of these label sources, the label-quality value is left unspecified rather than guessed.

Scale. Dataset scale varies widely. Small datasets are common in expensive, environment-heavy assessments such as CTF, cyber-defense, malware analysis, policy generation, and exploit benchmarks [2, 4, 13, 14, 17, 54, 102, 119]. Medium-scale datasets appear in phishing, vulnerability, SOC, prompt-injection, and CTF-knowledge assessment [1, 20, 23, 40, 48, 84, 97, 113]. Large datasets are relatively rare in the verified taxonomy and appear mainly in large vulnerability-detection corpora and smart-contract analysis [42, 47]. This imbalance reflects a core assessment challenge: agentic security tasks are often costly to execute because they require live environments, tool interaction, sandboxing, or human validation, so scale is often traded for realism and measurement depth.

Language and artifact type. Some datasets are single-language code datasets, which are common in vulnerability detection, smart-contract analysis, repair, and formal-verification tasks [23, 42, 51, 60, 61, 76, 83, 89, 109, 112]. Others involve binary or compiled artifacts, including malware, reverse engineering, CTF binaries, and exploit-development tasks [2, 4, 13, 42, 46, 102, 121]. The largest artifact family is network/log data, which appears in cyber-defense, intrusion detection, protocol fuzzing, penetration testing, SOC alerting, and web-security tasks [1, 2, 4, 5, 8, 12, 14, 17–19, 22, 24, 34, 35, 37–40, 45, 48, 49, 52, 54–59, 62, 63, 65, 68, 70–75, 84, 91, 92, 94, 99–101, 110, 116, 120, 121]. Artifact type strongly shapes the agent’s required capabilities: code datasets emphasize semantic program reasoning, binary datasets require lower-level analysis, and network/log datasets emphasize temporal correlation and environment state.

Table 24. Paper attribution for Assessment: Dataset characterisation axes

Year	Paper	Realism			Label quality				Scale			Language / artifact			Vulnerability type coverage		Accessibility		
		Fully synthetic (9%)	Semi-synthetic (47%)	Fully real-world (36%)	Auto-labelled (4%)	Competition verified (11%)	Noisy / weakly labelled (2%)	Expert / reference verified (16%)	Small (8%)	Medium (8%)	Large (2%)	Single language (10%)	Binary / compiled (7%)	Network / log (49%)	Multi-type coverage (23%)	Fully public (50%)	Public w/ registration (3%)	Restricted (4%)	Proprietary / internal (1%)
2026	[68]		✓											✓		✓			
	[59]	✓												✓		✓			
	[60]			✓								✓		✓		✓			
	[75]		✓				✓	✓						✓		✓			
	[47]			✓										✓		✓			
	[112]			✓								✓		✓		✓			
	[72]		✓											✓		✓			
	[121]			✓		✓								✓		✓			
	[119]			✓					✓				✓		✓		✓		✓
	[30]	✓												✓		✓			✓
	[32]													✓		✓			
	[94]		✓											✓		✓			
	[104]			✓				✓						✓		✓			
	[118]			✓										✓		✓			
	[116]		✓								✓			✓		✓			
	[1]		✓											✓		✓			
	[99]			✓										✓		✓			
	[69]													✓		✓			
2025	[44]		✓											✓		✓			
	[34]			✓										✓		✓			
	[97]			✓										✓		✓		✓	
	[46]		✓										✓		✓				✓
	[113]		✓											✓		✓			
	[42]		✓									✓		✓		✓			
	[58]		✓										✓		✓				
	[16]			✓										✓		✓			
	[92]							✓						✓		✓			
	[71]	✓	✓											✓		✓			
	[53]		✓											✓		✓			
	[56]		✓											✓		✓			
	[63]		✓											✓		✓			
	[29]		✓											✓		✓			
	[98]		✓											✓		✓	✓		
	[108]			✓										✓		✓			
	[19]		✓											✓		✓			
	[13]		✓							✓				✓		✓			
	[8]		✓											✓		✓			
	[5]		✓					✓						✓		✓		✓	✓
	[84]		✓					✓						✓		✓			
	[77]	✓						✓			✓			✓		✓			
	[61]				✓			✓				✓		✓		✓			
	[28]			✓										✓		✓			
	[101]			✓										✓		✓			
	[117]			✓										✓		✓			
	[91]		✓											✓		✓			
	[41]		✓											✓		✓			
	[54]		✓											✓		✓			
	[14]		✓											✓		✓			
	[2]		✓					✓						✓		✓			
	[17]	✓												✓		✓			
	[45]	✓												✓		✓			
	[12]		✓											✓		✓			
	[79]		✓											✓		✓			
	[65]		✓											✓		✓			
	[88]	✓	✓											✓		✓			
	[26]		✓											✓		✓			
	[89]		✓										✓		✓		✓		
	[80]		✓				✓							✓		✓			
	[70]			✓										✓		✓			
	[64]			✓										✓		✓			
	[35]		✓											✓		✓			
	[4]		✓											✓		✓			
[102]		✓					✓						✓		✓				
[81]		✓					✓						✓		✓				
[49]		✓					✓						✓		✓				
[40]		✓					✓						✓		✓		✓		
[83]		✓									✓		✓		✓			✓	
[62]		✓											✓		✓				
[110]		✓											✓		✓				
[109]		✓											✓		✓				
[85]		✓		✓							✓		✓		✓		✓		
[95]		✓											✓		✓			✓	
[11]		✓					✓						✓		✓				
[51]			✓				✓						✓		✓				
[18]			✓										✓		✓				
[10]			✓										✓		✓				
[31]			✓										✓		✓				
[52]		✓											✓		✓				
[39]		✓											✓		✓				
[24]		✓											✓		✓				
[76]		✓									✓		✓		✓				
[48]		✓					✓			✓			✓		✓				
2024	[37]		✓		✓									✓		✓			
	[20]		✓											✓		✓			
	[15]			✓										✓		✓			
	[66]		✓											✓		✓			
	[57]		✓											✓		✓			
	[3]							✓						✓		✓			
	[120]		✓			✓								✓		✓			
	[111]		✓					✓						✓		✓			
	[106]			✓										✓		✓			
	[74]													✓		✓			
	[38]		✓											✓		✓			
	[9]		✓											✓		✓			
	[22]		✓											✓		✓			
	[73]		✓											✓		✓			
	[100]		✓											✓		✓			
[55]	✓						✓						✓		✓				
[23]	✓											✓		✓					
2023	[36]			✓											✓				

Vulnerability type coverage. Some datasets explicitly cover multiple vulnerability classes, attack types, or benchmark categories [2, 4, 8, 13, 22, 28, 32, 38, 40, 48, 70, 73, 80, 85, 98, 101, 109, 112, 113, 117, 119–121]. Coverage matters because many agents perform well on familiar vulnerability patterns but fail when the target requires a different exploitation strategy, input modality, or repair mechanism. BountyBench [112] is illustrative because it spans real bug-bounty

vulnerabilities across OWASP risk categories and assesses detect, exploit, and patch tasks. PentestGPT [22] similarly uses targets that cover OWASP top-10 vulnerabilities and multiple CWE items, making subtask performance more informative than a single aggregate score.

Accessibility. Accessibility determines whether assessment results can be reproduced. Fully public datasets are the dominant accessibility category [1–5, 8, 10–15, 20, 22–24, 30–32, 36, 37, 40, 44, 47, 49, 51, 54, 60, 61, 63, 75–77, 85, 91, 92, 94, 97–99, 102, 109–113, 118–121]. A smaller set is public but requires registration or platform access, often because targets live on hosted penetration-testing platforms [22, 85, 98]. Restricted datasets appear when environments, challenge assets, or collected data cannot be fully released [5, 34, 40, 119], and proprietary or internal data appears rarely [5]. If a paper does not disclose access conditions, accessibility is recorded as unspecified; public source artifacts are not taken to imply that the authors’ complete assessment dataset is public.

7 Analysis and Discussion of Survey Results

7.1 Agentic Approach to Software/Systems Security

The survey results on Approach (§6.2) show that LLM-based security agents are systems in which an LLM plans, acts, observes, and revises. This is a significant shift from treating the LLM as a standalone text generator. At the same time, this domain remains unevenly developed. Architecture and workflow design are relatively mature, while explicit uncertainty handling, safety controls, human governance, and long-term learning are still limited.

7.1.1 Limitations and Challenges of Existing Works. Existing approaches are highly modular, but their modularity is often operational rather than principled. Table 4 shows that 91% of the surveyed papers use a modular pipeline, and 88% place the backbone LLM in a planner+actor role. This indicates that most systems now separate planning, execution, tool use, observation, or reporting in some form. However, fewer papers include explicit critic/verifier/judge roles (15%), guardrail or policy-enforcement layers (13%), fine-tuned LLM components (7%), mixture-of-agents designs (4%), or all-in-one role definitions (4%), and a further 3% do not describe their internal organization in enough detail to classify at all. Systems such as REPOAUDIT [31] and ZT-ICAS [69] show that validators and guardrails can be architectural components rather than external checks, but they remain the exception. Thus, many agents are modular enough to operate but not yet sufficiently modular to make their own failure modes auditable. Verification, policy enforcement, and role boundaries are still treated as optional enhancements rather than core architectural requirements.

Memory and perception are broad but shallow. Table 5 shows that in-context working memory (60%) and long-term/persistent memory (57%) are common, and all systems rely on parametric memory in the broad sense of model-internal knowledge. Security-specific memory is also visible, including tool documentation (49%), execution traces and fuzzing logs (33%), vulnerability knowledge bases (25%), and code repositories or patch histories (23%). However, these stores are consumed far more often than they are curated: read operations appear in 61% of papers and update/reflection in 42%, but explicit write operations in only 7%, and knowledge-graph memory in 10%. COGNITIVE SOC [84], which converts alert evidence into a durable incident narrative, is among the few that treat memory as something the agent produces rather than only consumes. This asymmetry suggests that many papers use memory as context storage or retrieval support, but fewer define memory as a governed stateful subsystem with clear read/write/update semantics, provenance, forgetting, conflict handling, or contamination defenses.

Perception follows a similar pattern. Table 6 shows universal direct LLM ingestion (100%), frequent tool-mediated observation (68%), and substantial use of environment observations (66%), structured data (60%), system logs (55%), and natural language (42%). However, retrieval-augmented perception appears in 30%, summarisation/compression in 35%,

embedding-based semantic processing in 10%, and compiled binaries or decompiled outputs in only 5%. Security agents therefore consume many kinds of inputs, but their perception pipelines often depend on ad hoc prompt ingestion and tool output parsing. This is risky in adversarial settings where logs, web pages, code comments, repository files, and tool outputs may contain misleading or malicious instructions—precisely the threat model that AgentDojo [20] and AGENTPOISON [15] demonstrate against the ingestion and retrieval paths, respectively.

Reasoning and planning are dominated by reactive control rather than robust decision-making. Table 7 shows that dynamic/reactive planning appears in 80% of papers, while least-to-most/task decomposition appears in 46% and hypothesis-driven reasoning in 29%. These patterns are well matched to security tasks where observations arrive incrementally. However, explicit mechanisms for decision-making under uncertainty are much less common: confidence-based branching appears in 23%, majority voting in 7%, and human-in-the-loop checkpoints in only 4%. This is a central limitation because security agents often act under uncertainty. A related reporting gap compounds it: 18% of the surveyed papers do not identify their reasoning paradigm at all, and 16% of the papers do not identify their planning paradigm, which makes it difficult to tell whether a result follows from the agent scaffold or from the backbone model.

The action space reveals a strong dependence on retrieval and practitioner tools, but uneven integration with deeper security analysis. Table 8 shows that documentation retrieval (38%), vector/RAG retrieval (29%), penetration-testing frameworks (25%), REPL/shell execution (19%), code search (17%), execution sandboxes (17%), CTF platforms (14%), and linters/pattern matchers (15%) are among the most common actions. These actions make agents practically useful because they connect LLM reasoning to external evidence and executable environments. Still, more specialized tools are less consistently represented, including symbolic execution (2%), formal verification (5%), taint analysis (5%), binary analysis, cloud/IaC tooling, SIEM/SOAR integration, and cyber-range infrastructure. Where they are used, as in PROPERTYGPT [51], a sound external analysis rather than the model itself decides whether a candidate finding survives. As a result, many agents resemble tool-using assistants rather than deeply integrated security-analysis systems.

Workflow results show that autonomy has outpaced governance. Table 9 shows that fully autonomous workflows appear in 95% of papers, with analyst, executor, and planner roles appearing in 93%, 92%, and 74%, respectively. Sequential pipelines (90%) and iterative loops (78%) are also dominant. By contrast, human-on-the-loop workflows appear in 8%, human-in-the-loop workflows in 5%, and interactive/collaborative workflows in 3%. This gap is striking: many surveyed systems automate tasks that can affect real systems, generate exploits, patch code, or interpret incidents, yet only a small fraction structurally encode human review or approval.

Finally, self-improvement remains sparse. Table 10 shows that learning from feedback within a session appears in 32% of papers, but example-guided correction appears in only 1%, storing successful trajectories in 3%, updating fine-tuning data in 2%, reward-signal design in 9%, and environment-based RL in 9%. This means that most agents adapt locally through tool feedback or iterative prompting, but few accumulate durable experience across tasks or improve through controlled training loops. For security applications, this is a serious limitation: repeated vulnerability classes, recurring tool failures, common exploit chains, and SOC triage patterns should become reusable experience rather than disappearing after each run.

7.1.2 Future Research Directions. Future work should make agent architecture more auditable by treating verification, policy control, and role separation as first-class design elements. Modular pipelines should specify which component is responsible for planning, acting, evidence collection, validation, reporting, and risk control. Critic/verifier modules should be assessed separately from generation modules, because a system that generates many plausible findings but validates few of them is different from one that produces fewer but more reliable outputs. Similarly, guardrail

layers should be connected to concrete enforcement points, such as tool-call authorization, scope checking, retrieval filtering, command execution, memory writes, and report release, extending the capability-bounded tool invocation of ZT-ICAS [69].

Memory should evolve from passive context accumulation into managed security state. Future agents should distinguish working memory, long-term memory, retrieved knowledge, executable traces, and analyst-approved facts. They should also record provenance: where a fact came from, which tool produced it, when it was observed, and whether it has been validated. This is particularly important for repository auditing, penetration testing, incident response, and threat intelligence, where stale or poisoned context can mislead later actions, as AGENTPOISON [15] demonstrates for retrieval-backed memory. Memory systems should also support controlled updates, conflict resolution, deletion, and compartmentalization so that one compromised input does not contaminate the entire agent state.

Perception pipelines should become more adversarially robust. Since security agents ingest untrusted code, logs, websites, binaries, prompts, and tool outputs, future work should separate data from instructions and treat external artifacts as potentially hostile. Retrieval-augmented perception should include source ranking, provenance, freshness checks, and prompt-injection filtering. Summarization should preserve evidence links rather than merely compressing text. For binary, malware, and protocol tasks, perception should also integrate structured representations from disassemblers, sandboxes, dynamic traces, and protocol parsers rather than relying primarily on natural-language descriptions, generalizing the analyzer-backed interface of CLEARAGENT [13].

Reasoning and planning should explicitly represent uncertainty. Future agents should attach model confidence and evidence. Confidence-based branching, voting, verifier checks, and human checkpoints should be used when uncertainty affects safety or cost, and papers should state their reasoning paradigm explicitly rather than leaving it unspecified. Planning should also include recovery behavior: how the agent detects a failed assumption, rolls back a bad action, requests clarification, or performs explicit backtracking. This is especially important for penetration testing, repair, and autonomous cyber defense, where early mistakes can cascade.

The action space should deepen toward security-native tool integration. Future agents should not only call tools, but also understand tool preconditions, parse outputs reliably, validate results, and decide when a tool is inappropriate. Static-analysis engines, symbolic execution, taint analysis, formal verification, fuzzers, sandboxes, SIEM/SOAR systems, cloud/IaC platforms, and cyber ranges should be integrated through typed interfaces rather than free-form command strings whenever possible, following the sound-tool-in-the-loop design of REPOAUDIT [31]. Tool-call accuracy, permission boundaries, and side effects should be logged as part of the agent trajectory. This would make agent behavior easier to reproduce, audit, and constrain.

Human involvement should be designed around risk rather than added as an afterthought. Fully autonomous operation is reasonable for sandboxed benchmarks, low-risk analysis, or offline report generation, but real-world security workflows often require approval gates. Future work should define when a human must be in the loop, when a human can remain on the loop, and when autonomy is acceptable; PENTESTGPT [22] is instructive because it occupies both positions at different points in the same workflow. High-risk actions should trigger review policies. Human interfaces should expose evidence, uncertainty, planned actions, and alternatives, not merely final answers.

Finally, future agents should learn across tasks in a controlled and measurable way. In-session feedback is useful, but security work contains reusable structure: successful exploit chains, failed commands, false-positive patterns, patch templates, alert-triage rationales, and tool-specific recovery strategies. Future systems should store successful and failed trajectories with metadata, retrieve them for similar tasks, and use them to build fine-tuning or preference data when appropriate, extending the trajectory-synthesis pipeline of CYBER-ZERO [119] beyond CTF writeups to operational

security tasks. Reinforcement learning and environment-based improvement are promising for API testing, cyber ranges, autonomous defense, and attack simulation, but reward design must avoid unsafe shortcuts. The long-term goal should be security agents that improve from experience while preserving auditability, scope control, and reproducibility.

7.2 Applications of Agentic Approaches in Software/Systems Security

The survey results on Application (§6.3) show that LLM-based agents have already been applied to a wide range of software and systems security tasks. This breadth indicates that agentic systems are not confined to one narrow security subfield. However, the application landscape is uneven: current work is concentrated around vulnerability-centered and offensive workflows, while several operationally important defensive, low-level, and governance-heavy security tasks remain much less mature.

7.2.1 Limitations and Challenges of Existing Works. Existing applications are strongly concentrated around the vulnerability lifecycle, especially vulnerability detection, penetration testing, exploitability assessment, and repair. This concentration is natural because these tasks are text-, code-, and tool-rich: agents can inspect code, read documentation, call scanners, run commands, and generate reports. It has also produced some of the most concrete progress in the surveyed corpus, including repository-level auditing in REPOAUDIT [31], executable CVE exploitation in CVE-Bench [117], bug-bounty-style detect/exploit/patch tasks in BountyBench [112], and patch generation in PATCHAGENT [109]. At the same time, this concentration means that the field’s view of “security agent” is still shaped heavily by finding, exploiting, or fixing vulnerabilities. Other important security tasks, such as access-control analysis, supply-chain security, asset inventory, security policy governance, long-running compliance checks, and analyst knowledge management, receive much less systematic treatment.

The surveyed applications are also fragmented across the security lifecycle. Many systems address one stage well, such as detecting a vulnerable function, solving a CTF challenge, triaging an alert, or generating a patch, but fewer connect these stages into a coherent operational workflow. Detection-oriented agents often stop at candidate findings; exploitation-oriented agents often stop at proof of compromise; repair-oriented agents often assume a localized bug and available tests; SOC-oriented agents often focus on evidence synthesis rather than closed-loop containment and recovery. This separation makes it hard to assess whether an agent can support the full path from discovery to verification, prioritization, remediation, validation, reporting, and follow-up monitoring. BountyBench [112] is notable because it explicitly separates detect, exploit, and patch tasks, but such lifecycle-spanning designs are still uncommon.

Offensive applications have advanced faster than many defensive and governance-oriented applications. Penetration testing, red-teaming, CTF solving, exploit generation, and web vulnerability scanning are well represented, and systems such as PENTESTGPT [22], AUTOPESTER [29], ENIGMA [2], and PTFUSION [94] illustrate substantial progress in long-horizon offensive workflows. However, post-exploitation tasks such as privilege escalation, lateral movement, persistence analysis, and cleanup are much less developed. On the defensive side, autonomous cyber-defense and SOC systems are emerging, but many works remain in simulation or controlled-alert settings. In real environments, defensive agents must reason about business impact, false-positive cost, service availability, escalation policies, and human accountability, which are harder to encode than a CTF flag or exploit success condition.

Several security domains remain underexplored despite their practical importance. Malware analysis and Android-app security appear in only a small part of the taxonomy, even though agents could help combine static features, dynamic traces, threat intelligence, family attribution, and analyst-facing reports, as suggested by MAD-AGENT [102]. Binary analysis and reverse engineering are also comparatively sparse, partly because they require agents to interpret

disassembly, decompiled code, debugger state, calling conventions, and low-level execution artifacts. Protocol fuzzing and software testing have promising examples such as `MULTIFuzz` [62] and `AutoRestTest` [44], but they are not yet as broadly explored as penetration testing or source-code vulnerability detection. This imbalance suggests that current agents are strongest where security evidence can be represented as natural language, source code, or familiar command output, and weaker where the application requires specialized representations or stateful execution semantics.

Application realism is another persistent challenge. Many surveyed systems are assessed on CTF platforms, reproduced CVEs, synthetic networks, curated repositories, or benchmark tasks. These settings are valuable because they provide control, safety, and measurable outcomes, but they do not fully capture the constraints of production security work. Real deployments require authentication boundaries, incomplete asset inventories, noisy telemetry, legacy systems, change-management policies, legal scope limits, disclosure procedures, and human approval chains. Even when agents produce correct technical outputs, the application may still fail if it does not fit the workflow of a SOC analyst, cloud engineer, application-security reviewer, or incident commander. Thus, application success depends not only on agent capability, but also on integration with the surrounding security process.

Finally, many applications expose dual-use and operational-safety concerns. Agents that automate vulnerability discovery, exploit generation, web scanning, red teaming, or jailbreak generation can be useful for defense, but the same capabilities can cause harm if released or deployed without clear boundaries. Some surveyed works discuss sandboxing, scoped environments, or guardrails, yet application-level risk management is not consistently treated as part of the task definition. This is a limitation of the application literature itself: a security application should specify not only what the agent is trying to accomplish, but also where it is authorized to act, what evidence it may collect, what actions require approval, and what outputs should be withheld, sanitized, or disclosed responsibly.

7.2.2 Future Research Directions. Future work should broaden the application portfolio beyond vulnerability-centered and offensive workflows. Vulnerability detection and penetration testing will remain important, but the field also needs stronger agentic support for software supply-chain security, dependency risk assessment, access-control review, cloud and IaC governance, identity and permission analysis, asset discovery, compliance evidence collection, secure configuration management, and security-policy maintenance. These tasks are less glamorous than exploitation, but they represent recurring work in real security programs and are well suited to agents that can gather evidence, reconcile documentation, reason over policies, and produce auditable recommendations.

Future applications should also connect isolated tasks into lifecycle-aware workflows. A mature application should be able to carry evidence across stages: a suspected vulnerability should be verified, mapped to exploitability and impact, prioritized against asset context, repaired or mitigated, validated against proof-of-concept triggers and regression tests, and summarized for human review. For example, the direction suggested by `BountyBench` [112], `REPOAUDIT` [31], and `PATCHAGENT` [109] could be extended into end-to-end application-security agents that preserve traceability from discovery to patch validation. Similar lifecycle integration is needed for SOC workflows, where alert triage should connect to enrichment, hypothesis testing, containment planning, response execution, and post-incident reporting.

The field should invest in security-domain-specific agents rather than relying mainly on generic tool-using assistants. Malware agents should integrate disassemblers, sandboxes, YARA/Sigma rules, behavioral traces, and threat-intelligence feeds. Binary-analysis agents should work with structured intermediate representations, debugger sessions, symbolic execution, and decompiler output. Protocol and fuzzing agents should reason over RFCs, message grammars, state machines, coverage feedback, and crash triage. Cloud and IaC agents should understand provider-specific APIs, identity

policies, deployment graphs, and blast-radius analysis. In each case, the application should define the agent’s domain model, tool semantics, evidence format, and acceptance criteria, not merely expose a shell and ask the LLM to proceed.

Future work should deepen defensive and human-centered applications. SOC, SOAR, incident-response, and cyber-defense agents should be designed around analyst workflows, including evidence provenance, escalation paths, uncertainty communication, and approval gates. COGNITIVE SOC [84] illustrates the value of evidence-backed narratives, but future systems should also assess whether agents reduce analyst workload, preserve situational awareness, and support accountable decisions under time pressure. For autonomous cyber defense, agents should reason not only about attack mitigation, but also about service continuity, recovery cost, mission impact, and operator trust. These concerns make defensive applications different from offensive benchmarks where success is often a single exploit or flag.

Application-level safety should become part of task design. Future papers should specify authorization scope, environment assumptions, allowed and forbidden actions, human approval requirements, logging obligations, and release constraints. Offensive applications should default to sandboxed or consent-based targets, and exploit-generation systems should report how dangerous artifacts are controlled. Defensive applications should define when the agent may recommend an action versus execute it. This risk-aware framing is especially important for web scanning, exploit development, agent-security red teaming, and autonomous response, where an apparently successful application can still be unsafe if it crosses operational or legal boundaries.

Finally, future research should study deployment fit and transfer across application contexts. A security agent that works on CTF tasks may not transfer to enterprise penetration testing; a repository auditor may not transfer from curated open-source projects to proprietary monorepos; a SOC summarizer may not transfer across organizations with different logging schemas and playbooks. Future applications should therefore report environmental assumptions, integration requirements, failure modes, and adaptation mechanisms. Cross-domain studies are also needed: for example, techniques from penetration-testing agents may help asset-discovery agents, while evidence-linking methods from SOC agents may improve vulnerability-report generation. The long-term goal is not only to build agents for many isolated security tasks, but to understand which application patterns generalize and which require domain-specific design.

7.3 Assessment of Agentic Approaches in Security Applications

The survey results on Assessment (§6.4) show that the community has started to move beyond one-dimensional accuracy reporting, but the assessment practice for LLM-based security agents is still immature. The surveyed papers collectively assess task effectiveness, agent trajectories, safety and reliability, baselines, and datasets; however, these dimensions are used unevenly. Task-level success, classification, time, and resource metrics are relatively common, while tool-call quality, safety, reproducibility, and human-utility measurements remain sparse.

7.3.1 Limitations and Challenges of Existing Works. Existing assessments still emphasize final task outcomes more than the agentic process that produces them. In Table 18, the most common task-effectiveness family is success/completion, used by 51% of the surveyed papers, followed by precision/recall/F1 at 34%, time/responsiveness at 25%, and accuracy/classification at 23%. These metrics are necessary for vulnerability detection, exploit execution, patch success, malware classification, and cyber-defense tasks, but they are not sufficient for assessing agentic approaches. An agent may reach the right answer through brittle tool use, hallucinated reasoning, excessive cost, unsafe side effects, or a trajectory that analysts cannot audit. Conversely, an agent may fail the final benchmark task but still make useful intermediate progress, such as correctly identifying an attack surface or generating a partially valid patch.

The process-level evidence reported by existing papers is uneven. Table 19 shows that cost/token efficiency appears in 32% of papers and steps to completion in 21%, but hallucination rate and report/explanation metrics appear in only 11% each, iteration count in 10%, artifact correctness in 3%, economic/bounty value in 2%, and tool-call accuracy in only 1%. This is a major limitation because long-horizon security agents plan, invoke tools, observe outputs, update memory, and produce intermediate artifacts. Resource use is now reported by a meaningful minority, but tool-call correctness is almost never measured directly, and hallucination and other trajectory-quality properties remain much less visible than final outcomes.

Safety and reliability are also underrepresented as assessment targets. Table 20 records consistency in 18% of papers, attack success rate in 10%, defense success in 8%, prompt-injection robustness in 6%, scope containment in 5%, utility-security tradeoff in 4%, and overhead in 3%. Even the most common family therefore appears in fewer than one fifth of the corpus. This is concerning because many LLM-based security agents are deployed in adversarial contexts by design: they inspect untrusted code, parse attacker-controlled logs, browse web applications, retrieve external knowledge, execute commands, or interact with sandboxes. Studies such as AgentDojo [20], AgentPoison [15], RedAgent [104], and ZT-ICAS [69] show that the agent itself can become an attack surface, but adversarial assessment is not yet routine.

The Dataset results further reveal a tension between realism and reproducibility. Table 22 shows substantial use of purpose-built programs and environments (50%), production systems (28%), curated public artifacts (23%), and threat feeds (17%). Table 24 shows that 36% of papers use fully real-world datasets and 47% use semi-synthetic datasets. Fully public datasets appear in 50% of papers, while some datasets require registration, are restricted, proprietary/internal, or leave access unspecified. Ground truth also remains difficult for open-ended tasks: only 16% of papers use explicitly expert/reference-verified labels, vulnerability datasets may contain noisy labels, and exploit, repair, and SOC assessments require stronger oracles than surface fluency.

Finally, current assessments are often hard to compare. Table 21 shows that 36% of papers compare with non-AI tools, 28% with other agent systems, 27% with prior ML/DL methods, 26% include ablations, 12% compare with humans, and 9% compare with plain LLMs. These numbers show that tool, model, agent, and component-level comparisons are increasingly common, but direct human and plain-LLM baselines remain uncommon. Assessment coverage is also uneven across application areas: Table 23 shows stronger dataset support for cyber-defense simulation, penetration testing and CTF tasks, SOC alerting, vulnerability detection, smart-contract analysis, and AI-agent security, while asset discovery, malware analysis, web-threat detection, security testing and fuzzing, and repair datasets are represented by fewer papers. Resource reporting has improved—cost/token efficiency appears in 32% of papers—but safety overhead appears in only 3%, and measurement conventions remain inconsistent despite being decisive for repository-scale auditing, SOC-scale alert streams, and continuous security pipelines.

7.3.2 Future Research Directions. Future work should report assessment as a multi-dimensional profile rather than a single score. A mature assessment protocol for agentic security systems should include at least four dimensions: *task effectiveness*, which captures whether the intended security outcome is achieved; *trajectory quality*, which captures how the agent reasons, uses tools, and revises its state; *safety and reliability*, which captures whether the agent remains bounded and robust under adversarial inputs; and *cost and reproducibility*, which captures whether the result can be practically rerun and deployed. Benchmarks such as BountyBench [112], CVE-Bench [117], and AgentDojo [20] point in this direction because they assess agents in executable or stateful environments, but the field still lacks a shared reporting template that makes results comparable across security applications.

Future assessments should treat the agent trajectory as a first-class object. For penetration testing and exploitation, this means measuring not only whether the target was compromised, but also how many steps were needed, whether reconnaissance actions were relevant, whether tool outputs were interpreted correctly, and whether unsafe or out-of-scope actions occurred. For repair, this means measuring the sequence of localization, patch generation, validation, and revision, as in PatchAgent [109] and RepairAgent [10]. For SOC and incident-response systems, this means assessing evidence linkage, citation coverage, hallucination rate, and explanation quality, as illustrated by Cognitive SOC [84]. More generally, future benchmarks should release execution traces or logs where possible, so researchers can analyze not only end states but also failure modes inside agent trajectories.

Safety assessment should also become a default component whenever an agent ingests untrusted artifacts or interacts with external tools. Future studies should test prompt-injection robustness, memory and retrieval poisoning, scope containment, consistency across repeated runs, and utility-security tradeoffs. Such assessments should report both security and utility: a defense is not satisfactory if it prevents compromise only by preventing the agent from completing useful work. Responsible assessment is equally important because many surveyed systems automate exploitation, red teaming, jailbreak generation, or vulnerability discovery. Future benchmarks should use sandboxed environments, clear scope boundaries, safe release policies, and artifact sanitization, while also reporting what is withheld and why.

Dataset construction is another important future direction. Future datasets should combine real-world structure, executable oracles, and public reproducibility. CVE-Bench [117] is a strong example because it reproduces real-world CVEs in sandboxed web applications and provides automated assessment against attack targets. BountyBench [112] is another example because it uses real bug-bounty systems and defines detect, exploit, and patch tasks with localized checks. For repository-level auditing, RepoAudit [31] highlights the importance of real codebases and validation against confirmed or fixed bugs. Future benchmarks should release environment setup scripts, task specifications, expected outputs, traces, validation oracles, and partial-credit rubrics whenever release is ethically and legally possible.

Comparative assessment should be strengthened through stronger baselines, controlled agent-to-agent comparisons, and ablations. Agent systems should be compared against strong non-agent baselines when those baselines exist, such as traditional scanners, fuzzers, static analyzers, APR tools, SOC runbooks, or reinforcement-learning defenders. AutoRestTest [44] and MultiFuzz [62] are useful examples because they compare against established testing and fuzzing tools. Agent-to-agent comparisons should control for model, budget, tool access, and environment; otherwise, it is difficult to know whether the improvement comes from the agent architecture, the underlying LLM, a larger token budget, or privileged tool access. Ablation studies should also become standard, as illustrated by PatchAgent [109], AutoRestTest [44], and PropertyGPT [51], because the term “agent” hides many components, including planning, memory, retrieval, tool wrappers, validators, critics, and feedback loops.

Finally, future research should broaden assessment coverage and make cost explicit. Malware analysis needs datasets that combine static evidence, dynamic behavior, family attribution, and analyst-facing reports, as suggested by MAD-Agent [102]. Asset discovery and OSINT need assessments that capture both retrieval quality and time-to-discovery, not just final asset lists. SOC/SOAR systems need more alert streams with evidence provenance and analyst-review criteria. Repair and hardening need datasets that connect real vulnerabilities, proof-of-concept triggers, functional tests, and patch validity. Across all such tasks, future papers should report token usage, wall-clock time, monetary cost, infrastructure assumptions, and variance across runs. In this sense, assessment of LLM-based security agents is itself a security problem: the benchmark must be realistic enough to measure capability, controlled enough to prevent harm, and transparent enough to support scientific progress.

7.4 Cross-Cutting Future Research Directions

The preceding subsections discussed future work separately from the perspectives of approach, application, and assessment. These three perspectives, however, should not evolve independently. For LLM-based agents in software and systems security, technical architecture determines what applications are feasible; application context determines which risks and evidence matter; and assessment determines whether the resulting system is trustworthy, useful, and reproducible. We therefore summarize several cross-cutting research directions that span all three survey aspects.

7.4.1 Co-Designing Agent Architectures, Security Tasks, and Assessment Protocols. Future work should co-design the agent approach, target application, and assessment protocol from the beginning. Many current papers introduce an agent architecture, apply it to a task, and then assess the final outcome with task-specific metrics. This pipeline is understandable for early-stage research, but it can hide mismatches between design and use. A penetration-testing agent, a repository-auditing agent, a SOC triage agent, and a patch-generation agent should not differ only in prompts and tools; they require different authority boundaries, evidence models, success conditions, and failure-handling mechanisms.

A cross-cutting design methodology should therefore begin with the security task's operational requirements. If the application is vulnerability repair, the architecture should include localization, patch generation, validation, and regression-safety components, and the assessment should measure both security fixes and functional preservation. If the application is SOC investigation, the architecture should preserve evidence provenance and analyst review points, and the assessment should measure evidence linkage, hallucination, timeliness, and human usefulness. If the application is exploit generation or red teaming, the architecture should encode scope control and sandboxing, and the assessment should report both capability and containment. This co-design would make the term agent more precise: the agent would be defined by the task it can safely perform, the evidence it can use, and the assessment standard it must satisfy.

7.4.2 Evidence-Centered and Auditable Agentic Security. Across all three survey aspects, evidence is the central missing abstraction. Approach-wise, agents need memory, perception, reasoning, and tool-use mechanisms that distinguish observed facts from hypotheses, generated text, retrieved knowledge, and validated findings. Application-wise, security decisions must be traceable to concrete artifacts such as code locations, logs, packets, exploit outputs, test results, SBOM entries, CVE records, or analyst annotations. Assessment-wise, final-answer correctness is insufficient unless the supporting evidence can be inspected.

Thus, future agents should maintain explicit evidence graphs or evidence ledgers. Each security-relevant claim should record its source, time, tool or model that produced it, confidence, validation status, and downstream uses. This would support repository auditing, incident response, threat intelligence, repair, and penetration testing alike. For example, REPOAUDIT [31] points toward evidence-constrained repository exploration, while COGNITIVE SOC [84] highlights evidence-linked incident narratives. Future work should generalize these ideas into reusable evidence-management layers for security agents. Such layers would also improve assessment: benchmarks could check not only whether the final answer is correct, but whether the supporting chain of evidence is complete, faithful, and minimally sufficient.

7.4.3 Risk-Aware Autonomy and Governance. The survey shows that many security agents are designed for autonomous or near-autonomous operation, but autonomy has different implications across applications. A fully autonomous agent that summarizes alerts is different from one that executes exploits, modifies production code, changes firewall rules, or updates cloud policies. Approach research must therefore expose control points for authorization, rollback, human approval, and policy enforcement. Application research must define what actions are allowed in each security

setting. Assessment research must measure whether agents stay within those boundaries under normal, erroneous, and adversarial conditions.

Future work should develop risk-aware autonomy levels for security agents. Low-risk tasks, such as offline summarization or documentation retrieval, may permit fully autonomous execution. Medium-risk tasks, such as vulnerability triage or patch recommendation, may require human-on-the-loop review. High-risk tasks, such as exploit execution, production remediation, disclosure decisions, and active response, should require explicit human-in-the-loop approval or policy-verified execution. These autonomy levels should be reported as part of the agent design and benchmark setup. They should also be stress-tested against prompt injection, retrieval poisoning, malicious tool output, and scope-confusion attacks, following the concerns raised by benchmarks and systems such as AgentDojo [20], AgentPoison [15], RedAgent [104], and ZT-ICAS [69].

7.4.4 Realistic, Reproducible, and Safe Benchmark Ecosystems. A recurring issue across the approach, application, and assessment results is the lack of benchmark ecosystems that are simultaneously realistic, reproducible, and safe. Realistic applications need live services, repositories, attack surfaces, logs, binaries, cloud configurations, or cyber-range states. Reproducible assessment needs stable setup scripts, task definitions, labels, oracles, and comparable baselines. Safe release needs scope boundaries, artifact sanitization, and clear policies for exploit or vulnerability disclosure. Most existing studies optimize only part of this triangle.

Future benchmark ecosystems should package tasks as executable, instrumented environments rather than static datasets whenever the application requires interaction. CVE-Bench [117] and BountyBench [112] illustrate this direction for vulnerability exploitation and bug-bounty workflows; similar benchmark ecosystems are needed for SOC investigation, cloud/IaC security, malware analysis, protocol fuzzing, repair, access-control review, and supply-chain security. These benchmarks should include task metadata, allowed actions, expected evidence, validation oracles, baseline tools, resource budgets, and safety policies. They should also preserve trajectories where possible, because agent behavior is defined by the path from observation to action, not only by the final output.

7.4.5 Cost, Scalability, and Resource Governance. Cost and scalability cut across all three aspects. Approach choices such as multi-agent orchestration, long-context retrieval, repeated tool calls, verifier loops, and persistent memory can improve capability but also increase token usage, latency, and infrastructure cost. Application settings such as repository-scale auditing, SOC alert streams, cloud posture management, and internet-scale asset discovery require sustained operation rather than one-off benchmark runs. Assessment must therefore account for resource use as a first-class outcome.

Future research should report and optimize token cost, wall-clock time, tool-call count, infrastructure requirements, memory growth, and variance across runs. More importantly, agents should make resource-aware decisions: when to retrieve more context, when to call an expensive model, when to invoke a heavyweight analyzer, when to stop exploring, and when to ask for human input. This suggests a need for budget-aware planning and adaptive execution policies. Such policies should be assessed against both security effectiveness and resource consumption, because an agent that is accurate but too expensive or slow may be impractical for continuous security workflows.

7.4.6 Human-Agent Collaboration as a Security Interface. Human involvement should be studied as a cross-cutting design problem rather than a minor workflow option. Approach research should design interfaces that expose uncertainty, evidence, alternatives, and planned actions. Application research should identify where humans add judgment, authority, or domain context: approving exploit attempts, prioritizing vulnerabilities, interpreting business impact, validating

incident narratives, or deciding whether to deploy a patch. Assessment research should measure whether agent outputs actually improve human decisions, reduce workload, and preserve accountability.

Future studies should therefore move beyond fully automated benchmark scores and include human-centered assessment where the application requires professional judgment. For SOC, incident-response, vulnerability-management, and cloud-security settings, useful measures include analyst time saved, review accuracy, trust calibration, escalation quality, and error recovery. Human-agent collaboration should also be bidirectional: humans should be able to correct agent state, mark evidence as trusted or untrusted, constrain future actions, and inspect why an agent made a recommendation. In high-impact security settings, a usable agent is not merely one that produces the right answer; it is one whose reasoning and authority can be governed by the people responsible for the system.

7.4.7 Toward Generalizable Security-Agent Engineering Principles. Finally, the field needs reusable engineering principles that explain which agent patterns generalize across security tasks and which must remain domain-specific. Some capabilities, such as evidence tracking, tool-use validation, memory provenance, risk-based approval, and cost-aware planning, appear broadly useful across vulnerability detection, pentesting, incident response, repair, and SecOps. Other capabilities, such as exploit-chain construction, malware sandbox interpretation, protocol-state modeling, or cloud-policy reasoning, require domain-specific representations and tools.

Future work should compare agent designs across multiple security applications under controlled conditions. This would help identify when a multi-agent architecture is genuinely useful, when retrieval improves robustness, when verifier modules reduce false positives, when fine-tuning is preferable to prompting, and when human checkpoints improve safety without eliminating utility. The longer-term goal is to move from isolated prototypes to an engineering discipline for LLM-based security agents: a body of patterns, benchmarks, reporting standards, and safety practices that connects approach, application, and assessment into one coherent research agenda.

8 Threats to Validity

Our survey results are subject to validity threats because the studied area is recent, fast-moving, and terminologically unstable. LLM-based agents for software and systems security are described using overlapping terms such as autonomous agents, agentic workflows, multi-agent systems, tool-using LLMs, and LLM-based security assistants. Moreover, many surveyed works target dual-use security tasks, which affects dataset release, benchmark design, reproducibility, and the kinds of assessments that authors can report. We therefore discuss the main threats associated with our literature search, taxonomy derivation, paper attribution, and result analysis.

Literature search. The first threat concerns coverage of the literature. We used keyword-based search and forward/backward snowballing to identify papers published between January 2023 and March 2026, but relevant papers may still have been missed. This risk is heightened because the terminology around LLM agents is not yet standardized: some papers may describe similar systems as assistants, copilots, planners, tool-augmented LLMs, or multi-step workflows without using the word “agent.” Conversely, papers that use the term “agent” may not implement an agentic system in the sense used by this survey. We mitigated this threat by combining multiple agent-related and security-task-related keywords, manually screening candidate papers, and using snowballing from the seed set to recover papers that keyword search alone may not find.

A second search-related threat comes from our scope decisions. We focused on peer-reviewed papers and excluded studies exclusively available on arXiv, short papers, posters, non-English papers, and papers outside the January 2023 to March 2026 window. These criteria improve the consistency and inspectability of the corpus, but they may exclude

emerging systems, industry reports, technical blogs, benchmark repositories, or very recent preprints that influence practice. This is a tradeoff of the survey design. Our results should therefore be interpreted as a structured view of the peer-reviewed literature in the selected time window, not as an exhaustive inventory of all deployed or publicly released LLM-based security-agent systems.

Survey taxonomy derivation. Our taxonomy was derived through manual coding of the surveyed papers into the three aspects of Approach, Application, and Assessment. Although this process was grounded in recurring concepts observed in the corpus, alternative researchers could choose different abstraction levels. For example, one taxonomy might separate web penetration testing from CTF solving, while another might group both under offensive assessment. Similarly, one taxonomy might treat retrieval, memory, and context management as one design attribute, while ours separates them when they imply different agent capabilities.

We mitigated this threat by using the taxonomy for paper attribution and result analysis, rather than treating it as a standalone conceptual proposal. Items were retained when they captured recurring distinctions in the surveyed papers and helped explain differences in agent design, security task coverage, or assessment practice. We also organized the taxonomy around three high-level questions that are stable across the literature: how the agent is built, what security task it performs, and how its behavior is assessed. Even so, the taxonomy should be viewed as an evolving synthesis. As the field matures, new attributes may be needed for issues such as long-term memory governance, agent supply-chain risk, tool-permission models, and deployment-time monitoring.

Paper attribution. The third threat concerns the mapping of papers to taxonomy items. Many LLM-based security agents are multi-component systems, and a single paper may legitimately belong to multiple categories. For instance, a system may combine retrieval, planning, tool execution, verification, and reporting; it may address both vulnerability detection and repair; and it may assess both final task success and trajectory properties. Such multi-label attribution is necessary, but it introduces judgment calls about how much evidence is sufficient to assign an item.

We mitigated this threat by coding papers according to explicit descriptions in the paper text, including architecture descriptions, workflows, datasets, metrics, and experimental protocols. For the Assessment metric tables, we revisited the full text of every paper with an initially blank row, examining the methods, experimental setup, results, and appendices where available rather than relying on the abstract or introduction. We added every mapping supported by a reported measure and retained a blank only when the relevant metric family remained unspecified. When a paper described multiple relevant capabilities, we allowed multiple attributions rather than forcing a single primary category. We also considered duplicate or substantially overlapping publications to avoid counting the same contribution multiple times. Nevertheless, some ambiguity remains. Authors do not always use consistent terminology, and papers vary greatly in how much detail they provide about prompts, tools, memory, orchestration, datasets, baselines, and release artifacts. Our attribution should therefore be read as a best-effort characterization of the available evidence rather than as a definitive implementation audit.

Survey result analysis. The fourth threat concerns interpretation of the attributed results. Because LLM-based security agents depend heavily on foundation models, tool access, prompts, execution environments, and resource budgets, results reported by different papers are often not directly comparable. A performance difference may come from the agent architecture, the underlying model, the benchmark, the available tools, the amount of context, the number of attempts, or the assessment budget. The field is also changing quickly: models, APIs, cyber ranges, and benchmark versions may change after publication, and some reported results may become difficult to reproduce.

We mitigated this threat by emphasizing patterns across papers rather than ranking individual systems. Our analysis therefore focuses on recurring gaps, such as limited safety assessment, weak trajectory-level reporting, uneven baseline comparisons, concentration around vulnerability-centric applications, and insufficient human-governance mechanisms. These conclusions are less sensitive to any single paper’s result. Still, the survey may understate industrial practice, overstate published benchmark coverage, or miss negative results that were not published. The future research directions we identify should be interpreted as grounded recommendations from the available literature, not as claims that every individual system suffers from every limitation.

9 Conclusion

This paper presented a systematic survey of LLM-based agents for software and systems security, covering 100 peer-reviewed papers published between January 2023 and March 2026 and organized around three aspects: *Approach*, *Application*, and *Assessment*.

Our survey shows that LLM-based security agents have rapidly moved from simple prompt-response systems toward modular, tool-mediated, and often autonomous workflows, and that the resulting field is unevenly developed along a consistent axis. Agents are built to act: 91% adopt a modular pipeline, 88% place the backbone LLM in a planner-and-actor role, and 95% support fully autonomous operation. They are far less often built to be bounded or inspected: explicit critic or verifier roles appear in 15% of systems, guardrail layers in 13%, and any human review point in 13%. Assessment mirrors this asymmetry. Outcome measures are routine—success or completion in 51% of papers, precision/recall/F1 in 34%—while the measures that would expose *how* an outcome was reached are not: hallucination rate appears in 11%, scope containment in 5%, and tool-call accuracy in 1%, despite nearly every surveyed system being tool-using. Applications concentrate around the vulnerability lifecycle and offensive assessment, leaving post-access phases, low-level artifact analysis, and governance-oriented tasks such as access-control review and supply-chain security comparatively undeveloped.

The central message of this survey is that security agents should be studied as operational systems, not merely as prompts wrapped around LLMs. Their value depends on how they gather evidence, use tools, maintain state, respect authority boundaries, recover from errors, communicate with humans, and behave under adversarial conditions. Future progress in this field will require co-design across the three aspects: architectures shaped by the security tasks they perform, applications that encode evidence and risk requirements, and assessments that measure process quality, safety, cost, and human oversight alongside final outcomes. The field has built agents able to act; building agents whose authority is bounded and whose behavior is auditable remains the open problem.

References

- [1] Sherif Abdelhamid, James Bangura, Katelyn Redlinger, and Gunnar Romsland. Trustnet: A hybrid machine learning and llm-based multi-agent system for scam website detection. In *IEEE International Conference on AI in Cybersecurity (ICAIC)*, pages 1–6, 2026.
- [2] Talor Abramovich, Meet Udeshi, Minghao Shao, Kilian Lieret, Haoran Xi, Kimberly Milner, Sofija Jancheska, John Yang, Carlos E. Jimenez, Farshad Khorrami, Prashanth Krishnamurthy, Brendan Dolan-Gavitt, Muhammad Shafique, Karthik R. Narasimhan, Ramesh Karri, and Ofir Press. EnIGMA: Interactive Tools Substantially Assist LM Agents in Finding Security Vulnerabilities. In *International Conference on Machine Learning (ICML)*, pages 1–110, 2025.
- [3] Erik Adler, Johannes F. Loevenich, Linnet Moxon, Tobias Hürten, Florian Spelter, Johannes Braun, Yann Gourlet, Thomas Lefevre, and Roberto Rigolin F. Lopes. Exploring the potential of large language models for red teaming in military coalition networks. In *MILCOM IEEE Military Communications Conference (MILCOM)*, pages 170–175, 2024.
- [4] Erik Adler, Johannes F. Loevenich, Florian Spelter, Tobias Hürten, Damian Roncevic, Maxime Schwarzer, and Roberto Rigolin F. Lopes. Llm for penetration testing: Solving ctf challenges using offensive cybersecurity tools. In *International Conference on Cybersecurity and AI-Based Systems (Cyber-AI)*, pages 43–50, 2025.

- [5] Abdullah Aldaihan, Fahad Alotaibi, and Sergio Maffei. Clouseau: A hierarchical multi-agent approach for autonomous attack investigation. In *IEEE Annual Computer Security Applications Conference (ACSAC)*, pages 516–532, 2025.
- [6] Ross Anderson. *Security Engineering: A Guide to Building Dependable Distributed Systems*. Wiley, 3rd edition, 2020.
- [7] Anthropic. The Claude 3 Model Family: Opus, Sonnet, Haiku. <https://www.anthropic.com/news/claude-3-family>, 2024.
- [8] Daniel Ayzenshteyn, Roy Weiss, and Yisroel Mirsky. Cloak, honey, trap: Proactive defenses against LLM agents. In *USENIX Security Symposium (USENIX Security 25)*, pages 8095–8114, 2025.
- [9] Stanislas G. Bianou and Rodrigue G. Batogna. Pentest-ai, an llm-powered multi-agents framework for penetration testing automation leveraging mitre attack. In *IEEE International Conference on Cyber Security and Resilience (CSR)*, pages 763–770, 2024.
- [10] Islem Bouzenia, Premkumar Devanbu, and Michael Pradel. Repairagent: An autonomous, llm-based agent for program repair. In *IEEE/ACM International Conference on Software Engineering (ICSE)*, pages 2188–2200, 2025.
- [11] Tri Cao, Chengyu Huang, Yuexin Li, Wang Huilin, Amy He, Nay Oo, and Bryan Hooi. PhishAgent: A Robust Multimodal Agent for Phishing Webpage Detection. *AAAI Conference on Artificial Intelligence*, 39(27):27869–27877, 2025.
- [12] Xinye Cao, Guoshun Nan, Hongcan Guo, Hanqing Mu, Long Wang, Yihan Lin, Qinchuan Zhou, Jiayi Li, Baohua Qin, Qimei Cui, Xiaofeng Tao, He Fang, Haitao Du, and Tony Q. S. Quek. Exploring llm-based multi-agent situation awareness for zero-trust space-air-ground integrated network. *IEEE Journal on Selected Areas in Communications*, 43(6):2230–2247, 2025.
- [13] Xiang Chen, Anshunkang Zhou, Chengfeng Ye, and Charles Zhang. Clearagent: Agentic binary analysis for effective vulnerability detection. In *ACM SIGPLAN International Workshop on Language Models and Programming Languages*, pages 130–137, 2025.
- [14] Xuefei Chen, Yuqi Zhang, Haohao Liu, Xiaotong Wang, Chen Li, and Bibo Tu. End-to-end security policy automation with multi-llm agents in cloud-native systems. In *IEEE International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom)*, pages 175–183, 2025.
- [15] Zhaorun Chen, Zhen Xiang, Chaowei Xiao, Dawn Song, and Bo Li. AgentPoison: Red-Teaming LLM Agents via Poisoning Memory or Knowledge Bases. In *Advances in Neural Information Processing Systems 37*, pages 130185–130213, 2024.
- [16] Zhengkun Chen, Chuanjun Yi, and Pan Jia. Agentic rag for command generation in automated penetration testing. In *International Conference on Signal Processing, Computer Networks and Communications (SPCNC)*, pages 579–583, 2025.
- [17] Hassan Chowdhry, Jaume Manero, and Srinivas Sampalli. Evaluating ai agents for cyber defense: A comparison of deep reinforcement learning and llm approaches. In *International Conference on Intelligent Data Engineering and Automated Learning*, pages 423–433, 2025.
- [18] Hanzheng Dai, Yuanliang Li, Jun Yan, and Zhibo Zhang. Repentester: A knowledge-informed self-reflective penetration testing framework based on large language models. In *Annual International Conference on Privacy, Security, and Trust (PST)*, pages 1–8, 2025.
- [19] Francesco De Santis, Kai Huang, Rodolfo Valentim, Danilo Giordano, Marco Mellia, Zied Ben Houidi, and Dario Rossi. Cfa-bench: Cybersecurity forensic llm agent benchmark and testing. In *IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*, pages 217–225, 2025.
- [20] Edoardo DeBenedetti, Jie Zhang, Mislav Balunovic, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. In *Advances in Neural Information Processing Systems (NeurIPS)*, pages 82895–82920, 2024.
- [21] DeepSeek-AI. DeepSeek LLM: Scaling Open-Source Language Models with Longtermism. *arXiv preprint arXiv:2401.02954*, pages 1–48, 2024.
- [22] Gelei Deng, Yi Liu, Victor Mayoral-Vilches, Peng Liu, Yuekang Li, Yuan Xu, Tianwei Zhang, Yang Liu, Martin Pinzger, and Stefan Rass. PentestGPT: Evaluating and harnessing large language models for automated penetration testing. In *USENIX Security Symposium (USENIX Security 24)*, pages 847–864, 2024.
- [23] Gergely Eberhardt and Ákos Milánkovich. Vulngpt: Enhancing source code vulnerability detection using autogpt and adaptive supervision strategies. In *International Conference on Distributed Computing in Smart Systems and the Internet of Things (DCOSS-IoT)*, pages 450–454, 2024.
- [24] Even Eilertsen, Vasileios Mavroeidis, and Gudmund Grov. Towards agentic investigation of security alerts. In *IEEE International Conference on Big Data (BigData)*, pages 7793–7802, 2025.
- [25] Angela Fan, Beliz Gokkaya, Mark Harman, Mitya Lyubarskiy, Shubho Sengupta, Shin Yoo, and Jie M. Zhang. Large Language Models for Software Engineering: Survey and Open Problems. In *IEEE/ACM International Conference on Software Engineering: Future of Software Engineering (ICSE-FoSE)*, pages 31–53, 2023.
- [26] Mamatha G S, Vibha V Joshi, and Pranitha T Manur. Llm - driven autonomous cloud automation agent. In *International Conference on Computational System and Information Technology for Sustainable Solutions (CSITSS)*, pages 1–6, 2025.
- [27] Gemini Team, Google. Gemini: A Family of Highly Capable Multimodal Models. *arXiv preprint arXiv:2312.11805*, pages 1–90, 2023.
- [28] Xiaoyu Geng, Ning An, Boyuan Xu, Xiaobo Yang, Bo Jiang, Baoxu Liu, and Junrong Liu. Controller makes pentesting better: An improved multi-agent automated penetration testing framework. In *IEEE International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom)*, pages 845–852, 2025.
- [29] Yasod Ginige, Akila Niroshan, Sajal Jain, and Suranga Seneviratne. Autopentester: An llm agent-based framework for automated pentesting. In *IEEE International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom)*, pages 163–174, 2025.
- [30] Shengkang Gu, Jiahao Liu, Dongsheng Li, Guangping Zhang, Mingzhe Han, Hansu Gu, Peng Zhang, Ning Gu, Li Shang, and Tun Lu. Llm agent-based shilling attack on recommender systems. In *ACM International Conference on Web Search and Data Mining*, pages 163–173, 2026.
- [31] Jinyao Guo, Chengpeng Wang, Xiangzhe Xu, Zian Su, and Xiangyu Zhang. Repoaudit: An autonomous LLM-agent for repository-level code auditing. In *International Conference on Machine Learning*, pages 1–18, 2025.

- [32] Andreas Happe, Aaron Kaplan, and Juergen Cito. Llms as hackers: Autonomous linux privilege escalation attacks. *Empirical Software Engineering*, 31(3):70, 2026.
- [33] Mohammed Hassanin and Nour Moustafa. A Comprehensive Overview of Large Language Models (LLMs) for Cyber Defences: Opportunities and Directions. *arXiv preprint arXiv:2405.14487*, pages 1–20, 2024.
- [34] Yasser Hmimou, Mohamed Tabaa, Azeddine Khia, and Zineb Hidila. A multi-agent system for cybersecurity threat detection and correlation using large language models. *IEEE Access*, 13:150199–150215, 2025.
- [35] Ritesh Honnalli and Junaid Farooq. Llm-powered agentic ai approach to securing ev charging systems against cyber threats. In *IEEE International Symposium on a World of Wireless, Mobile and Multimedia Networks (WoWMoM)*, pages 266–274, 2025.
- [36] Sihao Hu, Tiansheng Huang, Fatih İlhan, Selim Furkan Tekin, and Ling Liu. Large language model-powered smart contract vulnerability detection: New perspectives. In *IEEE International Conference on Trust, Privacy and Security in Intelligent Systems and Applications (TPS-ISA)*, pages 297–306, 2023.
- [37] Xiaowei Hu, Haoning Chen, Huaifeng Bao, Wen Wang, Feng Liu, Guoqiao Zhou, and Peng Yin. A llm-based agent for the automatic generation and generalization of ids rules. In *IEEE International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom)*, pages 1875–1880, 2024.
- [38] Junjie Huang and Quanyan Zhu. Penheal: A two-stage llm framework for automated pentesting and optimal remediation. In *Proceedings of the Workshop on Autonomous Cybersecurity*, pages 11–22, 2024.
- [39] Ismail, Rahmat Kurnia, Zilmas Arjuna Brata, Ghitha Afina Nelistiani, Shinwook Heo, Hyeongon Kim, and Howon Kim. Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence. *Information*, 16(5):365, 2025.
- [40] Zimo Ji, Daoyuan Wu, Wenyuan Jiang, Pingchuan Ma, Zongjie Li, and Shuai Wang. Measuring and augmenting large language models for solving capture-the-flag challenges. In *ACM SIGSAC Conference on Computer and Communications Security*, pages 603–617, 2025.
- [41] Yutong Jiao, Jiaxuan Han, and Cheng Huang. Deepvulhunter: enhancing the code vulnerability detection capability of llms through multi-round analysis. *Journal of Intelligent Information Systems*, 63(6):2237–2264, 2025.
- [42] Wanqing Jie, Wangjie Qiu, Haofu Yang, Muyuan Guo, Xinpeng Huang, Tianyu Lei, Qinnan Zhang, Hongwei Zheng, and Zhiming Zheng. Agent4vul: multimodal llm agents for smart contract vulnerability detection. *Science China Information Sciences*, 68(6):160101, 2025.
- [43] Carlos E. Jimenez, John Yang, Alexander Wettig, Shunyu Yao, Kexin Pei, Ofir Press, and Karthik Narasimhan. SWE-bench: Can Language Models Resolve Real-World GitHub Issues? In *International Conference on Learning Representations*, 2024.
- [44] Myeongsoo Kim, Tyler Stennett, Saurabh Sinha, and Alessandro Orso. A multi-agent approach for rest api testing with semantic graphs and llm-driven inputs. In *IEEE/ACM International Conference on Software Engineering (ICSE)*, pages 1409–1421, 2025.
- [45] Silja Kluge, Laurin Holz, Johannes F. Loevenich, and Roberto Rigolin F. Lopes. Explaining hybrid rl agents for cyber defense using shap and reward decomposition. In *MILCOM IEEE Military Communications Conference (MILCOM)*, pages 1–6, 2025.
- [46] Tianwei Lan and Farid Nait-Abdesselam. Adversarial agents: Llm-powered attacks and defenses for android malware detectors. In *IEEE Conference on Dependable and Secure Computing (DSC)*, pages 1–8, 2025.
- [47] Amine Lbath, Massih-Reza Amini, Aurelien Delaitre, and Vadim Okun. Aviator: Towards ai-agentic vulnerability injection workflow for high-fidelity, large-scale code security dataset. pages 1–46, 2025.
- [48] Chunling Liu, Tieming Liu, Yonghe Tang, and Jian Lin. Vvf-ai: A vulnerability verification framework based on ai-agent. In *IEEE International Seminar on Artificial Intelligence, Networking and Information Technology (AINIT)*, pages 960–964, 2025.
- [49] Fengyu Liu, Yuan Zhang, Jiaqi Luo, Jiarun Dai, Tian Chen, Letian Yuan, Zhengmin Yu, Youkun Shi, Ke Li, Chengyuan Zhou, Hao Chen, and Min Yang. Make agent defeat agent: Automatic detection of Taint-Style vulnerabilities in LLM-based agents. In *USENIX Security Symposium (USENIX Security 25)*, pages 3767–3786, 2025.
- [50] Junwei Liu, Kaixin Wang, Yixuan Chen, Xin Peng, Zhenpeng Chen, Lingming Zhang, and Yiling Lou. Large language model-based agents for software engineering: A survey. *ACM Trans. Softw. Eng. Methodol.*, pages 1–87, 2026.
- [51] Ye Liu, Yue Xue, Daoyuan Wu, Yuqiang Sun, Yi Li, Miaolei Shi, and Yang Liu. PropertyGPT: LLM-Driven Formal Verification of Smart Contracts through Retrieval-Augmented Property Generation. In *Network and Distributed System Security Symposium*, pages 1–17, 2025.
- [52] Ye Liu, Yulei Yuan, Yuntian Zhu, Luolin Hu, and Lei Wang. Research on design and implementation of an intelligent network asset search system based on llm agent and fofa. In *International Conference on Cyber Security, Artificial Intelligence and the Digital Economy*, pages 483–488, 2025.
- [53] Zefang Liu. Autobnb: Multi-agent incident response with large language models. In *International Symposium on Digital Forensics and Security (ISDFS)*, pages 1–6, 2025.
- [54] Johannes Loevenich, Erik Adler, Tobias Hürten, and Roberto Rigolin F. Lopes. Design and evaluation of an autonomous cyber defence agent using drl and an augmented llm. *Computer Networks*, 262:111162, 2025.
- [55] Johannes F. Loevenich, Erik Adler, Adrien Bécue, Alexander Velazquez, Konrad Wrona, Vasil Boshnakov, Jerry Falkcrona, Nils Nordbotten, Olwen L. Worthington, Juha Röning, Roberto Rigolin, and F. Lopes. Training autonomous cyber defense agents: Challenges & opportunities in military networks. In *MILCOM IEEE Military Communications Conference (MILCOM)*, pages 158–163, 2024.
- [56] Johannes F. Loevenich, Erik Adler, Tobias Hürten, Florian Spelter, Damian Roncovic, and Roberto Rigolin F. Lopes. Automating cyber threat intelligence and attack chain generation using cyber security knowledge graphs and large language models. In *International Conference on Military Communication and Information Systems (ICMCIS)*, pages 1–10, 2025.

- [57] Johannes F. Loevenich, Erik Adler, Rémi Mercier, Alexander Velazquez, and Roberto Rigolin F. Lopes. Design of an autonomous cyber defence agent using hybrid ai models. In *International Conference on Military Communication and Information Systems (ICMCIS)*, pages 1–10, 2024.
- [58] Johannes F. Loevenich and Roberto Rigolin F. Lopes. Agentic generative ai for automation of cyber security attack chains in tactical manets. In *IEEE Conference on Local Computer Networks (LCN)*, pages 1–7, 2025.
- [59] Haoxiang Luo, Gang Sun, Yinqiu Liu, Dusit Niyato, Hongfang Yu, Mohammed Atiquzzaman, and Schahram Dustdar. A trustworthy agentic multi-llm network: Challenges, solutions, and a use case. *IEEE Wireless Communications*, pages 1–10, 2026.
- [60] Zhengxiong Luo, Huan Zhao, Dylan Wolff, Cristian Cadar, and Abhik Roychoudhury. Agentic Concolic Execution. In *IEEE Symposium on Security and Privacy (SP)*, pages 37–55, 2026.
- [61] Wei Ma, Daoyuan Wu, Yuqiang Sun, Tianwen Wang, Shangqing Liu, Jian Zhang, Yue Xue, and Yang Liu. Combining fine-tuning and llm-based agents for intuitive smart contract auditing with justifications. In *IEEE/ACM International Conference on Software Engineering (ICSE)*, pages 1742–1754, 2025.
- [62] Youssef Maklad, Fares Wael, Ali Hamdi, Wael Elersy, and Khaled Shaban. Multifuzz: A dense retrieval-based multi-agent system for network protocol fuzzing. In *IEEE/ACS International Conference on Computer Systems and Applications (AICCSA)*, pages 1–8, 2025.
- [63] Jiahao Mei, Shuangwu Chen, Yuanyi Ma, and Huizi Song. AutoPen: Towards Autonomous Penetration Testing Using LLM-Powered Agents. In *Proceedings of the 9th International Conference on Computer Science and Application Engineering*, pages 1–6, 2025.
- [64] Vishal Bharadwaj Meruga. Llm-guided multi-agent collaboration for complex task automation. In *International Conference on Emerging Research in Electronics, Computer Science and Technology (ICERECT)*, pages 1–7, 2025.
- [65] Hamoun Mohammadi, Jonathan J. Davis, and Mitchell Kiely. Leveraging large language models for autonomous cyber defense: Insights from cage-2 simulations. *IEEE Intelligent Systems*, 40(4):29–36, 2025.
- [66] Liang-bo Ning, Shijie Wang, Wenqi Fan, Qing Li, Xin Xu, Hao Chen, and Feiran Huang. Cheatagent: Attacking llm-empowered recommender systems via llm agent. In *ACM SIGKDD Conference on Knowledge Discovery and Data Mining*, pages 2284–2295, 2024.
- [67] OpenAI. GPT-4 Technical Report. *arXiv preprint arXiv:2303.08774*, pages 1–100, 2023.
- [68] Jothsna Praveena Pendyala, Sundeep Bobba, and Ali Azghar Hussain Syed Abbas. A self-adaptive red teaming framework for vulnerability profiling with dynamic attack graphs and retrieval augmented generation. In *IEEE International Conference on AI in Cybersecurity (ICAIC)*, pages 1–7, 2026.
- [69] Jothsna Praveena Pendyala and Sumeet Jeswani. Zt-icas: A zero-trust integrity-constrained framework for agentic vulnerability scanning. In *IEEE International Conference on AI in Cybersecurity (ICAIC)*, pages 1–7, 2026.
- [70] Adnan Qayyum, Abdullatif Albaseer, Junaid Qadir, Ala Al-Fuqaha, and Mohamed Abdallah. Llm-driven multi-agent architectures for intelligent self-organizing networks. *IEEE Network*, 40(4):1–10, 2025.
- [71] Qi Qin, Xinye Cao, Guoshun Nan, Sihan Chen, Rushan Li, Li Su, Haitao Du, Qimei Cui, Pengxuan Mao, Xiaofeng Tao, and Tony Q.S. Quek. An llm-based self-evolving security framework for 6g space-air-ground integrated networks. *IEEE Communications Magazine*, 63(10):110–116, 2025.
- [72] Maria Rigaki, Carlos A. Catania, and Sebastian Garcia. Building adaptative and transparent cyber agents with local language models. *Expert Systems with Applications*, 299:129987, 2026.
- [73] Maria Rigaki, Ondřej Lukáš, Carlos Catania, and Sebastian Garcia. Prompt. exploit. repeat: Automating network security testing with llms. In *International Conference on Agents and Artificial Intelligence*, pages 15–36, 2024.
- [74] Maria Rigaki, Ondřej Lukáš, Carlos Catania, and Sebastian Garcia. Out of the cage: How stochastic parrots win in cyber security environments. In *International Conference on Agents and Artificial Intelligence - Volume 3: ICAART*, pages 774–781, 2024.
- [75] Yakub Kayode Saheed and Joshua Ebere Chukwuere. Autonomous llm agent: A memory-augmented, edge-optimized shap explanations with zero-day attack resilience in iot/industrial iot networks. *IEEE Internet of Things Journal*, 13(7):14213–14228, 2026.
- [76] Md Nazmus Sakib and Latifur Khan. Vulnpatch: Multi-agent automated smart contract vulnerability detection, explanation, and mitigation framework. In *International Conference on Blockchain Computing and Applications (BCCA)*, pages 301–309, 2025.
- [77] Amirreza Samari, Parsa Hedayatnia, Seyyed Javad Bozorgzadeh Razavi, Mohammad Allahbakhsh, and Haleh Amintoosi. Collaborative llm reasoning for vulnerability detection in smart contracts. In *International Conference on Computer and Knowledge Engineering (ICCCKE)*, pages 1–8, 2025.
- [78] Timo Schick, Jane Dwivedi-Yu, Roberto Dessi, Roberta Raileanu, Maria Lomeli, Luke Zettlemoyer, Nicola Cancedda, and Thomas Scialom. Toolformer: Language Models Can Teach Themselves to Use Tools. In *Advances in Neural Information Processing Systems 36*, pages 68539–68551, 2023.
- [79] Ben Luca Schüring, Marc Herrmann, Alexander Specht, Marco Ehl, Duaa Adel Ali Elsofi, Katharina Großer, Jan Jürjens, and Kurt Schneider. Generating context-aware learning materials for software security via llm agents and traceability. In *IEEE International Requirements Engineering Conference Workshops (REW)*, pages 249–258, 2025.
- [80] Akshitha Segireddy. Llm-driven automated penetration testing: Architectures, benchmarks, and safety considerations. In *International Conference on Smart Structures and Systems (ICSSS)*, pages 1–8, 2025.
- [81] Sayuj Shah and Vijay K. Madiseti. Mad-cti: Cyber threat intelligence analysis of the dark web using a multi-agent framework. *IEEE Access*, 13:40158–40168, 2025.
- [82] Asif Shahriar, Md Nafiu Rahman, Sadif Ahmed, Farig Sadeque, and Md Rizwan Parvez. A survey on agentic security: Applications, threats and defenses. *arXiv preprint arXiv:2510.06445*, 2025.
- [83] Tanush Sharanarathi and Sreenidhi Polineni. Multi-agent llm collaboration for adaptive code review, debugging, and security analysis. In *International Conference on Mechatronics, Robotics, and Artificial Intelligence (MRAI)*, pages 541–546, 2025.

- [84] Saeid Sheikhi, Panos Kostakos, and Lauri Loven. Cognitive soc: Evidence-backed narrative generation for security operations with multi-agent llm architecture. In *IEEE International Conference on Big Data (BigData)*, pages 7027–7036, 2025.
- [85] Xiangmin Shen, Lingzhi Wang, Zhenyuan Li, Yan Chen, Wencheng Zhao, Dawei Sun, Jiashui Wang, and Wei Ruan. Pentestagent: Incorporating llm agents to automated penetration testing. In *ACM Asia Conference on Computer and Communications Security*, pages 375–391, 2025.
- [86] Siddhant Srinivas, Brandon Kirk, Julissa Zendejas, Michael Espino, Matthew Boskovich, Abdul Bari, Khalil Dajani, and Nabeel Alzahrani. Ai-augmented SOC: A survey of llms and agents for security automation. *Journal of Cybersecurity and Privacy*, 5(4):95, 2025.
- [87] Yaxin Tang, Yijia Liu, Jiahe Lan, Zheng Yan, and Erol Gelenbe. Security of llm-based agents regarding attacks, defenses, and applications: A comprehensive survey. *Information Fusion*, page 103941, 2025.
- [88] Phong Tran Thanh, Phuc Nguyen Le Bao, Trong-Nghia To, Van-Hau Pham, and Phan The Duy. Leveraging llm agents for autonomous web penetration testing targeting sql injection vulnerability. In *IEEE International Conference on Big Data (BigData)*, pages 5527–5534, 2025.
- [89] Dheer Toprani and Vijay K. Madiseti. Llm agentic workflow for automated vulnerability detection and remediation in infrastructure-as-code. *IEEE Access*, 13:69175–69181, 2025.
- [90] Hugo Touvron, Thibaut Lavril, Gautier Izacard, Xavier Martinet, Marie-Anne Lachaux, Timothée Lacroix, Baptiste Rozière, Naman Goyal, Eric Hambro, Faisal Azhar, et al. LLaMA: Open and Efficient Foundation Language Models. *arXiv preprint arXiv:2302.13971*, pages 1–27, 2023.
- [91] Md. Shamim Towhid, Shahrear Iqbal, Euclides Carlos Pinto Neto, Nashid Shahriar, Scott Buffett, Madeena Sultana, and Adrian Taylor. Cyber threat mitigation with knowledge-infused reinforcement learning and llm-guided policies. In *2025 22nd Annual International Conference on Privacy, Security, and Trust (PST)*, pages 1–10, 2025.
- [92] Fares Wael, Youssef Maklad, Ali Hamdi, and Wael Elersy. An agentic flow for finite state machine extraction using prompt chaining. In *Intelligent Methods, Systems, and Applications (IMSA)*, pages 328–333, 2025.
- [93] Lei Wang, Chen Ma, Xueyang Feng, Zeyu Zhang, Hao Yang, Jingsen Zhang, Zhiyuan Chen, Jiakai Tang, Xu Chen, Yankai Lin, et al. A survey on large language model based autonomous agents. *Frontiers of Computer Science*, 18(6):186345, 2024.
- [94] Wenhao Wang, Hao Gu, Zhixuan Wu, Hao Chen, Xingguo Chen, and Fan Shi. Ptfusion: Llm-driven context-aware knowledge fusion for web penetration testing. *Information Fusion*, 127:103731, 2026.
- [95] Dominik M. Weber, Ioannis Tzachristas, and Aifen Sui. Perses: Unlocking privilege escalation for small llms via extensible heterogeneity. In *ACM Asia Conference on Computer and Communications Security*, pages 344–357, 2025.
- [96] Jason Wei, Xuezhi Wang, Dale Schuurmans, Maarten Bosma, Brian Ichter, Fei Xia, Ed Chi, Quoc V. Le, and Denny Zhou. Chain-of-Thought Prompting Elicits Reasoning in Large Language Models. In *Advances in Neural Information Processing Systems (NeurIPS)*, pages 24824–24837, 2022.
- [97] Zhiyuan Wei, Jing Sun, Yuqiang Sun, Ye Liu, Daoyuan Wu, Zijian Zhang, Xianhao Zhang, Meng Li, Yang Liu, Chunmiao Li, Mingchao Wan, Jin Dong, and Liehuang Zhu. Advanced smart contract vulnerability detection via llm-powered multi-agent systems. *IEEE Transactions on Software Engineering*, 51(10):2830–2846, 2025.
- [98] Benlong Wu, Guoqiang Chen, Kejiang Chen, Xiuwei Shang, Jiapeng Han, Yanru He, Weiming Zhang, and Nenghai Yu. Autopt: How far are we from the fully automated web penetration testing? *IEEE Transactions on Information Forensics and Security*, 20:9657–9672, 2025.
- [99] Fan Wu, Yuxin Zhang, Gaolei Li, Jianhua Li, and Jin Ma. Trustpkgb: Trustworthy protocol knowledge blueprints generation via llm for low-altitude aav networks. *IEEE Transactions on Cognitive Communications and Networking*, 12:6152–6174, 2026.
- [100] Lei Wu, Xiaofeng Zhong, Jingju Liu, and Xiang Wang. Ptgroup: An automated penetration testing framework using llms and multiple prompt chains. In *International Conference on Intelligent Computing*, pages 220–232, 2024.
- [101] Xingyu Wu, Yunzhe Tian, Yuanwan Chen, Ping Ye, Xiaoshu Cui, Jingqi Jia, Shouyang Li, Jiqiang Liu, and Wenjia Niu. CurriculumPT: LLM-Based Multi-Agent Autonomous Penetration Testing with Curriculum-Guided Task Scheduling. *Applied Sciences*, 15(16):9096, 2025.
- [102] Georgios Xenos, Emmanouil Tzagakis, Sotirios Giannopoulos, and Dimitrios Serpanos. Mad-agent: A malware analysis and detection ai agent. In *IEEE International Smart Cities Conference (ISC2)*, pages 1–6, 2025.
- [103] HanXiang Xu, ShenAo Wang, Ningke Li, Kailong Wang, Yanjie Zhao, Kai Chen, Ting Yu, Yang Liu, and HaoYu Wang. Large language models for cyber security: A systematic literature review. *ACM Transactions on Software Engineering and Methodology*, 2025.
- [104] Huiyu Xu, Wenhui Zhang, Zhibo Wang, Feng Xiao, Rui Zheng, Zhongjie Ba, and Kui Ren. Redagent: an autonomous agent for context-aware red teaming of llm jailbreaks. *IEEE Transactions on Dependable and Secure Computing*, 23(3):1–17, 2026.
- [105] Minrui Xu, Jiani Fan, Xinyu Huang, Conghao Zhou, Jiawen Kang, Dusit Niyato, Shiwen Mao, Zhu Han, Xuemin Shen, and Kwok-Yan Lam. Forewarned is Forearmed: A Survey on Large Language Model-based Agents in Autonomous Cyberattacks. *arXiv preprint arXiv:2505.12786*, pages 1–35, 2025.
- [106] Tinghui Yang, Zhiyuan Jiang, and Yongjun Wang. Llmsqli: A black-box web sqli detection tool based on large language model. In *International Conference on Big Data & Artificial Intelligence & Software Engineering (ICBASE)*, pages 629–633, 2024.
- [107] Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao. ReAct: Synergizing Reasoning and Acting in Language Models. In *International Conference on Learning Representations*, 2023.
- [108] Alperen Yildiz, Sin G Teo, Yiling Lou, Yebo Feng, Chong Wang, and Dinil Mon Divakaran. Benchmarking LLMs and LLM-based agents in practical vulnerability detection for code repositories. In *The 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, pages 30848–30865, 2025.
- [109] Zheng Yu, Ziyi Guo, Yuhang Wu, Jiahao Yu, Meng Xu, Dongliang Mu, Yan Chen, and Xinyu Xing. PATCHAGENT: A practical program repair agent mimicking human expertise. In *USENIX Security Symposium (USENIX Security 25)*, pages 4381–4400, 2025.

- [110] Pallavi Zambare, Venkata Nikhil Thanikella, Nikhil Padmanabh Kottur, Sree Akhil Akula, and Ying Liu. Netmoniai: An agentic ai framework for network security & monitoring. In *International Conference on Artificial Intelligence, Blockchain, and Internet of Things (AIBThings)*, pages 1–6, 2025.
- [111] Tadesse Zemicheal, Hsin Chen, Shawn Davis, Rachel Allen, Michael Demoret, and Ashley Song. Llm agents for vulnerability identification and verification of cves. In *CAMLIS*, pages 161–173, 2024.
- [112] Andy K. Zhang, Joey Ji, Celeste Menders, Riya Dulepet, Thomas Qin, Ron Yifeng Wang, Junrong Wu, Kyleen Liao, Jiliang Li, Jinghan Hu, Sara Hong, Nardos Demilew, Shivatmica Murgai, Jason Khiem Tran, Nishka Kacheria, Ethan Jun-shen Ho, Denis Liu, Lauren McLane, Olivia Beyer Bruvik, Dai-Rong Han, Seungwoo Kim, Akhil Vyas, Cuiyuanxiu Chen, Ryan Li, Weiran Xu, Jonathan Z. Ye, Prerit Choudhary, Siddharth M. Bhatia, Vikram Sivashankar, Yuxuan Bao, Dawn Song, Dan Boneh, Daniel E. Ho, and Percy Liang. BountyBench: Dollar Impact of AI Agent Attackers and Defenders on Real-World Cybersecurity Systems. In *Advances in Neural Information Processing Systems 38: Datasets and Benchmarks Track*, pages 1–120, 2025.
- [113] Hanrong Zhang, Jingyuan Huang, Kai Mei, Yifei Yao, Zhenting Wang, Chenlu Zhan, Hongwei Wang, and Yongfeng Zhang. Agent Security Bench (ASB): Formalizing and Benchmarking Attacks and Defenses in LLM-Based Agents. In *International Conference on Learning Representations*, pages 35331–35366, 2025.
- [114] Wayne Xin Zhao, Kun Zhou, Junyi Li, Tianyi Tang, Xiaolei Wang, Yupeng Hou, Yingqian Min, Beichen Zhang, Junjie Zhang, Zican Dong, et al. A survey of large language models. *arXiv preprint arXiv:2303.18223*, 1(2):1–124, 2023.
- [115] Xin Zhou, Sicong Cao, Xiaobing Sun, and David Lo. Large language model for vulnerability detection and repair: Literature review and the road ahead. *ACM Transactions on Software Engineering and Methodology*, 34(5):1–31, 2025.
- [116] Yuyang Zhou, Guang Cheng, Kang Du, Zihan Chen, and Yuyu Zhao. Toward intelligent and secure cloud: Large language model empowered proactive defense. *IEEE Communications Magazine*, pages 1–7, 2026.
- [117] Yuxuan Zhu, Antony Kellermann, Dylan Bowman, Philip Li, Akul Gupta, Adarsh Danda, Richard Fang, Conner Jensen, Eric Ihli, Jason Benn, Jet Geronimo, Avi Dhir, Sudhit Rao, Kaicheng Yu, Twm Stone, and Daniel Kang. CVE-Bench: A Benchmark for AI Agents’ Ability to Exploit Real-World Web Application Vulnerabilities. In *International Conference on Machine Learning*, pages 1–18, 2025.
- [118] Yuxuan Zhu, Antony Kellermann, Akul Gupta, Philip Li, Richard Fang, Rohan Bindu, and Daniel Kang. Teams of LLM agents can exploit zero-day vulnerabilities. In *Conference of the European Chapter of the Association for Computational Linguistics (Volume 1: Long Papers)*, pages 23–35, 2026.
- [119] Terry Yue Zhuo, Dingmin Wang, Hantian Ding, Varun Kumar, and Zijian Wang. Cyber-zero: Training cybersecurity agents without runtime. In *The Fourteenth International Conference on Learning Representations*, pages 1–131, 2026.
- [120] Yuwen Zou, Yang Hong, Jingyi Xu, Lekun Liu, and Wenjun Fan. Leveraging large language models for challenge solving in capture-the-flag. In *IEEE International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom)*, pages 1541–1550, 2024.
- [121] Yuwen Zou, Jia Liu, and Wenjun Fan. Ctfagent: An llm-powered agent for ctf challenge solving. *Journal of Information Security and Applications*, 96:104305, 2026.